

Privacy Data Protection Foundation

Versão 2.0 -2020

IT PARTNERS

EXIN PRIVACY & DATA PROTECTION

© Copyright 2020 by IT Partners Assessoria e Consultoria Ltda.

The information contained in this classroom material is subject to change without notice.

This material contains proprietary information that is protected by copyright.

No part of this material may be photocopied, reproduced, or translated to another language without the prior consent of IT Partners Treinamento Ltda.

Copyright © 2020 EXIN

Todos os direitos reservados. Nenhuma parte desta publicação pode ser publicada, reproduzida, copiada ou armazenada em um sistema de processamento de dados ou circulado em forma de impressos, fotos, microfilme ou qualquer outro meio sem premissão escrita do EXIN.

This course follow strictly the: “Guia de preparação – EXIN Privacy Data Protection Foundation” from Exin Netherlands – All rights reserved.





Guia de preparação

Edição 202004

Copyright © EXIN Holding B.V. 2020. All rights reserved.
EXIN® is a registered trademark.

No part of this publication may be reproduced, stored, utilized or transmitted in any form or by any means, electronic, mechanical, or otherwise, without the prior written permission from EXIN.

Conteúdo

1. Visão geral 4
2. Requisitos do exame 7
3. Lista de conceitos básicos 11
4. Literatura 16

1. Visão geral

EXIN Privacy & Data Protection Foundation (PDPF.PR)

Escopo

EXIN Privacy & Data Protection Foundation (PDPF) é uma certificação que valida o conhecimento e compreensão de um profissional sobre a proteção de dados pessoais, as regras e regulamentos da União Europeia (UE) em matéria de proteção de dados.

Resumo

Onde quer que os dados pessoais sejam coletados, armazenados, usados e, finalmente, excluídos ou destruídos, surgem preocupações sobre privacidade. Com o Regulamento Geral de Proteção de Dados (GDPR) da UE, o Conselho da União Europeia tem por objetivo reforçar e unificar a proteção de dados para todos os indivíduos da União Europeia (UE). Este regulamento afeta todas as organizações que processam os dados pessoais de titulares dados localizados em território da EU e tem efeitos além de suas fronteiras. A certificação EXIN Privacy & Data Protection Foundation abrange os principais assuntos relacionados ao GDPR.

A nova norma na série ISO/IEC 27000: ISO/IEC 27701:2019 Técnicas de Segurança – Extensão da ISO/IEC 27001 e da ISO/IEC 27002 para Gestão de Informações de Privacidade – Requisitos e Diretrizes, é útil para organizações que desejam demonstrar a conformidade com o GDPR. O conteúdo da nova norma ISO ajuda no cumprimento das obrigações do GDPR pelas organizações em relação ao processamento de dados pessoais.

Nem o GDPR nem a norma ISO fazem parte da literatura do exame. Contudo, a matriz de literatura no capítulo 4 é projetada para mostrar a ligação entre os requisitos do exame, a literatura, o GDPR e a norma ISO/IEC 27701:2019 de modo a fornecer um contexto mais amplo à certificação.

Contexto

A certificação EXIN Privacy & Data Protection Foundation faz parte do programa de qualificação EXIN Privacy & Data Protection.



Público-alvo

Todos os colaboradores precisam ter uma compreensão da proteção de dados e dos requisitos legais europeus, conforme definido no GDPR. Essa certificação é destinada a:

- Data Protection Officers (DPO),
- Compliance Officers,
- Security Officesr,
- Funcionários de RH,
- Gerentes de Processos e de Projetos.

Requisitos para a certificação

- Conclusão bem sucedida do exame EXIN Privacy & Data Protection Foundation.

Detalhes do exame

Tipo do exame:	Questões de múltipla escolha
Número de questões:	40
Mínimo para aprovação:	65% (26/40 questões)
Com consulta/anotações:	Não
Equipamentos eletrônicos permitidos:	Não
Tempo designado para o exame:	60 minutos

As Regras e Regulamentos dos exames EXIN aplicam-se a este exame.

Nível Bloom

A certificação EXIN Privacy & Data Protection Foundation testa os candidatos nos Níveis Bloom 1 e 2 de acordo com a Taxonomia Revisada de Bloom:

- Nível Bloom 1: Lembrança – depende da recuperação de informações. Os candidatos precisarão absorver, lembrar, reconhecer e recordar.
- Nível Bloom 2: Compreensão – um passo além da lembrança. O entendimento mostra que os candidatos compreendem o que é apresentado e podem avaliar como o material de aprendizagem pode ser aplicado em seu próprio ambiente. Este tipo de pergunta pretende demonstrar que o candidato é capaz de organizar, comparar, interpretar e escolher a descrição correta de fatos e ideias.

Treinamento

Horas de contato

A carga horária recomendada para este treinamento é de 14 horas. Isto inclui trabalhos em grupo, preparação para o exame e pausas curtas. Esta carga horária não inclui pausas para almoço, trabalhos extra aula e o exame.

Indicação de tempo de estudo

60 horas, dependendo do conhecimento pré-existente.

Provedor de treinamento

Você encontrará uma lista de nossos provedores de treinamento credenciados em www.exin.com.

2. Requisitos do exame

Os requisitos do exame são definidos nas especificações do exame. A tabela a seguir lista os tópicos (requisitos do exame) e subtópicos (especificações do exame) do módulo.

Requisitos do exame	Especificações do exame	Peso
1. Fundamentos e regulamentação de privacidade e proteção de dados		**47,5%**
	1.1 Definições	7,5%
	1.2 Dados pessoais	17,5%
	1.3 Fundamentos legítimos e limitação de finalidade	5%
	1.4 Requisitos adicionais para processamento legítimo de dados pessoais	5%
	1.5 Direitos dos titulares dos dados	2,5%
	1.6 Violação de dados pessoais e procedimentos relacionados	10%
2. Organizando a proteção de dados		**35%**
	2.1 Importância da proteção de dados para a organização	12,5%
	2.2 Autoridade supervisora[1]	7,5%
	2.3 Transferência de dados pessoais para países terceiros	7,5%
	2.4 Regras corporativas vinculantes (BCR) e proteção de dados em contratos	7,5%
3. Práticas de proteção de dados		**17,5%**
	3.1 Proteção de dados desde a concepção (by design) e por padrão (by default)	5%
	3.2 Avaliação de Impacto sobre a Proteção de Dados (DPIA)	5%
	3.3 Dados pessoais em uso	7,5%
	Total	**100%**

[1] Antes da introdução do GDPR, a *autoridade de proteção de dados* era chamada de autoridade nacional, sendo esta a responsável pela aplicação do regulamento sobre proteção de dados. Após a entrada em vigor do GPDR, ela agora é chamada de *autoridade supervisora*.

Especificações do exame

1 Fundamentos e regulamentação de privacidade e proteção de dados

1.1 Definições

O candidato é capaz de …

1.1.1 definir privacidade.

1.1.2 relacionar privacidade a dados pessoais e proteção dos dados.

1.1.3 descrever o contexto da legislação da União e do Estado-Membro.

1.2 Dados pessoais

O candidato é capaz de …

1.2.1 definir dados pessoais de acordo com o GDPR.

1.2.2 distinguir dados pessoais e categorias especiais de dados, como dados pessoais sensíveis.

1.2.3 descrever os direitos do titular dos dados com relação aos dados pessoais.

1.2.4 definir processamento de dados pessoais que se enquadre no escopo do GDPR.

1.2.5 listar os papéis, responsabilidades e partes interessadas conforme o GDPR.

1.3 Fundamentos legítimos e limitação de finalidade

O candidato é capaz de …

1.3.1 listar os seis fundamentos legítimos para processamento.

1.3.2 descrever o conceito e a limitação de finalidade.

1.3.3 descrever proporcionalidade e subsidiariedade.

1.4 Requisitos adicionais para processamento legítimo de dados pessoais

O candidato é capaz de …

1.4.1 descrever os requisitos para processamento legítimo de dados.

1.4.2 descrever a finalidade do processamento de dados.

1.4.3 explicar os princípios relacionados ao processamento de dados pessoais.

1.5 Direitos dos titulares dos dados

O candidato é capaz de…

1.5.1 descrever os direitos relacionados à portabilidade de dados e direito de inspeção.

1.5.2 descrever o direito ao esquecimento.

1.6 Violação de dados pessoais e procedimentos relacionados

O candidato é capaz de …

1.6.1 descrever o conceito de violação de dados pessoais.

1.6.2 explicar os procedimentos sobre como agir quando ocorre uma violação de dados pessoais.

1.6.3 dar exemplos de categorias de violação de dados pessoais.

1.6.4 descrever a diferença entre uma violação de segurança (incidente) e violação de dados pessoais.

1.6.5 listar as partes interessadas relevantes que devem ser informadas no caso de uma violação de dados pessoais.

2 Organizando a proteção de dados

2.1 Importância da proteção de dados para a organização

O candidato é capaz de …

2.1.1 listar os diferentes tipos de administração (artigos 28 e 30 do GDPR).

2.1.2 indicar quais atividades são necessárias para estar em conformidade com o GDPR.

2.1.3 definir a proteção de dados desde a concepção (by design) e por padrão (by default).

2.1.4 dar exemplos de violação de dados pessoais.

2.1.5 descrever a obrigação de notificação de violação de dados pessoais conforme estabelecido no GDPR.

2.1.6 descrever a execução das regras mediante a emissão de sanções, incluindo multas administrativas.

2.2 Autoridade supervisora

O candidato é capaz de …

2.2.1 descrever as responsabilidades gerais de uma autoridade supervisora.

2.2.2 descrever o papel e as responsabilidades de uma autoridade supervisora em relação a violações de dados pessoais.

2.2.3 descrever como uma autoridade supervisora contribui para a aplicação do GDPR.

2.3 Transferência de dados pessoais para países terceiros

O candidato é capaz de …

2.3.1 descrever a regulamentação que é aplicada na transferência de dados dentro da Área Econômica Europeia (AEE).

2.3.2 descrever a regulamentação que é aplicada na transferência de dados fora da AEE.

2.3.3 descrever a regulamentação que é aplicada na transferência de dados entre a AEE e os Estados Unidos da América (EUA).

2.4 Regras corporativas vinculantes (BCR) e proteção de dados em contratos

O candidato é capaz de …

2.4.1 descrever o conceito de BCR.

2.4.2 descrever como a proteção de dados é formalizada em contratos entre o controlador e o processador.

2.4.3 descrever as cláusulas desse tipo de contrato.

3 Práticas de proteção de dados

3.1 Proteção de dados desde a concepção (by design) e por padrão (by default)

O candidato é capaz de …

3.1.1 descrever os benefícios da proteção de dados desde a concepção e por padrão.

3.1.2 descrever os sete princípios da proteção de dados desde a concepção.

3.2 Avaliação de Impacto sobre a Proteção de Dados (DPIA)

O candidato é capaz de …

3.2.1 descrever o que um DPIA aborda e quando um DPIA deve ser realizado.

3.2.2 mencionar os oito objetivos de um DPIA.

3.2.3 listar os tópicos de um relatório de DPIA.

3.3 Dados pessoais em uso

O candidato é capaz de …

3.3.1 descrever os objetivos da Gestão do Ciclo de Vida do Dado (GCVD).

3.3.2 explicar a retenção e minimização de dados.

3.3.3 descrever o que é um cookie e qual a sua finalidade.

3.3.4 descrever o direito de oposição ao processamento de dados pessoais com finalidade de marketing direto, inclusive definição de perfis.

3. Lista de conceitos básicos

Este capítulo contém os termos e abreviaturas com que os candidatos devem se familiarizar.

Por favor, note que o conhecimento destes termos de maneira independente não é suficiente para o exame; O candidato deve compreender os conceitos e estar apto a fornecer exemplos.

Inglês	**Português**
adequate	adequado
appropriate technical and organizational measures	medidas técnicas e organizacionais apropriadas
authenticity	autenticidade
availability	disponibilidade
awareness	conscientização
benchmark	benchmark (referência comparativa)
binding corporate rules (BCR)	regras corporativas vinculantes (BCR)
certification / certification bodies	certificação / organismos de certificação
codes of conduct	códigos de conduta
collecting personal data	coletar dados pessoais
commission reports	relatórios de comissão
complaint	reclamação
compliance	conformidade
consent • child's consent • conditions for consent • explicit consent	consentimento • consentimento da criança / do menor de idade • condições para o consentimento • consentimento explícito
consistency / consistency mechanism	consistência / mecanismo de consistência
constitution	constituição
controller	controlador
cross-border processing	processamento transfronteiriço
data accuracy	exatidão de dados
data breach	violação de dados
data classification system	sistema de classificação de dados
data concerning health	dados relativos à saúde
data lifecycle management (DLM)	Gestão do Ciclo de Vida do Dado (GCVD / DLM)
data mapping	mapeamento dos dados
data privacy breach response plan	plano de resposta à violação de dados
data protection	proteção de dados
data protection authority (DPA)	Autoridade de Proteção de Dados (DPA)
data protection by default / privacy by default	proteção de dados por padrão (by default) / privacidade por padrão (by default)
data protection by design / privacy by design	proteção de dados desde a concepção (by design) / privacidade desde a concepção (by design)

data protection impact assessment (DPIA)	Avaliação de Impacto sobre a Proteção de Dados (DPIA)
data protection officer (DPO) • designation • position • tasks	Data Protection Officer (DPO) • designação • posição • tarefas / responsabilidades
data subject	titular dos dados
data subject access (facilities)	acesso do titular dos dados (instalações)
data transfer	transferência de dados
declaration of consent	declaração de consentimento
delegated acts and implementing acts • committee procedure	atos delegados e atos de implementação • procedimento de comitê
derogation	exceção
documentation obligation	obrigação de documentar
enforcement • administrative fines • administrative penalties • criminal penalties • dissuasive penalties • effective penalties • proportionate penalties	execução / fiscalização • multas administrativas • sanções administrativas • sanções criminais • sanções dissuasivas • sanções efetivas • sanções proporcionais
enterprise	empresa
EU types of legal act • decision • directive • opinion • recommendation • regulation	tipos de atos legais da União Europeia (UE) • decisão • diretiva • opinião • recomendação • regulamento
European Data Protection Board • chair • confidentiality • independence • procedure • reports • secretariat • tasks	Comitê Europeu para Proteção de Dados • presidência • confidencialidade • independência • procedimento • relatórios • secretariado • tarefas / responsabilidades
European Data Protection Supervisor (EDPS)	Autoridade Europeia para a Proteção de Dados (EDPS)
European Economic Area (EEA)	Área Econômica Europeia (AEE)
European Union legal acts on data protection	Atos jurídicos da União Europeia sobre proteção de dados
exchange of information	troca de informações
exemption	isenção
filing system	sistema de arquivos
General Data Protection Regulation (GDPR)	Regulamento Geral de Proteção de Dados (GDPR)
governing body	órgão do governo
group of undertakings	grupo empresarial
information society service	serviço da sociedade da informação
international organization	organização internacional

joint controllers	co-controladores
judicial remedy	medida judicial
lawfulness of processing	legalidade do processamento
legal basis	base legal
legitimate basis (GDPR recital 40)	fundamento legítimo (item 40 do preâmbulo do GDPR)
legitimate ground (GDPR Article 17(1c), Article 18(1d), Article 21(1))	base legítima (artigo 17(1c), artigo 18(1d), artigo 21(1) do GDPR)
legitimate interest	interesse legítimo
liability	responsabilidade
main establishment	sede da empresa
material scope	escopo de aplicação material
non-repudiation	não repúdio
notification obligation	obrigação de notificar
opinion of the board	parecer do Comitê
personal data	dados pessoais
personal data breach	violação de dados pessoais
personal data relating to criminal convictions and offences	dados pessoais relativos a condenações e infrações criminais
principles relating to processing of personal data (GDPR, Article 5) • accountability • accuracy • confidentiality • data minimization • fairness • integrity • lawfulness • purpose limitation • storage limitation • transparency	princípios relacionados ao processamento de dados pessoais (artigo 5 do GDPR) • responsabilidade • exatidão • confidencialidade • minimização de dados • equidade • integridade • legalidade • limitação de finalidade • limitação de armazenamento • transparência
prior consultation	consulta prévia
privacy	privacidade
privacy analysis	análise de privacidade
privacy officer/chief privacy officer	Privacy Officer/Chief Privacy Officer
processing (of personal data)	processamento (de dados pessoais)
processing situations • data protection rules of churches and religious associations • employment • for archiving purposes in the public interest • for scientific or historical research purposes • for statistical purposes • freedom of expression and information • National Identification Number • obligations of secrecy • public access to official documents	situações de processamento • regras de proteção de dados de igrejas e associações religiosas • emprego • para fins de arquivamento por interesse público • para fins de pesquisa histórica ou científica • para fins estatísticos • liberdade de expressão e informação • Número de Identificação Nacional • obrigações de sigilo • acesso público a documentos oficiais

processing which does not require identification	processamento que não requer identificação
processor	processador
profiling	definição de perfis
proportionality, the principle of	proporcionalidade, princípio da
pseudonymization	pseudonimização
recipient	destinatário
relevant and reasoned objection	objeção relevante e fundamentada
representative	representante
restriction of processing	limitação de processamento
retention period	período de retenção
rights of the data subject • 'right to be forgotten' • automated individual decision-making • data portability • information and access • modalities • notification obligation • rectification and erasure • restriction of processing • restrictions • right to compensation • right to objection • transparency	direitos do titular dos dados: • 'direito ao esquecimento' • tomada de decisão individual automatizada • portabilidade de dados • informação e acesso • modalidades • obrigação de notificação • retificação e apagamento • limitação do processamento • restrições • direito à compensação • direito à oposição • transparência
rules of procedure	regras de procedimento
security breach	violação de segurança
security incident	incidente de segurança
security of personal data	segurança de dados pessoais
security of processing	segurança de processamento
sensitive data	dados sensíveis
seven principles for privacy by design	sete princípios da privacidade desde a concepção (by design) e por padrão (by default)
special categories of personal data • biometric data • data concerning health • genetic data • political opinions • racial or ethnic origin • religious or philosophical beliefs • sex life or sexual orientation • trade union membership	categorias especiais de dados pessoais • dados biométricos • dados relativos à saúde • dados genéticos • opiniões políticas • origem racial ou étnica • crenças religiosas ou convicções filosóficas • vida sexual ou orientação sexual • associação sindical
subsidiarity, the principle of	subsidiariedade, princípio da
supervisory authority	autoridade supervisora
supervisory authority concerned	autoridade supervisora competente
suspension of proceedings	suspensão do processo
territorial scope	escopo de aplicação territorial
third party	terceiro

threat	ameaça
transfer of personal data to third countries and to international organizations • adequacy decision • appropriate safeguards • binding corporate rules (BCR) • derogations • disclosures • international protection of personal data	transferência de dados pessoais para países terceiros e para organizações internacionais • decisão de adequação • salvaguardas apropriadas • regras corporativas vinculantes (BCR) • exceções • divulgações • proteção internacional de dados pessoais
vulnerability	vulnerabilidade

Comentário

A tabela abaixo apresenta a tradução dos termos utilizados no GDPR, que encontra-se escrito em Português de Portugal, para Português do Brasil. (Por favor note que os materiais de exame do EXIN estão todos escritos em Português do Brasil).

Portugal	**Brasil**
responsável pelo tratamento	controlador
subcontratante	processador
encarregado da proteção de dados	Data Protection Officer (DPO)
autoridade de controlo	autoridade supervisora
coimas	multa
tratamento	processamento
derrogação	exeção
ficheiro	arquivo
por defeito	por padrão *(by default)*
pessoa singular	pessoa física
pessoa coletiva	pessoa jurídica
cláusulas-tipo	cláusulas padrão
vinculativo	vinculante

4. Literatura

Literatura do exame

O conhecimento necessário para o exame é coberto na seguinte literatura:

A. L. Besemer
White Paper – Privacidade, Dados Pessoais e GDPR
Faça o download gratuito em http://bit.ly/PDPF_PR_literature

Literatura adicional

B. European Commission
General Data Protection Regulation (GDPR) Regulation (EU) 2016/679) Regulation of the European Parliament and the Council of the European Union. Bruxelas, 6 de abril de 2016, disponível em:
http://eur-lex.europa.eu
PDF:
http://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=OJ:L:2016:119:FULL&from=EN
HTML:
http://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=OJ:L:2016:119:FULL&from=EN

C. A. Cavoukian
Privacy by Design – The 7 Foundational Principles
Information & Privacy Commissioner, Ontario, Canada
https://www.iab.org/wp-content/IAB-uploads/2011/03/fred_carter.pdf

D. A. Calder
EU GDPR, A pocket guide
IT Governance Publishing
ISBN 978-1-84928-855-2
(ou ISBN 978-1-84928-857-6 parar e-book)

Comentário

A literatura adicional destina-se exclusivamente à referência e aprofundamento do conhecimento.

O GDPR (literatura B) não é uma literatura primária de exame porque a literatura do exame fornece conteúdo suficiente sobre o GDPR. Os candidatos devem estar familiarizados com o GDPR na extensão das referências feitas na literatura do exame.

Matriz da literatura

Requisitos do exame	Especificações do exame	Referência na literatura	Referência no GDPR	Referência na ISO/IEC 27701
1. Fundamentos e regulamentação de privacidade e proteção de dados				
	1.1 Definições	A, Capítulo 1	Preâmbulo 1, 2 & Artigo 96-99	*sem referência*
	1.2 Dados pessoais	A, Capítulo 1, Capítulo 2	Artigo 4.1(a), Artigo 9.1, Artigo 17, Artigo 4.10	Sub-cláusula 7.2.2, Sub-cláusula 7.3.6
	1.3 Fundamentos legítimos e limitação de propósito	A, Capítulo 3	Artigo 6.1, Artigo 24	Sub-cláusula 7.2.2
	1.4 Requisitos adicionais para processamento legítimo de dados pessoais	A, Capítulo 3	Artigo 25, Artigo 27-32, Artigo 5	Sub-cláusula 5.2.1. *Artigo 5 é citada ao longo da norma.*
	1.5 Direitos dos titulares dos dados	A, Capítulo 4	Artigo 15, Artigo 16, Artigo 17, Artigo 18, Artigo 20, Artigo 21, Artigo 22	Sub-cláusula 7.2.2, Sub-cláusula 7.3.2, Sub-cláusula 7.3.6, Sub-cláusula 7.3.9, Sub-cláusula 7.3.10, Sub-cláusula 7.5.1
	1.6 Violação de dados pessoais e procedimentos relacionados	A, Capítulo 5	Artigo 4(12), Artigo 33, Artigo 34	Sub-cláusula 6.13.1.5
2. Organizando a proteção de dados				
	2.1 Importância da proteção de dados para a organização	A, Capítulo 2, Capítulo 3, Capítulo 5, Capítulo 6, Capítulo 7	Artigo 7, Artigo 8, Artigo 13, Artigo 25(1), Artigo 30, Artigo 83	Sub-cláusula 6.11.2.1, Sub-cláusula 6.11.2.5, Sub-cláusula 7.2.3, Sub-cláusula 7.2.4, Sub-cláusula 7.2.5, Sub-cláusula 7.2.8, Sub-cláusula 7.3.2, Sub-cláusula 7.3.6, Sub-cláusula 7.3.10, Sub-cláusula 7.5, Sub-cláusula 8.2.6, Sub-cláusula 8.5.2, Sub-cláusula 8.5.3
	2.2 Autoridade supervisora	A, Capítulo 7	Artigo 33, Artigo 34, Artigo 36	Sub-cláusula 5.2.2, Sub-cláusula 6.13.1.1, Sub-cláusula 6.13.1.5, Sub-cláusula 7.2.5
	2.3 Transferência de dados pessoais para países terceiros	A, Capítulo 7	Artigo 29, Artigo 30, Artigo 45	Sub-cláusula 7.2.8, Sub-cláusula 7.5, Sub-cláusula 8.2.2, Sub-cláusula 8.2.6

	2.4 Regras corporativas vinculantes (BCR) e proteção de dados em contratos	A, Capítulo 7	Artigo 24, Artigo 28, Artigo 47	Sub-cláusula 5.2.1, Sub-cláusula 6.12.1.2, Sub-cláusula 7.2.6, Sub-cláusula 7.2.8, Sub-cláusula 7.5.1, Sub-cláusula 8.5
3. Práticas de proteção de dados				
	3.1 Proteção de dados desde a concepção (by design) e por padrão (by default)	A, Capítulo 7, Capítulo 8	Artigo 25	Seção B.8.4, Sub-cláusula 6.11.2.1, Sub-cláusula 6.11.2.5, Sub-cláusula 7.4.2
	3.2 Avaliação de Impacto sobre a Proteção de Dados (DPIA)	A, Capítulo 8	Artigo 35	Sub-cláusula 5.2.2, Sub-cláusula 7.2.5, Sub-cláusula 8.2.1
	3.3 Dados pessoais em uso	A, Capítulo 4, Capítulo 8	*sem referência*	Seção B.8.2.3



Contato EXIN

www.exin.com

Privacy Data Protection Foundation



v. 2

1

Privacy Data Protection Foundation

0. Introdução

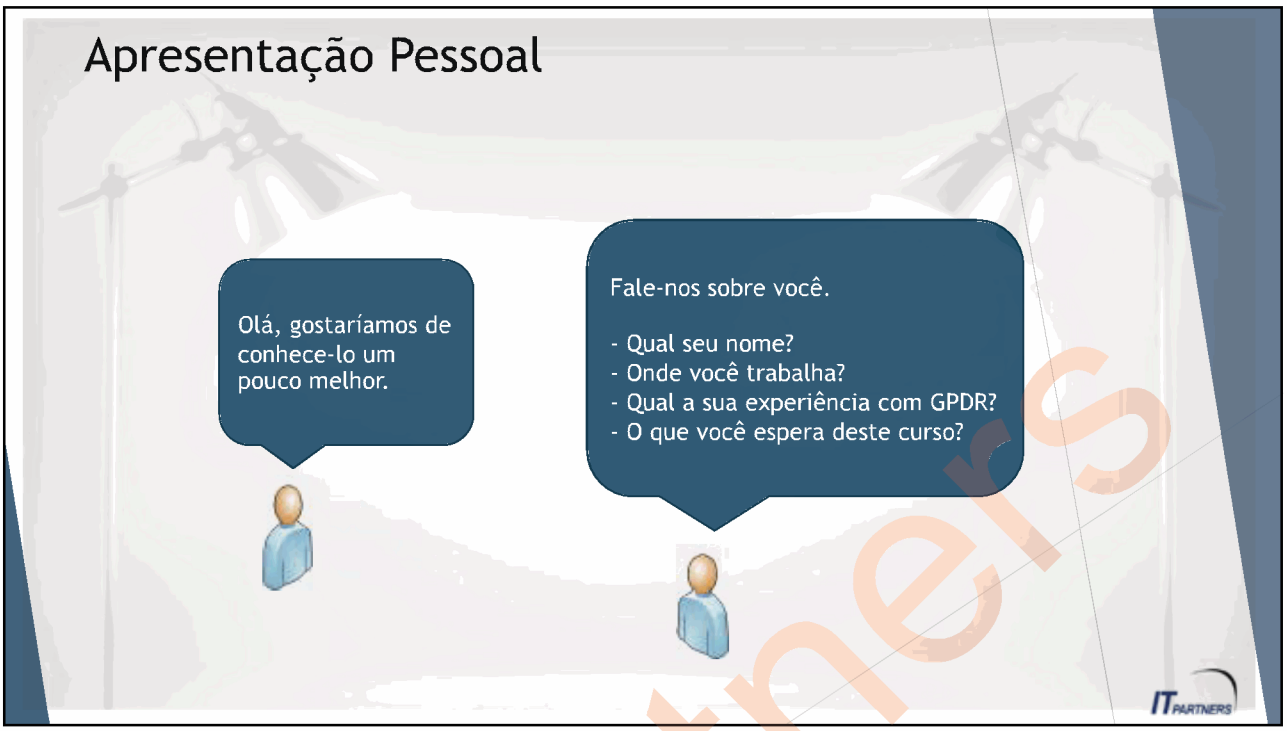
Copyright © 2020 EXIN Holding B.V. All rights reserved.

No part of this publication may be published, reproduced, copied or stored in a data processing system or circulated in any form by print, photo print, microfilm or any other means without written permission by EXIN.

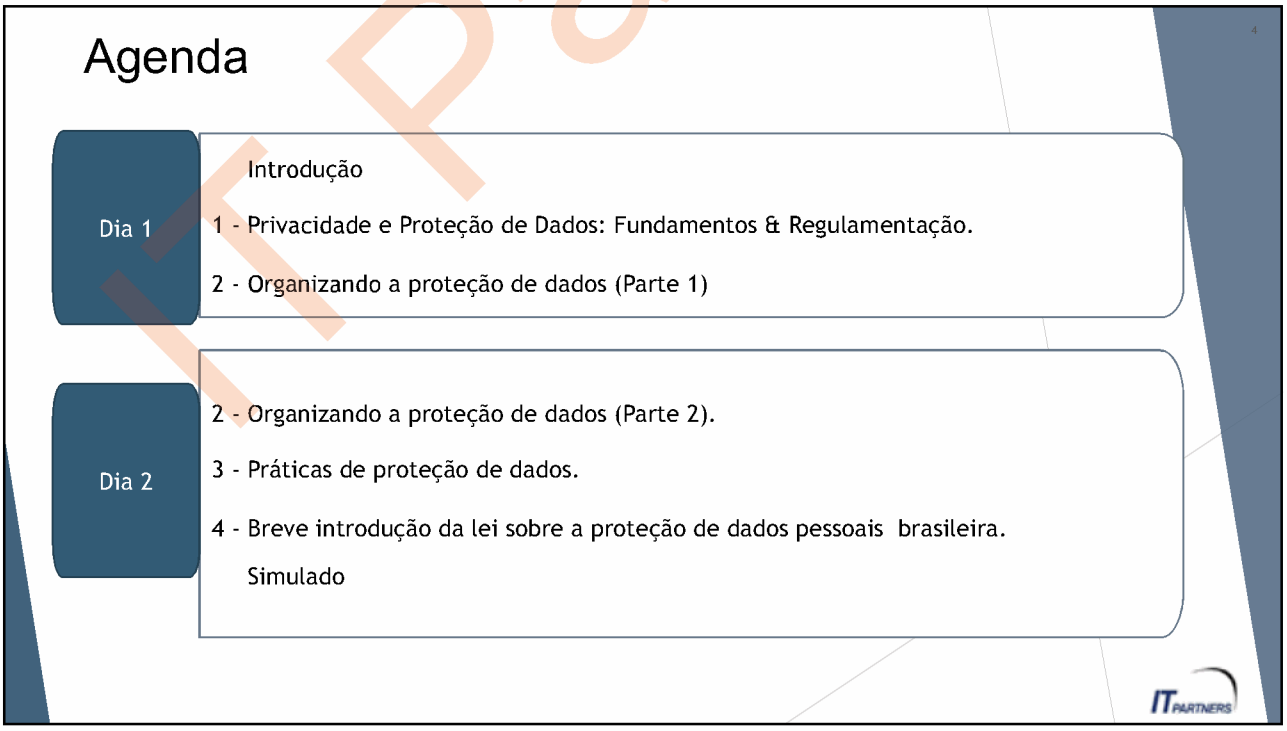
EXIN® is a registered trademark

2

IT Partners



3



4

IT Partners

Objetivos do Curso

Depois de concluir este curso, o participante estará:

- Familiarizado com a legislação, regulamentos e diretivas europeias
- Familiarizado com problemas de privacidade que possam surgir em sua própria organização
- Apto a saber como formular aconselhar para ajudar a resolver problemas de privacidade

5

Público Alvo



Todos os colaboradores precisam ter uma compreensão da proteção de dados e dos requisitos legais, conforme definido no GDPR.

As seguintes funções mais específicas podem se interessar:

- DPO (Diretor de Proteção de Dados),
- Legal Officer / Compliance Officer (Diretor Jurídico / Diretor de Conformidade)
- Security Officer (Diretor de Segurança)
- Funcionários de RH
- Gerentes de Processos e de Projetos

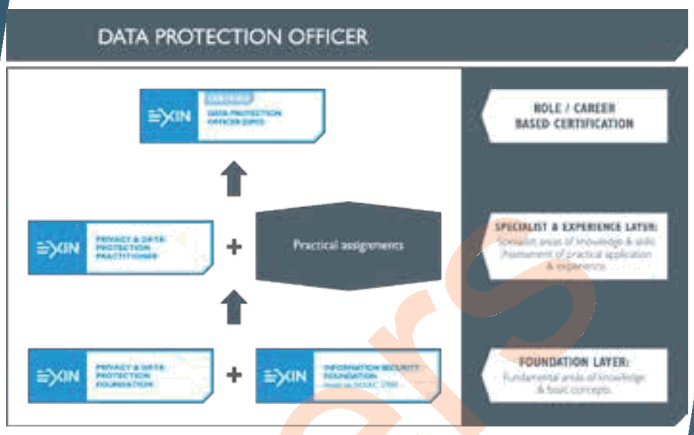
6

IT Partners

Pré-requisitos

O treinamento é uma parte obrigatória da certificação.

Espera-se que os candidatos tenham conhecimento de Segurança da Informação.



O certificado EXIN PDPF faz parte do programa de qualificação EXIN Privacy and Data Protection

7

Certificação e Exame



Requisitos para certificação:

- Treinamento no EXIN Privacy & Data Protection Certificate
- Conclusão bem sucedida dos exercícios e simulado
- Conclusão bem sucedida do exame de certificação

Detalhes do Exame:

- **Duração:** 60 minutos
- **Formato:** Em papel ou on-line utilizando computador
- **Idioma:** Disponível em português
- **Número de questões:** 40 questões de múltipla escolha
- **Nota de corte:** 65% (26 questões de 40)
- **Restrições:** Não é permitida a consulta a livros, apostilas, anotações ou qualquer outro equipamento eletrônico de apoio

8

Valor desta certificação



- O protocolo de privacidade e proteção de dados (PDPF) da EXIN é uma certificação que valida o conhecimento de um profissional sobre privacidade de dados e as regras e regulamentações da UE em relação à proteção de dados.
- As preocupações com a privacidade aumentam, onde quer que os dados pessoais sejam coletados, armazenados, usados e finalmente excluídos ou destruídos. O Regulamento Geral de Proteção de Dados da UE (GDPR) afeta todas as organizações que processam dados pessoais da UE.
- O PDPF abrange os principais assuntos relacionados a este regulamento sobre proteção de dados.

9

Exame

- Requisitos e pesos:
- Veja pg. 10-16 do Guia de Preparação
- É recomendável entender esses conceitos
- A lista de conceitos básicos é considerada entendida para o exame

Requisitos do exame	Especificações do exame	Peso
1. Fundamentos e regulamentação de privacidade e proteção de dados		**47,5%**
	1.1 Definições	7,5%
	1.2 Dados pessoais	17,5%
	1.3 Fundamentos legítimos e limitação de finalidade	5%
	1.4 Requisitos adicionais para processamento legítimo de dados pessoais	5%
	1.5 Direitos dos titulares dos dados	2,5%
	1.6 Violação de dados pessoais e procedimentos relacionados	10%
2. Organizando a proteção de dados		**35%**
	2.1 Importância da proteção de dados para a organização	12,5%
	2.2 Autoridade supervisora[1]	7,5%
	2.3 Transferência de dados pessoais para países terceiros	7,5%
	2.4 Regras corporativas vinculantes (BCR) e proteção de dados em contratos	7,5%
3. Práticas de proteção de dados		**17,5%**
	3.1 Proteção de dados desde a concepção (by design) e por padrão (by default)	5%
	3.2 Avaliação de Impacto sobre a Proteção de Dados (DPIA)	5%
	3.3 Dados pessoais em uso	7,5%
	Total	**100%**

10

IT Partners

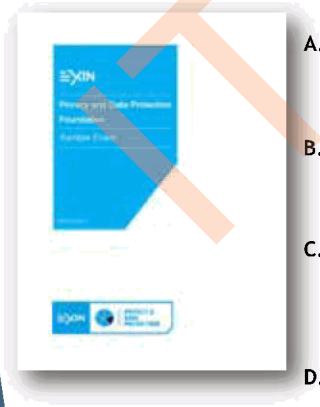
Especificações do Exame



- Tipo de exame: perguntas de múltipla escolha baseadas em computador ou em papel
- Número de questões: 40
- Marca de aprovação: 65%
- Livro aberto: não
- Equipamentos eletrônicos permitidos: Não
- Tempo previsto para exame: 60 minutos

11

Bibliografia



A. **L. Besemer**
White Paper - Privacidade, Dados Pessoais e GDPR
Faça o download gratuito em http://bit.ly/PDPF_PR_literature

B. **European Commission General Data Protection Regulation (GDPR) (Regulation (EU) 2016/679)** Regulation of the European Parliament and the Council of the European Union. Brussels, 6 April 2016

C. **A. Cavoukian**
Privacy by Design - The 7 Foundational Principles
Information & Privacy Commissioner, Ontario, Canada
https://www.iab.org/wp-content/IAB-uploads/2011/03/fred_carter.pdf

D. **Calder EU GDPR, A pocket guide IT Governance Publishing**
ISBN 978-1-84928-855-2 (E-book: ISBN 978-1-84928-857-6)

TODO MATERIAL DISPONÍVEL NO TALENTLMS

12

IT Partners



13



14

IT Partners

Privacy Data Protection Foundation

1. Fundamentos e regulamentação de Privacidade e Proteção de Dados

Copyright © 2020 EXIN Holding B.V. All rights reserved.

No part of this publication may be published, reproduced, copied or stored in a data processing system or circulated in any form by print, photo print, microfilm or any other means without written permission by EXIN.

EXIN® is a registered trademark

v. 2

1

Este módulo cobre:

Um pouco de história

1.1 Definições de privacidade.

1.2 Dados Pessoais.

1.3 Fundamentos legítimos e limitação de finalidade.

1.4 Seis princípios relativos ao processamento de dados pessoais.

1.5 Direitos dos titulares dos dados.

1.6 Violação de dados pessoais e procedimentos relacionados.

47,5%

2

IT Partners

Como tudo começou:
O progresso no processamento de dados

- O aumento no uso das telecomunicações nos anos 70 coincidiram com o desenvolvimento da União Europeia, que aumentou o comércio entre países.
- Tornava-se necessário o uso de novos padrões que permitissem aos indivíduos exercer controle sobre suas informações pessoais.
- O comércio internacional precisava de fluxo internacional livre de informações.
- O desafio era (e é) encontrar um equilíbrio entre as preocupações com a proteção das liberdades pessoais e a possibilidade de apoiar o livre comércio em toda a Europa.

3

Como tudo começou:
Convenção Europeia dos Direitos do Homem (CEDH)

Uma das primeiras proteções legais para informações pessoais foi codificada no Artigo 8 da Convenção Europeia de Direitos Humanos (ECHR) em 1953.

Fornece a base para as modernas leis europeias de privacidade.

O artigo 8º diz:

1. **Qualquer pessoa tem direito ao respeito da sua vida privada e familiar, do seu domicílio e da sua correspondência**

(https://www.echr.coe.int/Documents/Convention_POR.pdf

4

Como tudo começou:
Definições de privacidade da UE

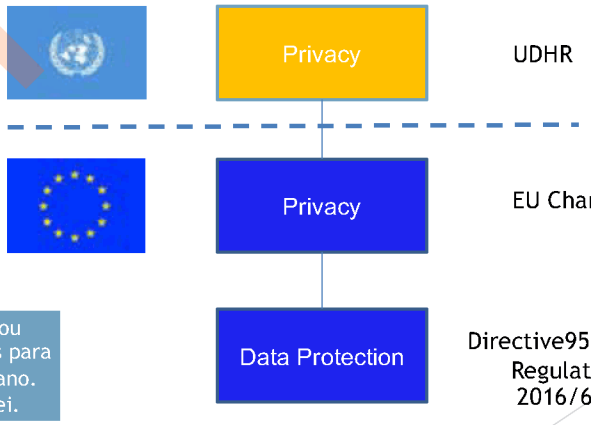
- "Todo mundo tem o direito de proteger os dados pessoais que lhes dizem respeito".
  - Tratado sobre o Funcionamento da Europa («Tratado de Roma, 1957»)
- "Todos têm o direito de proteger os dados pessoais relativos a si próprio".
  - Carta dos Direitos Fundamentais da União Europeia (2000) Primeiro considerando do Regulamento Geral de Proteção de Dados (GDPR)
  - A proteção de pessoas singulares em relação ao processamento de dados pessoais é um direito fundamental. Artigo 8.º da Carta dos Direitos Fundamentais da União Europeia (a "Carta") e
  - O artigo 16.º do Tratado sobre o Funcionamento da União Europeia (TFUE) estabelece que todas as pessoas têm direito à proteção dos dados pessoais que lhe digam respeito.

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 1.3 Definições

5

Evoluiu para uma "diretiva" para a UE e seus estados membros

Visão Geral



Diretiva: instrução ou conjunto de instruções para a execução de um plano. Não tem força de lei.

6

Da diretiva, finalmente a GDPR

- A Diretiva 95/46 / CE sobre proteção de dados relativa à proteção das pessoas singulares no que diz respeito ao tratamento de dados pessoais e à livre circulação desses dados (adoptada em 1995). Regulava o processamento de dados pessoais dentro da União Europeia.
- A Diretiva 95/46 / CE, **por ser apenas orientação FOI revogada** quando o GDPR a partir de 25 de maio de 2018
- O Regulamento Geral de Proteção de Dados (GDPR) 2016/679 é um regulamento pelo qual a Comissão Europeia pretende reforçar e unificar a proteção de dados para indivíduos dentro da União Europeia (UE).
- O regulamento foi adotado em 27 de abril de 2016 e entra em vigor em 25 de maio de 2018. A Diretiva de Proteção de Dados (& GDPR) aplica-se aos países do Espaço Econômico Europeu (EEE). Isto inclui todos os países da UE e, além disso, os países não pertencentes à UE, a Islândia, o Liechtenstein e a Noruega. (EEE EFTA)

Esta substituição é mencionada no (sub)título do regulamento. Fonte: GDPR.

7

General Data Protection Regulation (GDPR)

O GDPR define requisitos pormenorizados em matéria de coleta, armazenamento e gestão de dados pessoais, aplicáveis para empresas e organizações europeias que tratam dados pessoais na UE como também para empresas e organizações estabelecidas fora do território da UE que também tratam de dados de pessoas residentes na UE.

- Foi adotado pelo Conselho e Parlamento da UE em abril de 2016
- Entrou em vigor em todos os estados membros da UE em 25 de maio de 2018
- Estabelece os requisitos para as organizações e para os Estados Membros
- Prevê a criação de um Conselho de Proteção de Dados da UE



8

General Data Protection Regulation (GDPR)

O GDPR trata a privacidade de dados das seguintes formas:

- Estabelece as regras relativas à proteção das pessoas singulares no que diz respeito ao tratamento de dados pessoais e à livre circulação desses dados
- Defende os direitos e as liberdades fundamentais das pessoas singulares, nomeadamente o seu direito à proteção dos dados pessoais



Principal Objetivo:
Fortalecer e unificar a proteção de dados para indivíduos na União Europeia

9

A GDPR não afeta outras leis

Os Estados-Membros podem determinar ainda as condições específicas para o tratamento de um número de identificação nacional ou de qualquer outro identificador de aplicação geral.

- Outras leis nacionais:
  - Constituição
  - Código Civil
  - Lei policial
  - Lei de imposto
  - Arquivos e registros agem
  - Ato de telecomunicações
  - Etc.



10

1.1 Definições

7,5%

11

Definições

Privacidade

- É o direito **ao respeito pela vida privada de uma pessoa**, em seu âmbito familiar e de sua correspondência.
- É a habilidade de uma pessoa em controlar a exposição e a disponibilidade de informações acerca de si (Dicionário Informal).

Proteção de dados

- O GDPR é sobre a proteção de dados pessoais, não de todos os dados.

12

IT Partners

Considerações no GDPR

> O presente regulamento respeita todos os direitos fundamentais e observa as liberdade e os princípios reconhecidos na Carta, consagrados nos Tratados, nomeadamente o **respeito pela vida privada e familiar, pelo domicílio** e pelas comunicações, a proteção dos dados pessoais, a liberdade de pensamento, de consciência e de religião, a liberdade de expressão e de informação, a liberdade de empresa, o direito à ação e a um tribunal imparcial, e a diversidade cultural, religiosa e linguística.
>
> Fonte: GDPR – Considerando 4

Podemos extrair daqui uma definição implícita de privacidade.

13

Privacidade x Proteção de Dados

- **Privacidade** é o direito a ser protegido de uma interferência em assuntos pessoais.
- Abrange **vários aspectos**, como privacidade de localização, relacional, corporal e de informações.

Você não pode ter **privacidade** sem proteção de dados.

A Privacidade inclui o direito à **proteção de dados** pessoais.

- A **proteção de dados** ajuda a garantir alguns (não todos) aspectos da privacidade.
- É o **modo/meio** para implementar a proteção ao direito de privacidade.

14

IT Partners

Privacidade x Segurança da Informação

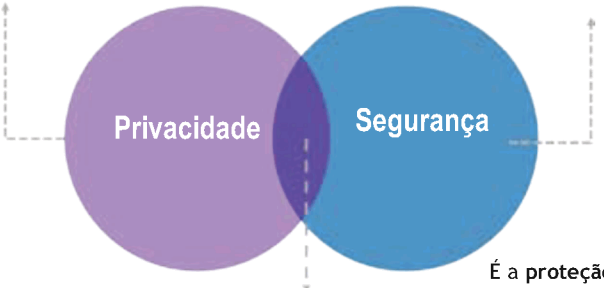
"você pode ter segurança sem privacidade,
mas não pode ter privacidade sem segurança".

15

Privacidade x Segurança da Informação

A **privacidade dos dados** pessoais vai além da segurança da informação, pois considera todo o ciclo de vida dos dados pessoais e dos processos de negócios que os utilizam.

Segurança da Informação é requisito básico para qualquer organização que deseja proteger sua confidencialidade, integridade e disponibilidade de todos os seus dados.



Segurança para garantir a privacidade

É a **proteção dos dados** pessoais contra acessos físicos e lógicos não autorizados - deve-se implementar controles físicos e lógicos

16

IT Partners

1.2 Dados Pessoais

12%

17

O que são Dados Pessoais?

'Dados pessoais' significam qualquer informação relativa a uma pessoa singular identificada ou identificável ("pessoa em causa")

Uma pessoa singular identificável é aquela que pode ser identificada, direta ou indiretamente, em particular por referência a um identificador como:

- **um nome**
- **um número de identificação**
- **Dados de localização**
- **um identificador online**

Ou a um ou mais fatores específicos da identidade física, fisiológica, genética, mental, econômica, cultural ou social daquela pessoa natural.

O GPDR não se aplica aos dados pessoais de pessoas falecidas.
Isso é tema para os Estados Membros

Fonte: EU GDPR, Um guia de bolso - Capítulo 2 Termos e definições – Dados pessoais & GDPR art. 4 (1).

18

IT Partners

Dados Pessoais

- O conceito de dados pessoais não se limita a informações que possam ser consideradas prejudiciais à vida privada e familiar do indivíduo.
- Nem o meio em que a informação está contida é relevante: o conceito de dados pessoais inclui informações disponíveis sob qualquer forma: texto, figuras, gráficos, fotografia, vídeo, acústico ou qualquer outro meio possível que leve a identificação do sujeito de modo direto ou indireto

19

Definição de **dados pessoais** de acordo o GDPR

"É a informação relativa a uma pessoa singular identificada ou identificável."

- Art. 4º GDPR («titular dos dados» "data subject"): é considerada identificável uma pessoa singular que possa ser identificada, direta ou indiretamente, em especial por referência a um identificador, como por exemplo um nome, um número de identificação, dados de localização, identificadores por via eletrônica ou a um ou mais elementos específicos da identidade física, fisiológica, genética, mental, econômica, cultural ou social dessa pessoa singular.

20

IT Partners

Tipos de dados pessoais

- **Direto**

  Dados que podem ser atribuídos a um dado específico sem o uso de informações adicionais; por exemplo. foto, DNA, etc.

- **Indireto**

  Dados que não podem ser atribuídos a um indivíduo de dados específico sem o uso de informações adicionais; por exemplo. Endereço IP, matrícula do carro, etc.

- **Pseudonimização de Dados**

  Significa o processamento de dados pessoais de tal maneira que os dados pessoais não podem mais ser atribuídos a um sujeito de dados específico sem o uso de informações adicionais. O processo é reversível (com uma chave). Considera-se dados pessoais.

- **Anonimização**

  Significa que nenhuma informação a partir da qual a pessoa a quem os dados se referem pode ser identificada. NÃO são considerado dados pessoais.

21

Anonimização de dados

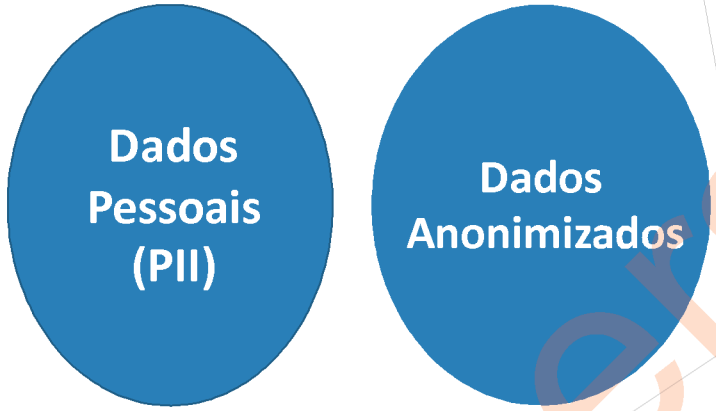
- É um processo de saneamento de dados pessoais que os altera para tornar impossível identificar quaisquer indivíduos (titulares dos dados).
- É um processo unidirecional. Não deve ser possível inverter o processo.
- Os dados anônimos ou anonimizados não são mais classificados como dados pessoais. Além de proteger a privacidade, também tira os dados do escopo do GDPR.
- Fonte: considerando 26 do GDPR



22

IT Partners

Dicotomia (forças opostas)



23

O que é anonimização? (exemplo)

TABELA 1
BASE DE DADOS RELACIONAIS

NOME	CPF	CEP	IDADE	CLASSIFICAÇÃO | SEGMENTAÇÃO
Bruno dos Santos	123.456-77	04055-000	18	Jovem hipster
Bruno dos Santos	234.567-88	04055-111	17	Jovem poupador
Bruno dos Santos	345.678-99	04055-222	17	Jovem consumista
Bruno Souza	456.789-10	01201-000	65	Idoso com rentabilidade
Bruno Souza	567.891-01	04201-111	66	Idosa sem rentabilidade
Bruna Schonberg	222.333.44-55	04201-222	70	Idosa com rentabilidade
Maria Silva	157.890.88-66	09201-000	40	Adulto desempregado
Maria Silva	666.666.66-66	09201-111	38	Adulto perfil executivo
Maria Silva	987.354.22-99	09201-222	16	Jovem hipster

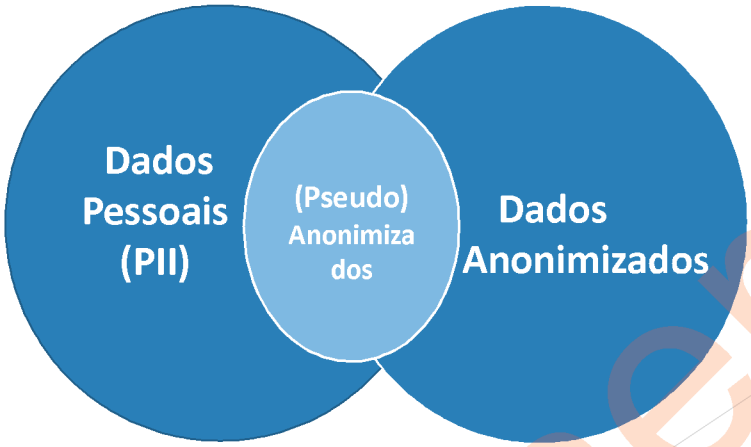
TABELA 2
BASE DE DADOS RELACIONAIS ANONIMIZADA

NOME	CPF	CEP	IDADE	CLASSIFICAÇÃO | SEGMENTAÇÃO
Bruno		04055-	18 >	Jovem hipster
Bruno		04055-	18 >	Jovem poupador
Bruno		04055-	18 >	Jovem consumista
Bruno		01201-	60 <	Idoso com rentabilidade
Bruno		04201-	60 <	Idosa sem rentabilidade
Bruna		04201-	60 <	Idosa com rentabilidade
Maria		09201-	18 <	Adulto desempregado
Maria		09201-	18 <	Adulto perfil executivo
Maria		09201-	18 >	Jovem hipster

24

IT Partners

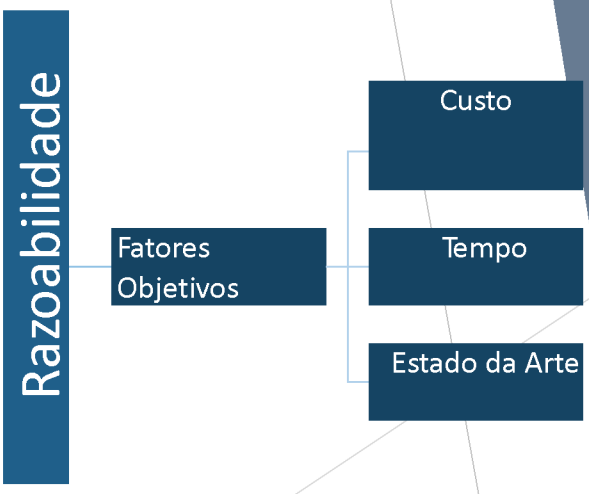
Zona Cinzenta



25

Pseudonimização de dados

- É referida no Artigo 4 do GDPR e é um processo que substitui os identificadores de dados pessoais por dados fictícios realistas, conhecidos como pseudônimo ou token
- Ao contrário da anonimização, a pseudonimização de dados pessoais destina-se a permitir a **reidentificação** de dados pessoais quando necessário.
- Um valor de pseudônimo substitui os campos de dados pessoais no conjunto de dados do aplicativo.
- Essa substituição de dados é rastreada em uma tabela de consulta separada, que pode ser usada para identificar dados pessoais.



26

IT Partners

Categorias especiais de dados pessoais ("dados pessoais sensíveis")

O GDPR distingue várias categorias de dados pessoais que merecem um tratamento especial.



- Dados que revelem origem racial ou étnica
- opiniões políticas
- crenças religiosas ou filosóficas ou filiação sindical
- dados genéticos
- dados biométricos com o propósito de identificar unicamente uma pessoa
- dados relativos à saúde
- dados relativos à vida sexual ou orientação sexual de uma pessoa singular

O GDPR também define quais são as isenções a essa regra.

Fonte: GDPR art. 9, §10 - Categorias especiais de dados pessoais.

27

Distinção: Dados Pessoais x Dados Sensíveis

Dados pessoais ("*personal data*") :

- nome completo,
- RG,
- CPF,
- e-mail,
- endereço, entre outros.

Dados sensíveis ("*sensitive data*"):

- opção sexual,
- convicções religiosas,
- filosóficas ou morais, entre outros.

É proibido processar os dados pessoais especiais, exceto nos casos explicitamente mencionados no Artigo 9 do GDPR. Exemplo de permissão: quando o titular der o consentimento.

Pode haver elevado risco para os titulares em caso de violação de dados sensíveis.

28

IT Partners

Exceções à proibição de tratamento de dados sensíveis

A proibição não se aplica se verificar um dos seguintes casos:

1. Consentimento explícito.
2. Cumprir obrigação legal trabalhista ou previdenciária.
3. Necessário para proteger interesses vitais do Titular de Dados.
4. Para entidades sem fins lucrativos tratarem esses dados ligados à sua finalidade de atuação (membros + confidencialidade).
5. Dados já tornados públicos pelo próprio Titular.
6. Para declaração ou defesa em processo judicial.
7. Interesse público.
8. Medicina preventiva ou do trabalho.
9. Saúde pública.
10. Investigação científica ou histórica, ou para fins estatísticos.

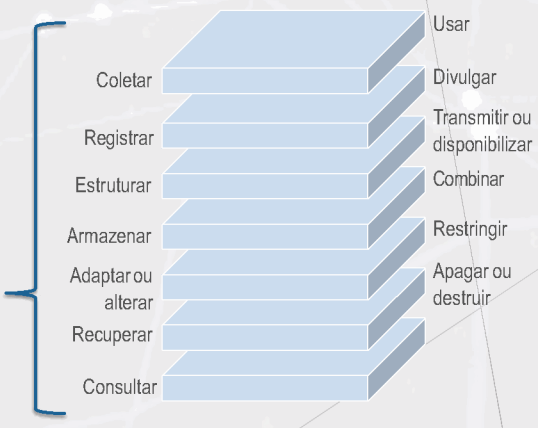
Fonte: GDPR artigo 9 (2)

29

Processamento dos Dados Pessoais
(ou atividades de tratamento)

É qualquer operação ou conjunto de operações que são realizadas com dados pessoais ou em conjuntos de dados pessoais, sendo ou não feitas de modo automatizado.

O GDPR aplica-se a todo tipo de tratamento feito a dados pessoais.

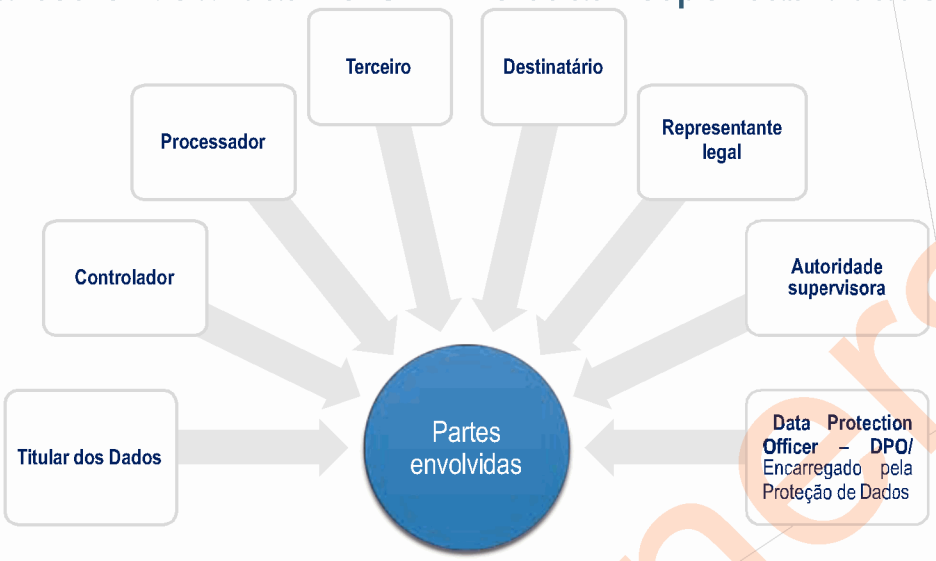


Principais atividades de tratamento

Fonte: GDPR art.4 (1)

30

Partes envolvidas no GDPR e suas responsabilidades



31

Partes envolvidas no GDPR e suas responsabilidades

Titular dos Dados	Pessoa física a quem os dados fazem referência (exceção: pessoa falecida).
Controlador	Citado no GDPR como Responsável pelo Tratamento. Pode ser uma pessoa física ou jurídica, autoridade pública, agência ou outro organismo que determina os objetivos/finalidades e os meios do tratamento de dados pessoais.
Processador	Citado no GDPR como Subcontratante. Pode ser pessoa física ou jurídica, autoridade pública, agência ou outro organismo que processe dados pessoais em nome do responsável pelo tratamento (Controlador).
Terceiro	Pessoa física ou jurídica que não seja o Titular de Dados, o Controlador ou o Processador e que esteja autorizada a processar dados pessoais ("Subprocessador").
Destinatário	Pessoa física ou jurídica, autoridade pública, agência ou outro organismo para quem os dados pessoais são divulgados, terceiros ou não.

32

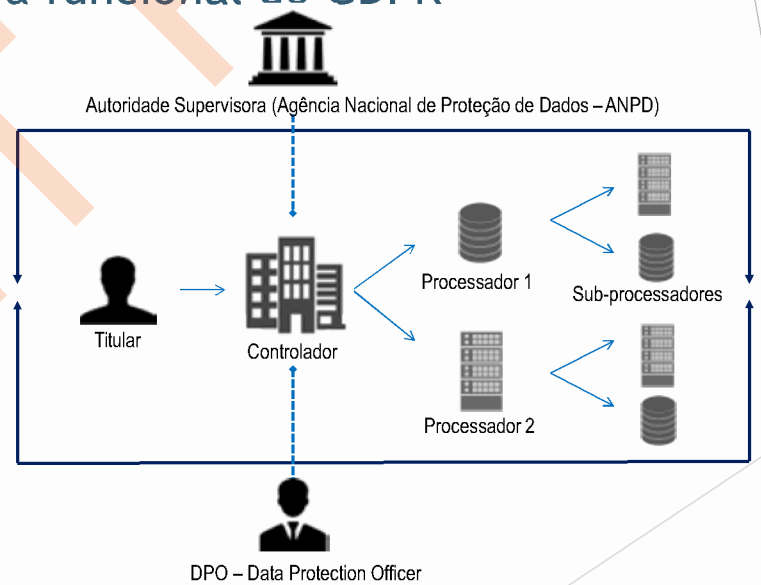
IT Partners

Partes envolvidas no GDPR e suas responsabilidades

Data Protection Officer (DPO)	Orienta a implementação de medidas apropriadas para *compliance* (conformidade/adequação legal) do controlador ou processador.
Representante legal	Pessoa física ou jurídica (na UE) designada pelo Controlador ou Processador para representá-lo perante a autoridade supervisora e os titulares dos dados. É requerido conforme GDPR artigo 27.
Autoridade supervisora	Autoridade pública independente estabelecida por um Estado-Membro da UE.

33

Estrutura funcional do GDPR



34

IT Partners

Aplicabilidade

O GDPR aplica-se a:

- organizações dentro da UE, e para
- quaisquer organizações externas que estão negociando dentro da UE.

Isso potencialmente inclui organizações em todo o mundo, independentemente de quão difícil possa ser para aplicar o Regulamento.

Com o objetivo de impedir que as organizações europeias trabalhem com empresas e estados que não cumprem os requisitos do regulamento, tanto o responsável pelo tratamento de dados (provável que esteja na UE) como o processador de dados são responsáveis em caso de violação de dados.

35

1.3 Fundamentos legítimos e limitação de propósito

5%

36

IT Partners

Fundamentos legítimos

O processamento somente será lícito se ao menos um dos motivos abaixo se aplicarem:

- Consentimento ambíguo para o processamento (pelo sujeito dos dados)
- Necessário para a execução de um contrato em que o titular dos dados é parte
- O processamento é necessário para cumprir uma obrigação legal à qual a parte responsável está sujeita

37

Fundamentos legítimos e limitação de propósito

FUNDAMENTO	EXPLICAÇÃO
1) Consentimento	O titular dos dados dá o seu consentimento ao processamento dos seus dados pessoais para um ou mais fins específicos, explícitos e legítimos.
2) Execução de contrato	O processamento é necessário para execução de um contrato no qual o titular dos dados é parte ou para tomar medidas a pedido do titular dos dados antes de celebrar um contrato.
3) Cumprimento de obrigação legal, por parte do Controlador	Cumprimento de uma obrigação legal a que o Controlador está sujeito.
4) Proteção de interesse vital	Proteção de um interesse vital do titular dos dados ou de outra pessoa física.
5) Interesse Público/Exercício de Autoridade	Realização de tarefa do interesse público ou no exercício de autoridade oficial conferida ao responsável pelo tratamento.
6) Legítimo interesse do Controlador ou Terceiro*	Defender os interesses legítimos do Controlador ou de um Terceiro, exceto nos casos em que os interesses, direitos fundamentais e liberdades do titular dos dados, prevaleçam, e em especial se o titular dos dados for uma criança

38

IT Partners

Fundamentos legítimos e limitação de propósito

FUNDAMENTO	EXEMPLO
1) Consentimento	Empresa disponibiliza uma aplicação de música e solicita o consentimento dos cidadãos para efetuar o tratamento das suas preferências musicais a fim de lhes poder oferecer sugestões personalizadas de músicas e concertos
2) Execução de contrato	A organização vende via internet e antes de celebrar o contrato pode, portanto, efetuar o tratamento do nome, do endereço de entrega, do número de cartão de crédito (se o pagamento for efetuado por cartão)
3) Cumprimento de obrigação legal, por parte do Controlador	Uma empresa para obter cobertura da seguridade social, é obrigada por lei a fornecer os dados pessoais (por exemplo, o rendimento semanal dos seus trabalhadores) à autoridade competente.
4) Proteção de interesse vital	Um hospital está tratando de uma vítima de acidente rodoviário grave e precisa pesquisar a sua identidade e verificar se a pessoa existe na base de dados do hospital, a fim de consultar o seu processo clínico
5) Interesse Público/Exercício de Autoridade	uma associação profissional investida de autoridade pública para esse fim, pode instaurar processos disciplinares contra alguns dos seus membros
6) Legítimo interesse do Controlador ou Terceiro*	A empresa garante a segurança da sua rede através do controle da utilização dos dispositivos informáticos dos seus colaboradores limitando o acesso a determinados sites.

39

39

Consentimento

Definição

- Qualquer indicação livre, específica, informada e inequívoca dos desejos do titular dos dados, pela qual ele ou ela, por uma declaração ou por uma ação afirmativa clara, significa acordo para o tratamento de dados pessoais relativos a ele ou ela.
- O Titular dos dados deve dar o consentimento de forma ativa e clara e a Organização tem de conseguir demonstrar a todo o momento que o consentimento foi obtido de acordo com o GDPR.
- O Titular dos Dados pode retirar o consentimento a qualquer momento.

40

IT Partners

Consentimento

Alguns serviços e informações que necessitam de consentimento:

- ✓ Google Maps
- ✓ Google Analytics
- ✓ Matomo (antigo *Piwik*)
- ✓ *Omniture*
- ✓ Facebook, Twitter, Instagram e outras mídias sociais (exceto os links)
- ✓ Inserção de vídeos *Youtube*, *Vimeo* e outros; e,
- ✓ Todas as ferramentas de conversação externas (*Chatbot*).



41

Consentimento

Em geral, e preciso ter o consentimento de um usuário de dados para processar seus dados.

Há circunstâncias específicas em que o consentimento não é estritamente necessário, geralmente em torno de requisitos legais (como em conformidade com outra lei, ou para proteger os direitos de um titular de dados) ou quando o consentimento do sujeito de dados é fornecido por meio de um contrato que eles têm com um terceiro.

Além desses tipos de isenções, é preciso garantir o consentimento para o processamento das informações pessoais de qualquer pessoa.

O consentimento deve ser dado após a apresentação da especificação da finalidade e antes da coleta dos dados pessoais

42

IT Partners

Garantindo o consentimento

Os responsáveis pelo tratamento dos dados terão de garantir que o consentimento é claro e inequívoco da pessoa em causa antes de processar seus dados pessoais.

O controlador não pode usar o "Silêncio, caixas pré-marcadas ou inatividade" como prova de consentimento.

Além disso, o processamento não pode prosseguir a menos que o titular dos dados tenha consentido em todas as atividades de processamento.

Por exemplo:

Se você deseja realizar seis ações diferentes com os dados do participante, é necessário garantir que o assunto tenha sido consentido cada um eles.

43

Crianças menores de 16 anos

Crianças menores de 16 anos não podem mais consentir que seus dados pessoais sejam processados.

Isso pode forçar algumas organizações a fazer mudanças significativas na maneira de operar.

A obtenção do consentimento do "detentor da responsabilidade parental" pode estar em qualquer lugar entre o difícil e o impossível.

44

IT Partners

Fornecendo o consentimento

O regulamento observa que o consentimento pode ser fornecido eletronicamente (tick-box, manualmente, opt-in)

O GDPR exige que o documento de consentimento seja estabelecido em termos simples:

"o pedido deve ser claro, conciso e não desnecessariamente perturbador para o uso do serviço para o qual é fornecido".

Isso pode ser problemático, especialmente quando e necessário o consentimento para uma variedade de atividades.

> Exemplo: Caso uma contratada contrate um processamento externo de dados pessoais, esta deverá assinar um contrato com a outra parte. As obrigações e direitos do controlador devem governar esse contrato.

Fonte: EU GDPR, Um guia de bolso - Capítulo 3 O Regulamento – Contratos de controladores/processadores

45

Documentação de consentimento e retirada

O direito à retirada de consentimento

A documentação do consentimento é crucial, e essa é uma área-chave na qual a contribuição legal de seus consultores profissionais é essencial.

O consentimento pode ser retirado, as organizações precisam de um processo formal e eficiente para permitir que os titulares de dados removam o consentimento,

O regulamento exige que o responsável pelo tratamento de dados forneça um método pelo qual seja "tão fácil retirar o consentimento quanto dá-lo".

Os aplicativos precisam incluir soluções robustas para permitir que os titulares de dados retirem seu consentimento de acordo com esse requisito.

46

IT Partners

Limitação de finalidade

Especificação de Finalidades:

- ✓ Somente serão coletados dados pessoais para fins específicos, explícitos e legítimos.
- ✓ O processamento adicional não é permitido por nenhuma outra razão, a menos que isso seja declarado separadamente no GDPR.

Está ligado ao princípio de minimização de dados:

- ✓ Adequados, relevantes e limitados ao que for necessário para a finalidade do processamento.

Os dados processados devem ser relevantes

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 3.1.2 Proporcionalidade e subsidiariedade

47

Limitação de finalidade

Isso está ligado ao princípio de **minimização dos dados.**

▶ Por outro lado, o processamento é permitido para fins de arquivamento de interesse público, científico ou para pesquisa histórica ou estatística, desde que, de acordo com o GDPR, as salvaguardas apropriadas para os direitos e liberdades do Titular dos Dados estejam em vigor.



Fonte: Baseado no parecer do Grupo de Trabalho do Artigo 29 sobre limitação de finalidade, § III.1.1. (acessado em 29 de março de 2017)

48

IT Partners

Proporcionalidade

Isso está ligado ao princípio de **minimização dos dados.**

O processamento de dados pessoais tem sempre que cumprir as regras da "legalidade do processamento"; em outras palavras, você precisa ter motivos legítimos para fazê-lo.

Precisam se mantidos em uma forma que permita a identificação dos titulares por um período não mais que o necessário considerando a finalidade para o qual o dado foi coletado.

O princípio básico é que o processamento de categorias especiais de dados pessoais NÃO é permitido e a provisão para exceções foi feita na legislação.

Por exemplo. razões médicas urgentes, etc.

Os dados pessoais devem ser adequados, relevantes e limitados em relação às finalidades.



Fonte: GDPR - § 3.1.2 Proporcionalidade e subsidiariedade & GDPR art. 35 (7)

49

Subsidiariedade

É um princípio que diz que dados pessoais só podem ser processados se não houver outros meios para atingir a finalidade.

- A subsidiariedade é encontrada na regra geral que exige que os dados pessoais só possam ser processados se não houver outros meios para alcançar os objetivos. *Ser o menos transgressor possível*. Um dos seis fundamentos jurídicos: o processamento é necessário para os interesses legítimos perseguidos pelo controlador ou por um terceiro.

Exemplo: para descobrir quantas pessoas passeiam por uma rua em um dia, não é necessário saber quem elas são. Seria possível contá-las usando o sinal do telefone. No entanto, como o sinal Wi-Fi leva ao indivíduo que possui o smartphone, ele é considerado um dado pessoal. Neste caso, existiriam outras maneiras de contar o número de pessoas que passam por uma rua sem usar dados pessoais.

50

IT Partners

1.4 Requisitos adicionais para processamento legítimo de dados

5%

51

Requisitos para processamento legítimo de dados

O processamento só será lícito se:

- O titular dos dados der consentimento explícito.
- Domínio do direito do emprego e da segurança social e da proteção social (se autorizado).
- Para proteger os interesses vitais do titular dos dados (ou de outra pessoa).
- Atividades de uma fundação, associação ou outro organismo sem fins lucrativos com o seguinte objetivo: político, filosófico, religioso, sindical.
- Dados pessoais que são manifestamente tornados públicos pela pessoa em causa.
- Exercício ou defesa de reclamações legais.
- Por razões de interesse público substancial.
- Para fins médicos (e medicamente relacionados).
- Razões de interesse público na área da saúde pública.
- Objetivos de arquivamento no interesse público, para fins de pesquisa científica ou histórica ou para fins estatísticos.

52

IT Partners

Finalidade do processamento de dados

Com base no GDPR, só podem ser processados dados pessoais por um motivo.

O processamento também inclui a coleta de dados.

Esse objetivo deve ser:

- Específico
- Explícito
- Legítimo
- E declarado antes de qualquer dado pessoal ser processado

Além disso, também deve haver uma base legítima.



53

Princípios de Processamento de Dados (1/2)

1. **Legalidade, justiça e transparência**: Os dados pessoais devem ser processados de forma legal, justa e transparente em relação ao titular dos dados.
2. **Limitação de finalidade**: Os dados pessoais devem ser coletados para fins específicos, explícitos e legítimos e não devem ser processados de maneira incompatível com esses propósitos.
3. **Minimização de dados**: Os dados pessoais devem ser adequados, relevantes e limitados ao necessário em relação aos fins para os quais são processados.

54

IT Partners

Princípios de Processamento de Dados (2/2)

4. **Exatidão**: Os dados pessoais devem ser precisos e, quando necessário, atualizados: Todo passo razoável deve ser tomado para garantir que os dados pessoais que são imprecisos sejam retificados ou excluídos.
5. **Limitação de armazenamento**: Os dados pessoais devem ser mantidos em um formato que permita a identificação dos titulares de dados por não mais do que o necessário para as finalidades para as quais os dados pessoais são processados; etc.
6. **Integridade e confidencialidade**: Os dados pessoais devem ser processados de forma a garantir a segurança apropriada dos dados pessoais, incluindo proteção contra processamento não autorizado ou ilegal e contra perda, destruição ou dano acidental, usando medidas técnicas ou organizacionais apropriadas.

55

5%

1.5 Direitos do titular dos dados

56

IT Partners

Direitos dos titulares de dados

DIREITO DE SER INFORMADO	DIREITO DE LIMITAR O PROCESSAMENTO
O controlador deve ser transparente sobre a coleta e processamento dados pessoais e o a finalidade pretendida. Os titulares devem ser informados sobre seus direitos e como eles terão acesso.	O titular tem o direito de solicitar a interrupção do processamento dos seus dados.
DIREITO DE ACESSO	DIREITO DE PORTABILIDADE DOS DADOS
O titular tem o direito de acessar os seus dados. O controlador deve possibilitar isso em seus processos de negócio e criar meios técnicos adequados.	O controlador terá que ter meios de exportar dados pessoais e enviar para o titular.
DIREITO DE RETIFICAÇÃO	DIREITO DE OPOSIÇÃO
O titular tem o direito de corrigir os seus dados que acredita estarem incorretos.	O titular tem o direito de se opor ao processamento de seus dados.
DIREITO DE APAGAR	DIREITOS EM RELAÇÃO A DECISÕES AUTOMATIZADAS
O controlador precisa fornecer ao titular o direito de ser esquecido. Porém é importante considerar o interesse legítimo do controlador em manter retido certos dados.	O titular tem o direito de não ficar sujeito exclusivamente a decisões baseadas em processamento automatizado, incluindo definições de perfis.

Fonte: EU GDPR, Um guia de bolso - Capítulo 3 O Regulamento – Direitos dos titulares dos dados

57

Direitos dos titulares de dados

Para o exame

DIREITO DE SER INFORMADO	DIREITO DE LIMITAR O PROCESSAMENTO
O controlador deve ser transparente sobre a coleta e processamento dados pessoais e o a finalidade pretendida. Os titulares devem ser informados sobre seus direitos e como eles terão acesso.	O titular tem o direito de solicitar a interrupção do processamento dos seus dados.
DIREITO DE ACESSO	DIREITO DE PORTABILIDADE DOS DADOS
O titular tem o direito de acessar os seus dados. O controlador deve possibilitar isso em seus processos de negócio e criar meios técnicos adequados.	O controlador terá que ter meios de exportar dados pessoais e enviar para o titular.
DIREITO DE RETIFICAÇÃO	DIREITO DE OPOSIÇÃO
O titular tem o direito de corrigir os seus dados que acredita estarem incorretos.	O titular tem o direito de se opor ao processamento de seus dados.
DIREITO DE APAGAR	DIREITOS EM RELAÇÃO A DECISÕES AUTOMATIZADAS
O controlador precisa fornecer ao titular o direito de ser esquecido. Porém é importante considerar o interesse legítimo do controlador em manter retido certos dados.	O titular tem o direito de não ficar sujeito exclusivamente a decisões baseadas em processamento automatizado, incluindo definições de perfis.

Fonte: EU GDPR, Um guia de bolso - Capítulo 3 O Regulamento – Direitos dos titulares dos dados

58

IT Partners

Direito de acesso

O titular dos dados terá o direito de obter confirmação do controlador sobre se os seus dados pessoais estão ou não sendo processados e, em caso positivo, o acesso a eles e às seguintes informações:

Fonte: GDPR Artigo 15

O Controlar deverá ser obrigado a responder aos pedidos do titular dos dados sem demora injustificada e o mais tardar no prazo de um mês e expor as suas razões quando tiver intenção de recusar o pedido.

Fonte: GDPR - Considerando 30

Informações que o titular tem direito:

- ✓ Finalidade do processamento dos dados.
- ✓ Categorias dos dados pessoais em questão.
- ✓ Para quem os seus dados são divulgados.
- ✓ Prazo previsto para o processamento.
- ✓ Existência de direitos de solicitar retificação, apagamento ou limitação de processamento.
- ✓ Procedimento para abrir uma reclamação a uma autoridade supervisora.
- ✓ Fontes indiretas de coleta de seus dados.
- ✓ Existência decisões automatizadas.

59

Direitos de portabilidade dos dados

- O titular dos dados tem o direito de receber os dados pessoais que lhe são fornecidos, que forneceu a um responsável pelo tratamento, num formato estruturado, habitualmente utilizado e legível por máquina, e tem o direito de os transmitir para outro controlador sem impedimento do controlador para o qual os dados pessoais foram fornecidos.
- O titular dos dados tem o direito de obter, da confirmação do responsável pelo tratamento, se os dados pessoais relativos a ele ou dela estão sendo processados e, se for o caso, o acesso aos dados pessoais e as seguintes informações:
  - Finalidade do processamento, Categorias, Destinatários, período previsto de processamento, existência de direitos específicos, procedimento de reclamações, fontes indiretas de coleta, existência de tomada de decisão automática.

60

IT Partners

Direito de apagar

Direito de apagar ("direito de ser esquecido")

- O titular dos dados tem o direito de obter do responsável pelo tratamento o apagamento de dados pessoais que lhe digam respeito, sem atrasos indevidos (1 mês).

Motivos para ter os dados apagados

- Não são mais necessários para os fins para os quais foram coletados / processados
- Retirada do consentimento
- Os dados foram coletados para uma oferta de serviços de informação diretamente a uma criança menor de 16 anos.
- Objeções ao processamento.
- Processamento ilegal.
- Conformidade com a legislação da União ou do Estado-Membro aplicável ao controlador



61

1.6 Violação de dados e procedimentos relacionados

10%

62

IT Partners

Violação de segurança e violação de dados

Violação de segurança *"incidente de segurança"* - Evento que tem um impacto negativo na confidencialidade, integridade ou disponibilidade de informações.

- Por exemplo. perda de uma cartão USB ou laptop, hackeamento de um sistema.

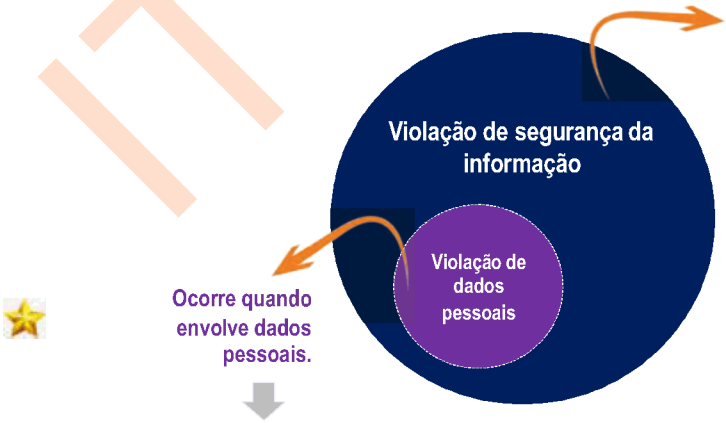
Violação de dados pessoais - É uma violação da segurança que conduz à **destruição** acidental ou ilegal, **perda, alteração**, divulgação não autorizada ou acesso a **dados pessoais** transmitidos, armazenados ou tratados de outro modo.

Fonte: GDPR Artigo 15(1)

Uma *violação de dados* é uma *violação de segurança* envolvendo dados pessoais.

63

Violação de segurança da informação e violação de dados pessoais



- **É um incidente de segurança.**
- Evento que tem impacto negativo na CID (confidencialidade, integridade e disponibilidade).

Exemplo: perda de USB ou laptop com informações confidenciais do negócio.

Ocorre quando envolve dados pessoais.

Exemplo: um hacker acessa um servidor e rouba dados de clientes da empresa.

64

IT Partners

Violação de dados pessoais

- Violação de dados pessoais é uma violação da segurança que conduz à destruição acidental ou ilegal, perda, alteração, divulgação não autorizada ou acesso a dados pessoais transmitidos, armazenados ou tratados de outro modo.
- Em outras palavras, uma violação de dados pessoais ocorre quando dados pessoais caem nas mãos de terceiros que não devem ter acesso a eles. *É sempre um incidente de segurança.*
- Inclui: nome, endereço, número de telefone, e-mail, aniversário, informação sobre saúde e NÃO inclui informações corporativas (por exemplo, sobre um processo de produção ou pesquisa.

Definição GDPR: Uma brecha de segurança que leva à destruição acidental ou ilegal, perda, alteração, divulgação não autorizada ou acesso a dados pessoais transmitidos, armazenados ou processados de outra forma.

Fonte: EU GDPR, Um guia de bolso - Capítulo 3 O Regulamento – Violações de dados & GDPR artigo 4 (12)

65

Agindo na violação de dados

O GDPR determina a informação tanto da autoridade de supervisão como dos próprios titulares de dados

Ambos - controladores e processadores são obrigados a:

"Implementar medidas técnicas e organizacionais adequadas para garantir um nível de segurança adequado ao risco".

Se a violação representar um risco para o indivíduo, a organização tem de notificar a autoridade de controle no prazo de 72 horas, após tomar conhecimento da violação.

(Artigo 32 do GDPR)

Normas de segurança da informação, como a ISO/IEC 27001, estão em vigor, com procedimentos para lidar com o incidente com o objetivo de reparar os danos e evitar que o incidente aconteça novamente.

Fonte: EU GDPR, Um guia de bolso - Capítulo 3 O Regulamento – Violações de dados GDPR artigo 4 (12)

66

IT Partners

Notificação de violação de dados



Responsabilidades:

Controlador

- A obrigação de notificação de violação de dados se dirige à parte responsável pelo processamento de dados pessoais (Controlador)

Processador

- "O Processador deve notificar o Controlador sem demora indevida após tomar conhecimento de uma violação de dados pessoais"

Comunicação ao titular do dado

- Quando a violação resultar num elevado risco para os direitos e liberdades dos indivíduos, estes também terão de ser notificados diretamente.

Fonte: Livro Branco - Privacidade, Dados Pessoais e o GDPR - § 5.2 Procedimentos sobre como agir quando ocorre uma violação de dados.

67

Exceções de Notificação

A notificação ao titular dos dados não é obrigatória nas seguintes circunstâncias:

Encriptação

O controlador "implementou medidas de proteção técnica e organizacional apropriadas" que "tornam os dados ininteligíveis para qualquer pessoa que não tenha autorização para acessá-los, como criptografia".

Medidas de mitigação

O responsável pelo tratamento toma as medidas subsequentes à violação de dados pessoais para "garantir que o elevado risco para os direitos e liberdades dos titulares de dados" é improvável de se materializar

Esforço desproporcional

Quando a notificação a cada titular de dados "envolveria um esforço desproporcional". Neste último caso, podem ser utilizadas medidas de comunicação alternativas.

68

IT Partners

Categorias de violação de dados



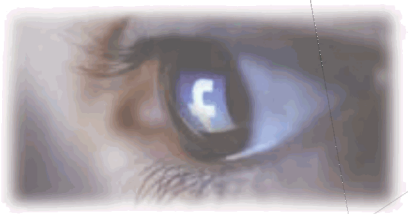
- **Material**
  - **Perda de portadores de dados, pastas de arquivos perdidas, smartphones perdidos, etc.** Ex. perda de um hd com dados pessoais.
- **Verbal**
  - **Indiscrição, papagaio de pirata, vazamento intencional de informações sigilosas, etc.**
    - **Exemplo clonar um cartão de crédito**
- **Ciberespaço (não material)**
  - **Backdoors, codificação incorreta, mau administrador (por exemplo, gerenciamento de patches), medidas de segurança técnica insuficientes, hacking etc.**

69

Exemplos de violação de dados

As 5 principais vulnerabilidades de violação de dados:

- Funcionários
- Dispositivos móveis não seguros
- Aplicativos de armazenamento em nuvem
- Provedores de serviços terceirizados
- Ataques maliciosos



[fonte: Eric Basu Forbes.com - novembro de 2015]

70

IT Partners

Exemplos de violação de dados



71

Diferença entre uma violação de segurança (incidente) e violação de dados

Violação de segurança ("incidente de segurança"): um incidente de segurança pode ser definido como qualquer evento adverso, confirmado ou sob suspeita, relacionado a segurança de sistemas de computação ou de redes de computadores. Por exemplo. perda de uma chave USB ou laptop, hack do sistema.

Violação de dados: é aquela que provoca, de modo acidental ou ilícito, a destruição, a perda, a alteração, a divulgação ou o acesso, não autorizados, a dados pessoais transmitidos, conservados ou sujeitos a qualquer outro tipo de tratamento, de acordo com a definição do item 12 do artigo 4º do GDPR.

- A primeira coisa que o controlador deve fazer é verificar se a violação pode ter provocado o processamento ilícito de dados pessoais ou a perda de dados.

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 5.2 Procedimentos sobre como agir quando houver uma violação de dados

72

IT Partners

O que precisa ser reportado em caso de violação?

Quando exigido a notificação de violação à autoridade supervisora, esta deve conter:

a) A natureza da violação dos dados pessoais, incluindo, sempre que possível, as categorias, o número aproximado de Titulares de Dados e as categorias e o número aproximado de registos de dados pessoais afetados;

b) O nome e os detalhes de contato do DPO ou outro ponto de contato que possa fornecer mais informações;

c) As prováveis consequências da violação de dados pessoais, e

d) As medidas tomadas ou propostas pelo Controlador/Processador para tratar da violação de dados pessoais (incluindo ações de mitigação).

Fonte: GDPR Artigo 33

Lembrar que a responsabilidade de notificação à autoridade supervisora é do Controlador. (Artigo 33(1))

73

Quem deve ser informado



Fonte: EU GDPR, Um guia de bolso - Capítulo 3 O Regulamento – Violações de dados

74



80

IT Partners

Privacy Data Protection Foundation

2. Organizando a proteção de dados

Copyright © 2020 EXIN Holding B.V. All rights reserved.

No part of this publication may be published, reproduced, copied or stored in a data processing system or circulated in any form by print, photo print, microfilm or any other means without written permission by EXIN.

EXIN® is a registered trademark

v. 2

1

Este módulo cobre:

2.1 Importância da proteção de dados para a organização.

2.2 Autoridade de supervisão.

2.3 Transferência de dados pessoais para países terceiros.

2.4 Vinculação de regras corporativas e proteção de dados em contratos.

35%

2

IT Partners

2.1 Importância da proteção de dados para a organização

13%

3

Conformidade com a GDPR - Cabe ao Controlador

- **Implementar medidas técnicas e organizacionais** apropriadas, como pseudonimização e minimização de dados, que são projetadas para implementar os princípios de proteção de dados e para **integrar** as salvaguardas necessárias **no processamento**, a fim de atender aos requisitos do GDPR e proteger os direitos dos titulares dos dados.
- Implementar medidas técnicas e organizacionais apropriadas para garantir que, **por padrão**, somente os dados pessoais necessários para **cada finalidade** específica do processamento sejam processados.

4

IT Partners

Tipos de administração - Controlador

O controlador deve ser responsável e demonstrar o cumprimento dos princípios relativos ao tratamento de dados pessoais. (Princípio da "responsabilidade")

- Aderência a códigos de conduta aprovados ou a mecanismos de certificação aprovados pode ser usada como um elemento para demonstrar o cumprimento das obrigações do controlador. Determina as finalidades e os meios de processamento de dados pessoais.

O controlador precisa:

- Demonstrar o cumprimento das obrigações legais de processamento às quais o controlador está sujeito (legalidade).
- Documentar violações de dados para auxiliar na verificação da conformidade com a obrigação de notificação pela autoridade supervisora.
- Realize avaliações de impacto de proteção de dados para ajudar a demonstrar a conformidade com o GDPR.
- Manter um registro das atividades de processamento (veja próximo slide)

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 1.4 Funções, responsabilidades, partes interessadas.

5

Conformidade com a GDPR - Cabe ao Controlador

Manter registro de todas atividades de tratamento sob sua responsabilidade, que constem:

- Nome e contato do(s) Controlador(es) ou de seus representantes e DPO
- A finalidade do processamento
- A descrição das categorias de titulares de dados e categorias de dados pessoais
- As categorias de destinatários a quem tenham sido ou venham a ser divulgados os dados pessoais, incluindo destinatários em países terceiros ou organização internacional
- Se for aplicável, transferências de dados pessoais para um país terceiro ou uma organização internacional, incluindo a identificação desse país ou organização internacional
- Se possível, os prazos previstos para exclusão das diferentes categorias de dados pessoais
- Se possível, uma descrição geral das medidas técnicas e organizacionais de segurança.

6

Conformidade com a GDPR - Cabe ao Processador

Manter **registro das atividades ligadas ao processamento** de dados pessoais. Nesses registros, devem constar as seguintes informações

- Nome e contato do(s) Processador(es) e de cada Controlador em nome do qual o Processador está atuando e quando aplicável, do representante do Controlador e DPO
- As categorias de processamento realizadas em nome de cada Controlador
- Se for caso, transferências de dados pessoais para um país terceiro ou uma organização internacional, incluindo a identificação desse país ou organização internacional
- Sempre que possível, uma descrição geral das medidas técnicas e organizacionais de segurança.
- O processamento deve ocorrer de acordo com instruções do Controlador, incluindo a exclusão e/ou retorno de todos dados pessoais após o serviço, exceto se requerido por lei.

7

Data Protection Officer (DPO)

•Também conhecido como encarregado da proteção de dados.

- Necessário especialmente nos casos de processamento de grande volume de dados e/ou grande volume de dados sensíveis (Art. 9º) e/ou criminais (Art. 10).
- Pode ser um colaborador da própria organização ou prestador de serviço terceirizado.
  - Deve-se garantir que não haja qualquer conflito de interesses (art. 38).
- O contato do DPO deve ser publicado pelo Controlador e comunicado à autoridade supervisora (art. 36(3)).
- Titulares de Dados podem contatá-lo para todas as questões que dizem respeito aos seus dados pessoais e o exercício de seus direitos (art. 38).
- Precisa estar envolvido em todas as questões relativas à proteção de dados (art. 38).
- Não pode ser penalizado ou demitido por cumprir sua função (art. 38).
- Reporta diretamente à alta Diretoria (art. 38).

8

IT Partners

Data Protection Officer - Responsabilidades

•Também conhecido como encarregado da proteção de dados.

- Informar/aconselhar o Controlador/Processador.
- Informar/aconselhar colaboradores que lidam com tratamento de dados.
- Monitorar conformidade legal.
- Realizar ou prestar auxílio em auditorias.
- Auxiliar Avaliações de Impacto na Proteção de Dados (AIPD).
- Cooperar com a autoridade supervisora.
- Ponto de contato para a autoridade supervisora.

Fonte: baseado no GDPR seção 4 (artigos 37 a 39)

9

Posição do DPO na organização

•Também conhecido como encarregado da proteção de dados.



- A organização tem de envolver o DPO nas suas atividades.
- O DPO **não deve** receber instruções do responsável pelo tratamento nem do subcontratante relativamente ao exercício das suas funções.
- O DPO responde diretamente perante o **nível mais elevado** de administração da organização.

10

DPO pode responder criminalmente?

•Também conhecido como encarregado da proteção de dados.

- As leis em todo o mundo variam e, em alguns casos, o DPO pode ser responsabilizado criminalmente pelo não cumprimento delas. Exemplo:
- No Reino Unido:
  - Um DPO pode enfrentar a responsabilidade penal se sabia que havia um risco de contravenção e esta contravenção poderia causar dano substancial ou sofrimento substancial, mas não tomou medidas para evitar isso.
- Na Irlanda:
  - Um DPO pode ser responsabilizado criminalmente se as violações forem cometidas com o consentimento ou conivência do diretor ou outra parte que solicitou a negligência .
- Para ambos os países não há prisão.

11

Proteção de dados desde a concepção
(by design)

Proteção de dados desde a concepção "Privacy by design"

- É uma metodologia na qual a proteção de dados pessoais é pensada desde a concepção de sistemas, práticas comerciais, projetos, produtos ou qualquer outra solução que envolva o manuseio de dados pessoais.
- O responsável pelo tratamento deve criar e reforçar a segurança e privacidade ao longo de todo o ciclo de vida da concepção, significando cada novo projeto ou serviço que faça uso de dados pessoais está obrigado a tomar precauções na proteção desses dados.
- Estas medidas podem ser impostas através de técnicas de pseudonimização ou encriptação dos dados.

12

IT Partners

Proteção de dados *por padrão* *(by default)*

- **Privacidade por Padrão** ***"Privacy by Default"***
- O responsável pelo tratamento deve criar e reforçar as configurações de privacidade para se aplicarem automaticamente quando um novo projeto ou serviço faça uso de dados pessoais.
- Estas medidas devem ser impostas para que os dados pessoais armazenados sejam mantidos pelo espaço de tempo necessário para providenciar o produto ou serviço.
- Quando os recursos de tratamento são adquiridos a um subcontratante, o responsável pelo tratamento deve sempre impor, se possível, os requisitos de Privacidade por Desenho e por Padrão.

13

Proteção de dados *by design* e *por padrão*

- **Cabe ao Controlador:**
- Implementar medidas técnicas e organizacionais apropriadas, como pseudonimização e minimização de dados, que são projetadas para implementar os princípios de proteção de dados;
- **Integrar as salvaguardas necessárias no processamento**, a fim de atender aos requisitos presentes no regulamento e proteger os direitos dos titulares de dados e
- Implementar medidas técnicas e organizacionais apropriadas para garantir que, por padrão, apenas os dados pessoais necessários para cada finalidade específica do processamento sejam processados.

O GPDR aborda a proteção de dados por projeto como uma obrigação legal, fazendo referência à minimização de dados e ao possível uso de pseudominimização.

14

IT Partners

Exemplos de violação de dados

Funcionários

- Divulgação não intencional, insider malicioso (ex-empregados que tiveram acesso a dados)
- Dispositivos não seguros
- Dispositivo móvel / portátil, dispositivo estacionário (ex. câmeras)

Aplicativos de armazenamento em nuvem

- Gerenciamento incorreto de identidades, interfaces e APIs hackeadas, captura de contas, perda de dados, tecnologia compartilhada

Provedores de serviços de terceiros

- Insiders maliciosos, armazenamento de dados em países terceiros (não abrangidos por decisões da UE)

Ataques maliciosos

- Hacking, malware

15

Exemplos de violação de dados - 2018

1. Aadhar | Registro de cidadãos | 1,1 bilhão de usuários

O que foi afetado: dados privados de cidadãos indianos, como nomes, números de identificação e contas bancárias

2. Marriott Starwood | Hotéis | 500 milhões de usuários

O que foi afetado: informações de hóspedes, como números de telefone, passaporte, dados sobre reservas, cartões de pagamento e endereços de e-mail.

3. Exactis | Gestão de dados | 340 milhões de usuários

O que foi afetado: informações compiladas de milhões de pessoas e empresas, incluindo números de telefone, endereços, interesses, características pessoais, etc.

4. MyFitnessPal | Aplicativo para atividades físicas | 150 milhões de usuários

O que foi afetado: informações de conta dos usuários

5. Quora | Fórum de discussão | 100 milhões de usuários

O que foi afetado: nomes, endereços de e-mail, senhas criptografadas, dados de contas e perguntas e respostas dos usuários publicadas no Quora.

16

IT Partners

A obrigação de notificação de violação de dados

- O Processador deve notificar o Controlador, sem demora indevida, após tomar conhecimento de uma violação de dados pessoais.
- Em caso de violação de dados pessoais, o responsável pelo tratamento deve, sem demora injustificada e, sempre que possível, **no prazo de 72 horas** após ter tomado conhecimento do mesmo, notificar a violação dos dados pessoais à autoridade de supervisão.
- Quando a violação de dados pessoais resultar em um alto risco aos direitos e liberdades das pessoas físicas, o responsável pelo tratamento deve comunicar a violação de dados pessoais à pessoa em causa sem demora indevida.
- O responsável pelo tratamento documentará quaisquer violações de dados pessoais (e disponibilizará essas informações à autoridade supervisora).

17

O que deve ser reportado



A notificação deve, pelo menos:

- Descrever a natureza da violação dos dados pessoais, incluindo, sempre que possível, as categorias e o número aproximado de titulares de dados envolvidos e o número aproximado de registos de dados pessoais em causa
- Comunicar o nome e os detalhes de contato do encarregado de proteção de dados ou outro ponto de contato onde mais informações podem ser obtidas
- Descrever as consequências prováveis da violação de dados pessoais
- Descrever as medidas tomadas ou propostas pelo controlador para tratar da violação de dados pessoais (*incluindo ações de mitigação*)

18

IT Partners

A execução das regras e multas administrativas

Condições gerais:

- Cada autoridade de supervisão deve assegurar que a imposição de multas administrativas seja, em cada caso individual, eficaz, proporcional e dissuasiva.
- As multas administrativas devem, dependendo das circunstâncias de cada caso individual, ser impostas além ou em vez de outras medidas.
- O tipo de multa ou medida é determinado de acordo com o histórico tais como, mas não limitados a infrações anteriores, gravidade, categorias de dados, etc.



19

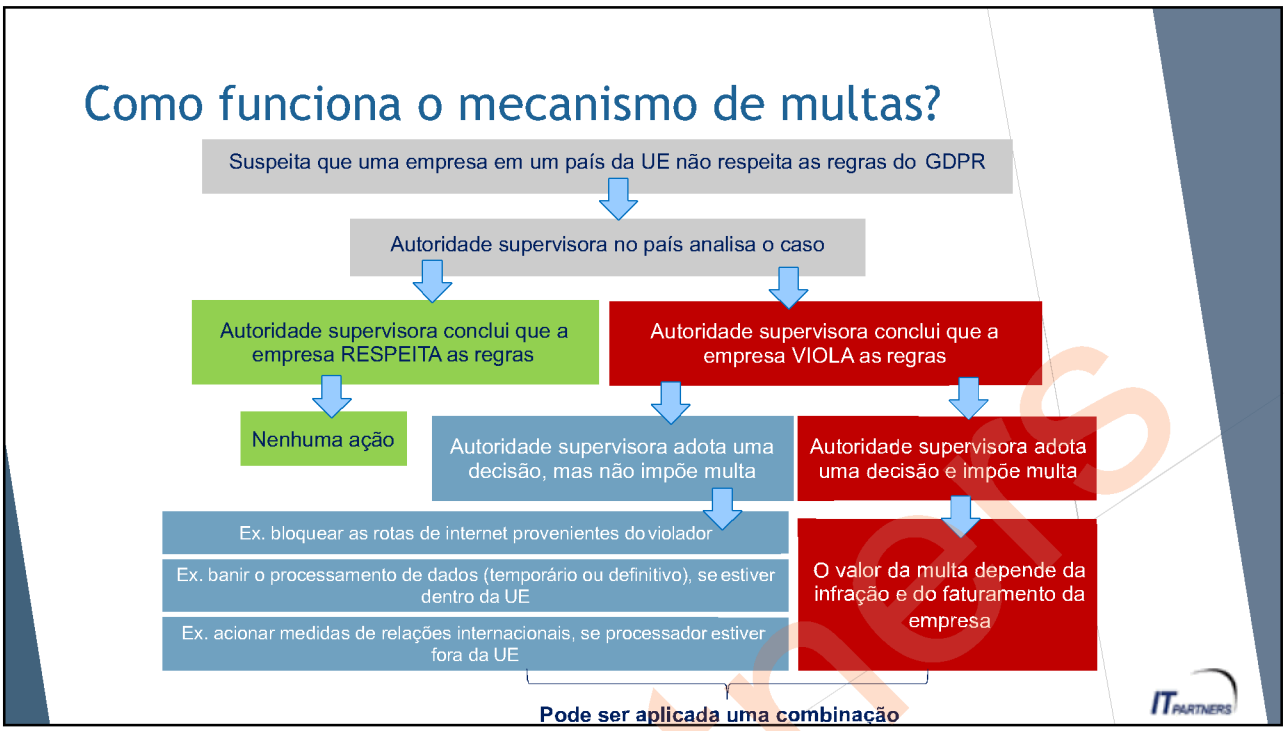
Aplicação de multas



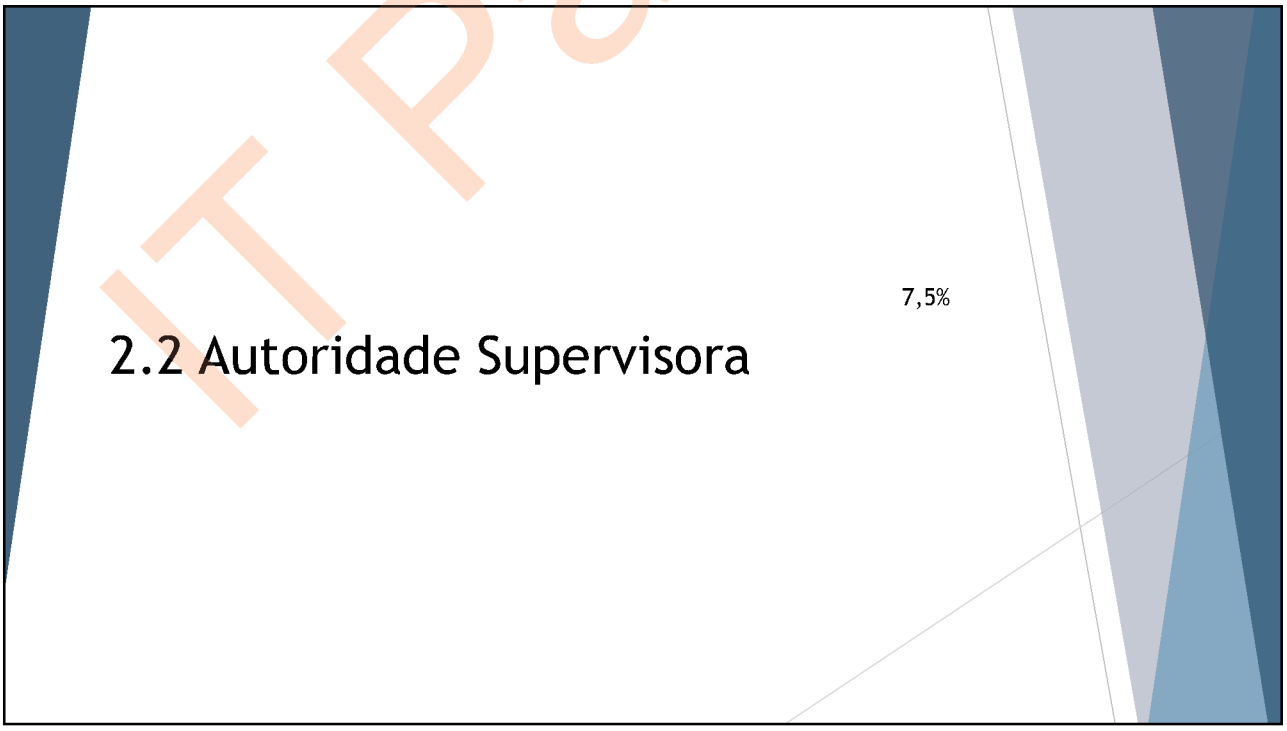
- Existem duas categorias de multas. Por infrações às obrigações do controlador e do processador, a multa máxima será de € 10.000.000 ou 2% do volume de negócios mundial da empresa no ano financeiro anterior, o que for maior.
- Para estas categorias, a multa administrativa máxima será de € 20.000.000 ou até 4% do volume de negócios mundial da empresa no ano financeiro anterior, o que for maior:
  - Violação dos princípios básicos de processamento, incluindo as condições de consentimento
  - Violação dos direitos dos titulares de dados
  - as transferências de dados pessoais para um destinatário num país terceiro ou uma organização internacional
  - Não cumprimento de uma encomenda ou limitação temporária ou definitiva do processamento ou suspensão da transmissão de dados pela autoridade supervisora

20

IT Partners



21



22

IT Partners

Responsabilidades de uma Autoridade Supervisora - DPA (ou Fiscalizadora)

- Monitorar e fazer cumprir a aplicação do GDPR
- Aconselhar o Parlamento Nacional, governos, etc. sobre medidas legislativas e administrativas relacionadas com a proteção de dados pessoais
- Definir padrões (normas e diretrizes)
- Estabelecer e manter uma lista em relação à exigência de AIPDs*
- Aprovar regras corporativas vinculantes
- Manter registros internos das infrações ao presente regulamento
- Promover a conscientização pública e a compreensão dos riscos, regras, salvaguardas e direitos em relação ao processamento de dados pessoais.

AIPD - Avaliação de Impacto sobre a Proteção de Dados

23

Papel de uma autoridade supervisora
(em relação às violações de dados)

- Tem poderes de investigação (por exemplo, para realizar auditorias de proteção de dados, para notificar o responsável pelo tratamento ou o subcontratante de uma infração alegada)
- Tem poderes corretivos (por exemplo, emitir advertências, ordenar a comunicação de uma violação de dados pessoais a um titular de dados, retirar uma certificação, impor multas administrativas)
- Da autorização e poderes consultivos (por exemplo, para adotar cláusulas contratuais padrão, para emitir certificações)

Uma autoridade pública independente que seja estabelecida por um Estado Membro

Fonte: GDPR 2016/679, Artigo 4 e Artigo 51.

24

IT Partners

Como uma autoridade supervisora contribui para a aplicação da GDPR

- A autoridade supervisora contribui para a aplicação do regulamento em toda a União, cooperando com as outras autoridades interessadas, trocando entre si as informações pertinentes.
- As autoridades conduzem operações conjuntas, sempre que conveniente, incluindo investigação e medidas de execução nas quais participem membros ou pessoal das autoridades de controle.
  - Exemplo: Ela define um conjunto mínimo de medidas que devem ser adotadas para a proteção de dados pessoais.

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 7.1.4 Definição de normas.

25

Diretiva do NIS

(Network and Information Security)

A diretiva relativa à segurança das redes e da informação (NIS) do Parlamento Europeu.

- Visa estabelecer funcionalidades de segurança cibernética de nível nacional que afetarão empresas comuns e outras organizações.
- Nos casos em que o GPDR procura proteger os dados pessoais e os direitos da pessoa em causa, o NIS procura estabelecer uma "autoridade competente" para a cibersegurança em cada Estado-Membro.
- As autoridades são responsáveis por garantir que a infraestrutura nacional esteja protegida contra ameaças de segurança cibernética e que o cidadão comum possa ter um certo grau de confiança nas tecnologias que usa diariamente
- O NIS é uma diretiva e, portanto, não possui o peso legal total do GDPR.

26

2.3 Transferência de dados pessoais para outros países

7,5%

27

Transferência de dados para outros países

- O GDPR permite a transferência de dados pessoais para países terceiros, fora do bloco europeu, por meio de uma série de condições, desde que esses sejam considerados pela Comissão Europeia países com um nível "adequado" de proteção de dados pessoais
- A Diretiva 104 do Parlamento Europeu especifica que decisões de adequação são conferidas a países com níveis de proteção similar ao garantido na União Europeia.

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 7.5.2 Regulamentos aplicáveis à transferência de dados para fora da Área Econômica Europeia

28

IT Partners

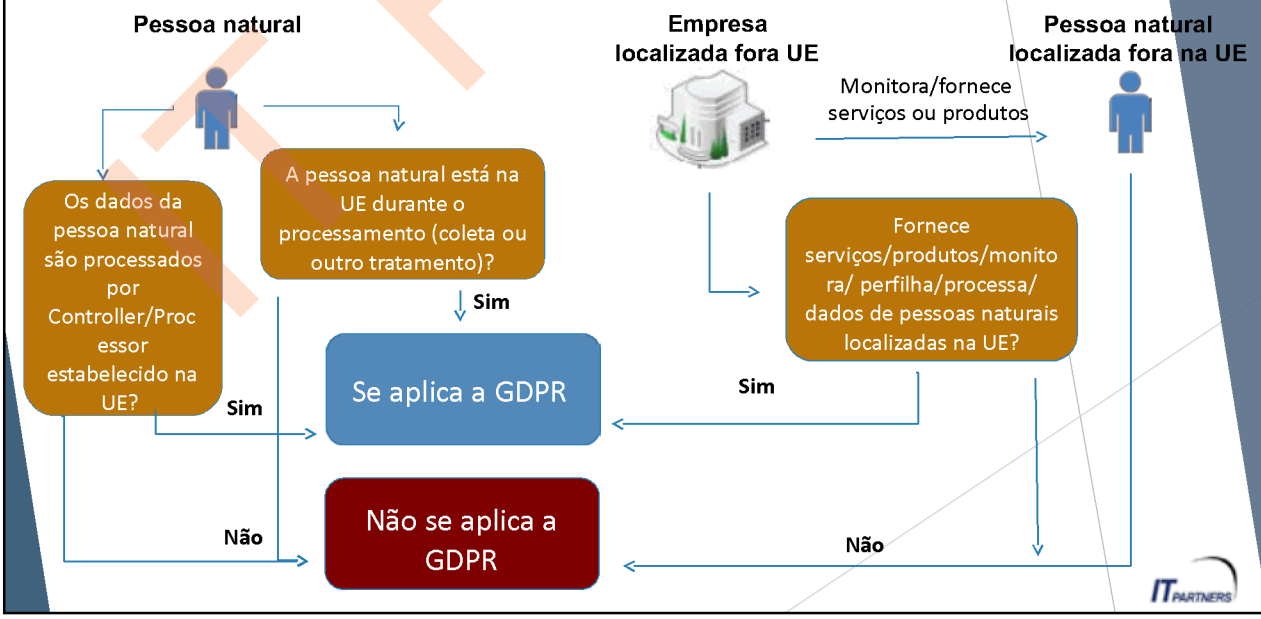
Transferência de dados para outros países

LGPD

- **Aplicação extraterritorial:** em moldes similares à regulamentação europeia, a GDPR, a Lei Geral terá aplicação extraterritorial, ou seja, o dever de conformidade superará os limites geográficos do país.
- Toda empresa estrangeira que, pelo menos, tiver filial no Brasil, ou oferecer serviços ao mercado nacional e coletar e tratar dados de pessoais naturais localizadas no país estará sujeita à nova lei.

29

Aplicação extraterritorial – além da UE



30

Transferência de dados dentro da EEA
(Economic European Area)

- A Comissão Europeia está habilitada a decidir quais países terceiros são considerados como assegurando um nível adequado de proteção.
- Todos os Estados-Membros da UE e os Estados-Membros do EEE (Islândia, Noruega e Liechtenstein) aplicavam as disposições da Diretiva 95/46 / CE.
- Esses países respeitam, assim, os princípios da proteção de dados pessoais, tal como definidos na diretiva.
- Em caso de multinacionais, a autoridade supervisora do estabelecimento principal deve ter competência para agir como autoridade de controle principal para o processamento transfronteiriço.

31

Transferência de dados fora da EEA
(Economic European Area)

European Union
EXTERNAL ACTION

- Comissão Europeia está habilitada a decidir quais países terceiros são considerados detentores de um nível adequado de proteção aos dados pessoais.
- A Comissão Europeia reconheceu os seguintes países: Andorra, Argentina, Canadá (nem todo tipo de processamento), Ilhas Faroé, Guernsey, Israel, Ilha de Man, Jersey, Nova Zelândia, Suíça e Uruguai.
- Particularmente para empresas e organizações multinacionais, a autoridade supervisora pode aprovar regras corporativas compulsórias (BCR)

32

IT Partners

Transferência de dados entre a EEA e USA

- UE e Estados Unidos fecharam acordo para proteger a privacidade na internet. Esse acordo é chamado de adequação.
- ***Privacy Shield*** – marco jurídico sobre a transferência dos dados pessoais com fins comerciais.

Decisão de adequação da CE

DECISÃO DE EXECUÇÃO (UE) 2016/1250 DA COMISSÃO de 12 de julho de 2016 nos termos da Diretiva 5/46 / CE do Parlamento Europeu e do Conselho relativa à adequação da proteção oferecida pelos documentos UE-EUA. Escudo de Privacidade

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 7.5.4 Regulamentos aplicáveis à transferência de dados entre a Área Econômica Europeia e os EUA

33

2.4 Regras Corporativas Compulsórias e proteção de dados em contratos

7,5%

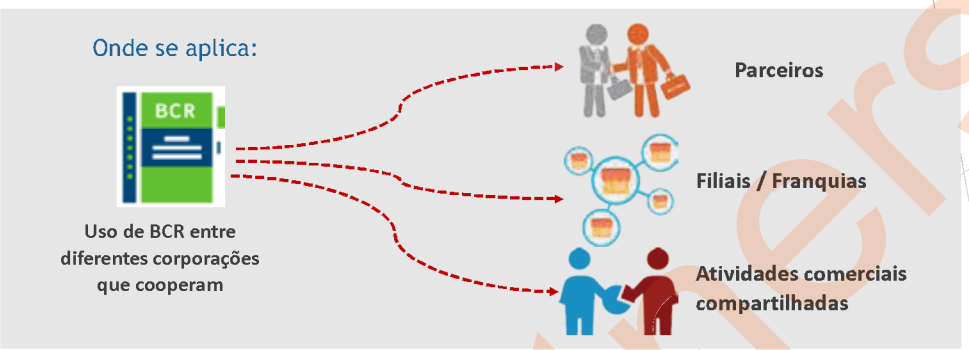
34

IT Partners

Regras Corporativas Compulsórias

Binding Corporate Rules (BCR)

As BCRs foram concebidas para permitir que um grupo de empresas possa utilizar regras empresariais vinculantes aprovadas para as suas transferências internacionais da União para organizações pertencentes ao mesmo grupo, garantindo as salvaguardas apropriadas para transferências de dados pessoais.



35

Regras Corporativas Compulsórias

Binding Corporate Rules (BCR)

As BCR podem ser elaboradas por controladores e processadores.

Significam a criação de processos, procedimentos e acordos corporativos sobre o manuseio de dados pessoais dentro da organização.

A BCR necessita de ser oficialmente aprovada pela Autoridade Supervisora competente para ser utilizada na União Europeia.

Uma BCR aprovada pode substituir:

- Quando as Regras Corporativas Compulsórias são aprovadas por uma autoridade de proteção de dados não é necessária aprovação de outras autoridades dentro da UE.
- Contrato escrito entre o controlador e o processador
- Ser usado para transferências de dados fora da UE

Fonte: EU GDPR, Um guia de bolso - Capítulo 3

36

IT Partners

Como a proteção de dados é formalizada?

- É necessário existir um contrato por escrito garantindo a confidencialidade dos dados, no qual o Controlador define os objetivos e os métodos de processamentos.
- O Artigo 25 do GDPR exige que o controlador implemente medidas técnicas e organizacionais apropriadas e garanta que essas precauções permaneçam em vigor durante o processamento, na verdade, implementando um dos princípios da Proteção de Dados "by design": segurança de ponta a ponta.
- As duas partes devem assinar esse contrato. (Art. 28 GDPR).
- Regras Corporativas Compulsórias – Art. 47 do GDPR.

37

Contratos entre o controlador e o processador

Requerido

- Quando um Controlador usa um Processador para processar dados pessoais, um contrato por escrito entre essas partes é obrigatório. (Mesmo se o processador for uma empresa subsidiária).
- Se diz respeito a uma empresa estrangeira.
- Se um Service Desk externo exibir dados pessoais (este é um exemplo de processamento)

38

IT Partners

Quais as cláusulas deste contrato

No contrato por escrito, o Processador processará somente os dados pessoais sob as ordens do Controlador. Cláusulas mínimas necessárias:

- Dados pessoais processados de acordo as instruções do Controlador
- Objeto e duração do tratamento
- Confidencialidade
- Estipular que o Processador está em conformidade com o GDPR
- Cláusulas contratuais padrão para as transferências de dados para fora da UE pela Comissão Europeia.

39

Obrigações contratuais do Processador

- Processar os dados pessoais somente em instruções documentadas do Controlador
- Assegurar que todas as pessoas que processam os dados se enquadram em um NDA - Non Disclosure Agreement ("obrigação apropriada de confidencialidade")
- Tomar medidas de segurança apropriadas (artigo 32)
- Respeitar as condições para contratar outro Processador
- Auxiliar o responsável por medidas técnicas e organizacionais apropriadas

40

Obrigações contratuais do Processador

(cont.)

- Auxiliar o Controlador a garantir o cumprimento dos requisitos de segurança para processamento (art. 32) e consulta prévia (art.36) na escolha do Controlador
- Eliminar ou devolver todos os dados pessoais ao Controlador após o final da prestação de serviços relacionados com o processamento e eliminar todas as cópias
- A menos que o armazenamento seja exigido pela legislação da UE (por exemplo, lei fiscal) disponibiliza ao responsável todas as informações necessárias para demonstrar o cumprimento das obrigações
- O responsável pelo tratamento está isento da sua obrigação de cumprir certos direitos dos titulares de dados se não conseguir identificar quais os dados em sua posse que se relacionam com os dados relevantes do titular.

41

Observações do contrato

O contrato deve:

- Garantir que as disposições contratuais sejam revistas e atualizadas
- Assegurar que as responsabilidades e responsabilidades entre o controlador e o processador sejam estipuladas
- Documentar claramente as responsabilidades dos dados (garantir que não haja confusão)
- Aceitar que os níveis de risco e requisitos de medidas de proteção de dados aumentados podem afetar os custos do serviço.

42



48

IT Partners

Privacy Data Protection Foundation

3. Práticas de Proteção de Dados

Copyright © 2020 EXIN Holding B.V. All rights reserved.

No part of this publication may be published, reproduced, copied or stored in a data processing system or circulated in any form by print, photo print, microfilm or any other means without written permission by EXIN.

EXIN® is a registered trademark

v. 2

1

Este módulo cobre:

3.1 Proteção de dados *by design* e por padrão.

3.2 Avaliação do impacto sobre a proteção de dados (DPIA).

3.3 Aplicações práticas relacionadas ao uso de dados, marketing e mídias sociais.

35%

2

IT Partners

Segurança da Informação e proteção de dados

- Lembre-se que dados pessoais são um **subconjunto** de todos os dados processados em uma organização.
- Os requisitos de qualidade aplicáveis a todas as informações são também o mínimo aplicável às informações pessoais.
- A adoção de medidas para mitigar o risco da informação também inclui a adoção de medidas relacionadas a informações pessoais.
- O GDPR exige medidas de segurança **técnicas e organizacionais** adequadas.

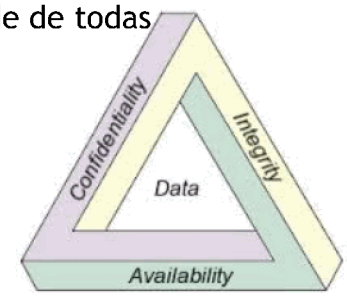


A privacidade não pode ser garantida sem a identificação, implementação e monitoramento de medidas de segurança da informação adequadas.

3

Segurança da Informação

- Segurança da informação é o conjunto de medidas preventivas, detectivas, repressivas e corretivas, bem como procedimentos e processos que garantem a disponibilidade, integridade e confidencialidade de todas as formas de informação
- Atributos da segurança da informação:
  - Confidencialidade
  - Integridade
  - Disponibilidade



4

IT Partners

5%

3.1 Proteção de Dados *by design* e por padrão

5

Proteção de Dados no GDPR

O GDPR exige que você estabeleça medidas técnicas e organizacionais apropriadas para implementar os princípios de proteção de dados e salvaguardar os direitos individuais. Esta é a "proteção de dados por design e por padrão".

Em essência, isso significa que você precisa integrar a proteção de dados em suas atividades de processamento e práticas de negócios, desde o estágio de design até o ciclo de vida.

Este conceito não é novo. Anteriormente conhecido como "privacidade por design", sempre fez parte da lei de proteção de dados. A principal mudança com o GDPR é que agora é um requisito legal.

6

IT Partners

O que é proteção de dados *by design?*

privacidade desde a concepção

A ***proteção de dados por design*** é uma abordagem que garante a consideração de questões de privacidade e proteção de dados na fase de design de qualquer sistema, serviço, produto ou processo e, em seguida, durante todo o ciclo de vida.

A ***proteção de dados por design*** tem ampla aplicação. Exemplos incluem:

Desenvolvimento de novos sistemas, serviços, produtos e processos de TI que envolvam o processamento de dados pessoais;

- Desenvolver políticas organizacionais, processos, práticas de negócios e / ou estratégias que tenham implicações de privacidade;
- Design físico;
- Embarcar em iniciativas de compartilhamento de dados; ou
- Usar dados pessoais para novos propósitos.

7

O que é proteção de dados “by default” ?

por padrão

- A ***proteção de dados por padrão***, exige que apenas se processe os dados necessários para atingir sua finalidade específica. Vincula-se aos princípios fundamentais de proteção de dados de minimização de dados e limitação de finalidade.
- A ***proteção de dados por padrão***, significa que é preciso especificar esses dados antes do início do processamento, informar apropriadamente os indivíduos e processar apenas os dados necessários para sua finalidade.
- Ele não exige uma solução "padrão para desativado". Tudo depende das circunstâncias do seu processamento e dos riscos para os indivíduos.

vinculado ao princípio fundamental de **minimização de dados.**

8

O que somos obrigados a fazer?

Proteção de dados por padrão:

Não existe um método "*one size fits all*" para isso e nenhum conjunto de medidas obrigatórias. Depende das circunstâncias.

A chave é considerar os problemas de proteção de dados desde o início de qualquer atividade de processamento e adotar políticas e medidas apropriadas que atendam aos requisitos de proteção de dados por design e por padrão. Exemplos:

- Minimizar o processamento de dados pessoais
- Pseudónimo de dados pessoais o mais rapidamente possível
- Garantir a transparência no que diz respeito às funções e ao tratamento de dados pessoais
- Permitir que os indivíduos monitorem o processamento

O controlador deve Implementar medidas técnicas e organizacionais adequadas para implementar os princípios de proteção de dados e salvaguardar os direitos individuais.

Fonte: EU GDPR, Um guia de bolso - Capítulo 3 O Regulamento

9

Quando devemos fazer?

Na fase inicial de qualquer sistema, serviço, produto ou processo.

Deve-se considerar as atividades de processamento pretendidas, os riscos que elas podem representar para os indivíduos e as possíveis medidas disponíveis para garantir que se cumpra os princípios de proteção de dados e proteja os direitos individuais.

Essas considerações devem cobrir:

- O estado da arte e os custos de implementação de quaisquer medidas
- A natureza, o escopo, o contexto e os propósitos do seu processamento e
- Os riscos que seu processamento representa para os direitos e liberdades dos indivíduos.

10

IT Partners

Benefícios da proteção de dados by design e por padrão

Quando se trata de desenvolver produtos e serviços seguros, a privacidade deve ser englobada em todo o design. Falta privacidade se for uma reflexão posterior e for encarada como uma característica, e não como parte do produto. Os benefícios incluem:

- Problemas potenciais são identificados em um estágio inicial, quando abordá-los geralmente será mais simples e menos dispendioso.
- Maior conscientização sobre privacidade e proteção de dados em toda a organização.
- As organizações são mais propensas a cumprir suas obrigações legais e menos propensas a violar a Lei de Proteção de Dados.
- É menos provável que as ações sejam intrusivas para a privacidade e tenham um impacto negativo nos indivíduos.

11

Princípios da proteção de dados *by design*

Princípios fundamentais:

1. Proativo e não reativo (preventiva não corretiva)
2. Proteção de dados como configuração padrão
3. Proteção de dados incorporada ao design
4. Funcionalidade total (soma positiva)
5. Segurança de ponta a ponta (proteção total do ciclo de vida)
6. Visibilidade e transparência
7. Respeito pela privacidade do usuário (centrado no usuário)

12

IT Partners

Princípios da proteção de dados *by design* (cont.)

1. Proativo e não reativo; preventiva não corretiva

A abordagem de Proteção de Dados "by design" é caracterizada por medidas proativas em vez de reativas. Ele antecipa e evita eventos invasivos de privacidade antes que eles aconteçam. A Proteção de Dados "by design" não espera que os riscos de privacidade se concretizem, nem oferece remédios para resolver infrações de privacidade depois de terem ocorrido - ele visa impedir que ocorram. Em resumo, A Proteção de Dados "by design" vem antes do fato, não depois.

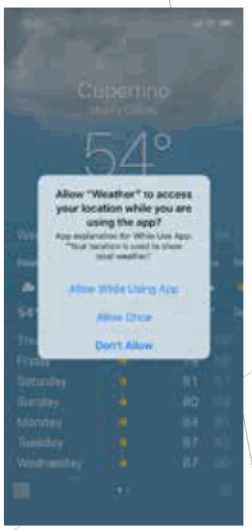


13

Princípios da proteção de dados *by design* (cont.)

2. Privacidade como a configuração padrão

Você deve projetar qualquer sistema, serviço, produto e / ou prática de negócios para proteger os dados pessoais automaticamente. Com a privacidade embutida no sistema, o indivíduo não precisa tomar nenhuma medida para proteger seus dados - sua privacidade permanece intacta sem que eles tenham que fazer nada.



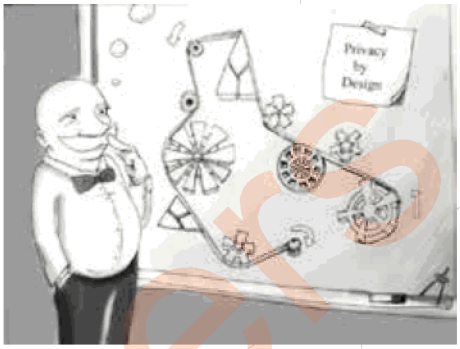
14

IT Partners

Princípios da proteção de dados *by design* (cont.)

3. "Privacidade incorporada ao design"

- A Proteção de Dados "by design" está incorporado ao design e à arquitetura de sistemas de TI e práticas de negócios.
- Não é acoplada como um complemento após o fato.
- O resultado é que a privacidade se torna um componente essencial da funcionalidade principal que está sendo entregue.
- A proteção de dados é parte integrante do sistema, sem diminuir suas funcionalidades.



Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 8.1.1 Os sete princípios da proteção de dados desde a concepção (by design)

15

Princípios da proteção de dados *by design* (cont.)

4. "Funcionalidade total - soma positiva, não soma zero"

Também conhecido como "ganha-ganha", este princípio é essencialmente sobre evitar trade-offs, como a crença de que em qualquer sistema ou serviço só é possível ter privacidade ou segurança, não privacidade e segurança. Em vez disso, você deve procurar incorporar **todos os objetivos legítimos**, ao mesmo tempo em que garante o cumprimento de suas obrigações. *Exemplo: funcionalidade ou segurança?*



Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 8.1.1 Os sete princípios da proteção de dados desde a concepção (by design)

16

IT Partners

Princípios da proteção de dados *by design* (cont.)

5. "Segurança de ponta a ponta - proteção total do ciclo de vida"

Coloque em vigor medidas de segurança fortes desde o início e estenda essa segurança em todo o ciclo de vida dos dados - ou seja, processe os dados com segurança e, em seguida, destrua-os com segurança quando não precisar mais deles.



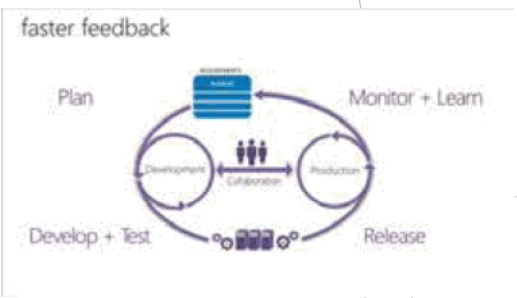
17

Princípios da proteção de dados *by design* (cont.)

6. "Visibilidade e transparência - mantenha-a aberta"

A Proteção de Dados "by design" procura assegurar a todos os stakeholders que, seja qual for a prática ou tecnologia de negócio envolvida, ela está, de fato, operando de acordo com as promessas e objetivos declarados, sujeito a verificação independente.

Seus componentes e operações permanecem visíveis e transparentes para usuários e provedores. Lembre-se, confie, mas verifique.

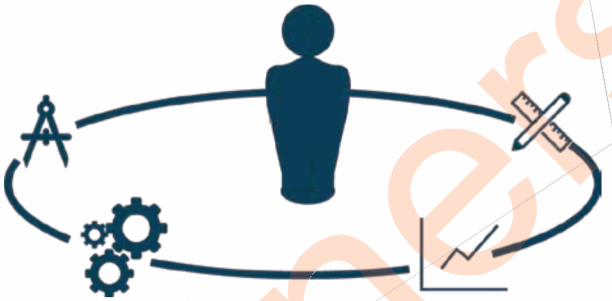


18

Princípios da proteção de dados *by design*
(cont.)

7. "Respeito à privacidade do usuário - mantenha-a centrada no usuário"

Acima de tudo, a Proteção de Dados "by design" exige que os arquitetos e operadores mantenham os interesses do indivíduo (usuário) em primeiro lugar, oferecendo medidas como padrões de privacidade fortes, notificação apropriada e capacitando opções fáceis de usar. Mantenha foco no usuário.



19

Como fazemos isso na prática?

- Um meio de colocar esses conceitos em prática é desenvolver um conjunto de diretrizes práticas e acionáveis que você pode usar em sua organização, enquadradas por sua avaliação dos riscos apresentados e das medidas disponíveis para você.
- Você pode basear as diretrizes nos sete princípios fundamentais.

20

5%

3.2 Avaliação de Impacto sobre a Proteção de Dados (DPIA)

21

Definições sobre Risco

- Um "risco" é um cenário que descreve um evento e suas consequências, estimado em termos de gravidade e probabilidade.
- "Gestão de risco" são as atividades coordenadas para dirigir e controlar uma organização em relação ao risco.
- O GDPR exige que os controladores implementem medidas apropriadas para garantir e demonstrar conformidade com o GDPR
- "Análise de risco" é a revisão dos riscos associados a um evento ou ação em particular. Uma análise de risco de GDPR é chamada de avaliação de impacto de proteção de dados (DPIA)
- A obrigação dos controladores de conduzir um **DPIA** em determinadas circunstâncias deve ser entendida

22

Avaliação de Impacto sobre a Proteção de dados
(AIPD - DPIA)

- Um DPIA é uma ferramenta que você pode usar para identificar e reduzir os riscos de proteção de dados de suas atividades de processamento. Eles também podem ajudá-lo a projetar processos mais eficientes e eficazes para lidar com dados pessoais.

- Os DPIAs são parte integrante da proteção de dados por design e por padrão. Por exemplo, eles podem determinar o tipo de medidas técnicas e organizacionais necessárias para garantir que o processamento esteja em conformidade com os princípios de proteção de dados e *minimizar o risco de multas*.



Fonte: EU GDPR, Um guia de bolso - Capítulo 3 O Regulamento – Avaliações de Impacto sobre a Proteção de Dados

23

Avaliação de Impacto sobre a Proteção de dados
(AIPD - DPIA)

Um DPIA é é um instrumento de análise de risco

- Ajuda a identificar riscos de proteção de dados (em um projeto)
- Ajuda a prever e evitar problemas e apresentar soluções para reduzir os riscos de proteção de dados.
- O DPIA é um instrumento útil para ajudar os responsáveis pelo tratamento a cumprir a legislação relativa à proteção de dados.
- A AIPD deve ser iniciado o mais cedo possível no projeto da operação de processamento, mesmo que algumas das operações de processamento ainda sejam desconhecidas.

24

Avaliando o impacto da privacidade

- As Avaliações de Impacto de Proteção de Dados (DPIAs) são agora obrigatórias para tecnologias e processos que podem resultar em um alto risco aos direitos dos titulares de dados
- Uma autoridade supervisora pode listar as situações específicas para as quais uma DPIA é ou não necessária
- As organizações devem garantir que uma DPIA faça parte de seu processo de avaliação de risco em relação a dados pessoais e esteja alinhada com a proteção de dados por design e por padrão
- um único DPIA pode tratar de um conjunto de operações de processamento semelhantes com riscos comparáveis
- O controlador de dados é responsável por garantir que os DPIAs sejam conduzidos

25

Quando um DPIA é necessário?

Sempre que um tipo de processamento, em especial utilizando novas tecnologias, e tendo em conta a natureza, âmbito, contexto e finalidades do processamento, possa **resultar num risco elevado** para os direitos e liberdades das pessoas singulares, o controlador processamento deve proceder na avaliação do impacto das operações de processamento previstas na proteção de dados pessoais.

Fonte: GDPR Artigo 35(1)

Por exemplo:

- Uma avaliação sistemática e exaustiva dos aspectos pessoais relativos às pessoas singulares (incluindo a definição de perfis)
- Processamento em larga escala de categorias especiais de dados (dados sensíveis)
- Um monitoramento sistemático de uma área de acesso público em larga escala.
- Grandes mudanças em um sistema ou processo que inclui o processamento de dados pessoais
- Novos projetos
- Projetar uma nova base de dados para administrar clientes

Data Protection Impact Assessment

Fonte: EU GDPR, Um guia de bolso - Capítulo 3 O Regulamento – Consentimento & Exposição do GDPR (39)

26

Quando é que um DPIA NÃO é necessário?

Um DPIA NÃO é necessário:

- Quando o processamento não é "susceptível de resultar em um alto risco", ou
- Existe um outro DPIA semelhante ou
- Foi autorizado antes de maio de 2018, ou
- Tem uma base legal, ou
- Está na lista de operações de processamento para as quais um DPIA não é necessário.

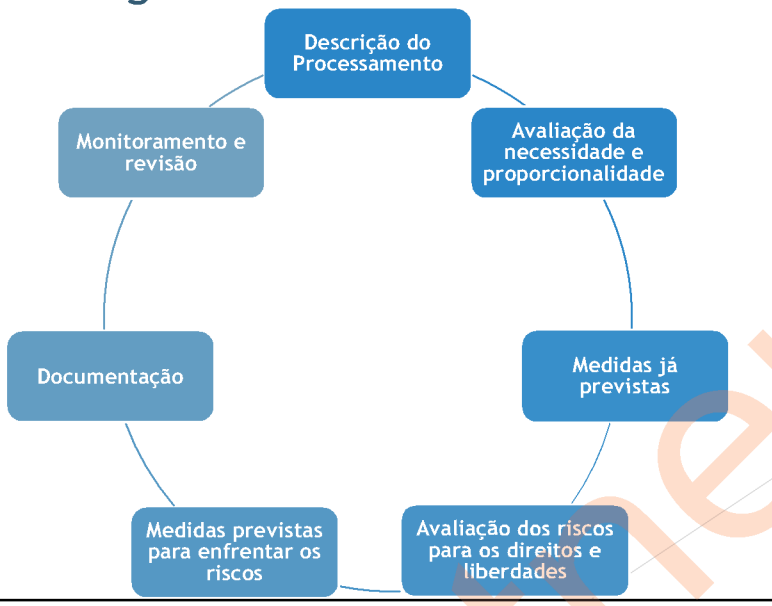
27

Objetivos de um DPIA

1. Evitar mudanças dispendiosas em processos, redesenho de sistemas ou término de projetos.
2. Reduzir as consequências supervisão e fiscalização
3. Melhorar a qualidade dos dados
4. a prestação de serviços
5. a tomada de decisão
6. a viabilidade do projeto
7. a comunicação em relação à privacidade e proteção de dados pessoais
8. Aumentar a conscientização sobre proteção de dados em uma organização
9. Fortalecer a confiança dos clientes ou cidadãos na forma como os dados pessoais são processados e a privacidade é respeitada

28

Atividades genéricas de um DPIA



29

Tópicos de um relatório DPIA

- Breve descrição do DPIA que foi conduzido
- Breve descrição do projeto, modelo de dados e fluxo de dados
- Descrição do impacto e dos riscos
- Decisões de viabilidade (Go / No-Go) do projeto
- Considerações para sistema / política para coleta de dados
- Abordagem de solução de descrição
- Nome do oficial responsável pela gestão e avaliação do DPIA
- Espaço para comentários do cliente

30

IT Partners

10%

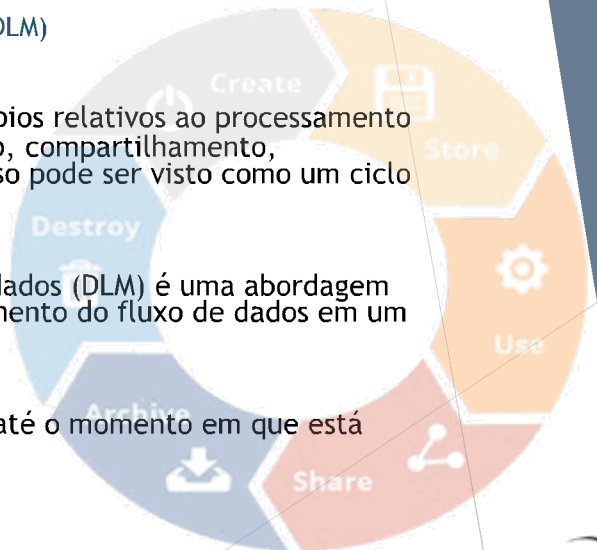
3.3 Aplicações práticas relacionadas

- Uso de dados
- Marketing
- Mídias sociais

31

Objetivos do Gerenciamento do Ciclo de Vida do Dado GCVD (Data Life Management – DLM)

- O Artigo 5 do GDPR descreve os princípios relativos ao processamento de dados pessoais desde a criação, uso, compartilhamento, arquivamento e exclusão. Esse processo pode ser visto como um ciclo de vida de dados.
- O gerenciamento de ciclo de vida de dados (DLM) é uma abordagem baseada em políticas para o gerenciamento do fluxo de dados em um sistema de informações.
- Do primeiro armazenamento do dado até o momento em que está desatualizado e é excluído



Picture source: spirion.com/us/solutions/data-lifecycle-management

32

Gerenciamento de ciclo de vida de dados

- O Gerenciamento do Ciclo de Vida do Dado (GCVD) é um processo que ajuda as organizações a gerenciar o fluxo de dados em todo o seu ciclo de vida - da criação, uso, compartilhamento, arquivamento e exclusão.
- Rastrear dados com precisão em todo o ciclo de vida da informação é a base de uma estratégia de proteção de dados confidencial e ajuda a determinar onde aplicar os controles de segurança.



Picture source: spirion.com/us/solutions/data-lifecycle-management

33

Entendendo o fluxo de dados

Coleta de dados	Estrutura das permissões	Criar regras de retenção / exclusão
• O GDPR requer um motivo para manter os dados pessoais armazenados. • Os titulares dos dados precisam ser informados da data e da finalidade da sua coleta.	• Uma estrutura de permissões é necessária para definir quais funcionários precisam, por conta de sua função na organização, ter acesso a quais dados pessoais.	• Necessário estabelecer regras para retenção e exclusão de dados pessoais e o período, de acordo com obrigações legais. • Considerar questões de minimização de dados e o "direito ao esquecimento".

34

Minimização de dados

- A minimização de dados é o terceiro princípio relacionado ao processamento de dados pessoais
- Os dados pessoais devem ser adequados, relevantes e limitados ao necessário em relação aos fins para os quais são tratados. (minimização)
- Faz parte da proteção de dados por design e por padrão
- Faz parte das regras corporativas compulsórias (BCR)
- Faz parte das salvaguardas e derrogações relativas ao processamento para fins de arquivamento

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - §2.1 Princípios do processamento de dados GDPR artigo 5.1.c.

35

Direito ao esquecimento



- O Titular dos Dados tem o direito de ter seus dados pessoais retificados, bem como tem o "direito ao esquecimento" quando a retenção desses dados viola o GDPR, a legislação da União ou do Estado Membro a que o Controlador está sujeito.
- Este direito é relevante, em particular, quando o titular dos dados deu o seu consentimento quando era criança.
- Mesmo depois de não ser mais uma criança, esse direito pode ser aplicado.

  Exemplo: muitas crianças publicam qualquer coisa na internet e nas mídias sociais sem considerar as consequências futuras.

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - §2.1 Princípios do processamento de dados GDPR artigo 5.1.c.

36

IT Partners

Direito de se opor

- Quando os dados pessoais forem processados para fins de marketing direto, o titular dos dados terá o **direito de se opor** (a qualquer momento) ao processamento de dados pessoais relativos a esse marketing, o que inclui a objeção à criação de perfil na medida em que está relacionado a tal marketing direto.
- O Controlador é obrigado a notificar os Titulares dos Dados sobre a possibilidade de registrar objeções/oposições.
- Quando o titular dos dados se opuser ao processamento para fins de marketing direto, os dados pessoais deixarão de ser processados para tais finalidades.



Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - §2.1 Princípios do processamento de dados GDPR artigo 5.1.c.

37

Cuidado com campos pré-selecionados

- O GDPR traz uma lista de interesses do usuário considerados como "legítimos" para o processamento de dados pessoais, ainda que sem seu **consentimento**.
- O marketing, no entanto, não é considerado como uma dessas hipóteses de legitimidade - é necessário o consentimento, sendo recomendado o "opt-in" do titular de dados.
- O usuário (titular) não pode ser obrigado a consentir o processamento de seus dados pessoais que não são necessários para a prestação de serviços que solicitou.
- Silêncio, campos pré-selecionados ou inatividade **não** podem ser interpretadas como expressão de consentimento.



Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - §2.1 Princípios do processamento de dados GDPR artigo 5.1.c.

38

IT Partners

Cookies e a privacidade



Um cookie é um arquivo de texto que é colocado no computador do usuário da Internet, capaz de identificar usuários e registrar suas preferências.

Tipos:

- Cookie técnico: por exemplo. usado para o seu carrinho de compras online
- Cookie de rastreamento; monitorar o comportamento online (surf) para criar um perfil do usuário da Internet
- Cookie de sessão: contém informações sobre o que você está fazendo*
- Permite publicidade personalizada e direcionada
- Um cookie é um tipo de identificador de dados pessoais indiretos

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 8.6.3 Cookies

39

Tipos comuns de cookies



Sessão

- Permitem que os usuários sejam reconhecidos dentro de um site.
- São excluídos ao sair do site ou fechar navegador.
- Exemplos de aplicação: carrinhos de compra em lojas virtuais e logon em sites.

Persistentes

- Permanecem no disco rígido do usuário até serem apagados ou até expirarem.
- Exemplo de aplicação: guardar preferências de um visitante recorrente, como idioma.

Rastreamento

- São colocados no disco rígido de um usuário por um site de um domínio diferente daquele que o usuário está visitando. Por isso são chamados de “cookies de terceiros”.
- Exemplo de aplicação: acompanhar quais páginas um usuário visita e utilizar isso para criar um perfil.

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 8.6.3 Cookies

40

IT Partners

Lista de requisitos de compatibilidade de cookies



Seu sistema de consentimento de cookie compatível com GDPR deve garantir que o consentimento seja:

- **Transparente**: dado com base em informações claras e específicas sobre tipos de dados e finalidade.
- **Prévio**: Dado antes de qualquer processamento diferente do estritamente necessário, também conhecido como "consentimento prévio".
- **Sem ambiguidade**: dado como uma ação positiva e afirmativa.
- **Documentado**: Gravado e armazenado de forma segura como prova de que o consentimento foi dado.
- **Reversível**: os usuários devem poder retirar seu consentimento sempre que quiserem.
- **Renovado**: renovado regularmente. (a Diretiva ePrivacy propõe uma vez por ano).

41

Como a Internet afetou a área de marketing

O marketing direto é difundido e usado por

- Fornecedores de produtos e serviços
- Organizações de caridade

Marketing é o processo de manter uma relação direta com um Titular dos Dados por razões comerciais ou de caridade

- Isso significa:
  - Coletando dados pessoais, criando perfis e enviando (todos os tipos de) malas diretas em campanhas publicitárias direcionadas
  - Compra de dados pessoais de terceiros
  - Contratar um terceiro para organizar suas correspondências

42

IT Partners

Privacidade como modelo de negócio

- Algumas empresas vendem informações de seus usuários como seu único modelo de negócios
- Facebook e Google (Alphabet) são as maiores empresas de perfis, eles sabem sobre tudo o que há para ser conhecido sobre os usuários de seus produtos gratuitos.

Política de privacidade do Facebook

Coletamos o conteúdo e outras informações que você fornece quando usa nossos serviços, inclusive quando você se inscreve em uma conta, cria ou acompanha e envia mensagens ou se comunica com outras pessoas. Isso pode incluir informações no ou sobre o conteúdo que você fornece, como a localização de uma foto ou a data em que um arquivo foi criado. Também coletamos informações sobre como você usa nossos serviços, como os tipos de conteúdo visualizados ou envolvidos, a frequência e a duração de suas atividades. "

43

Serviços gratuitos vem com um preço

Google, Facebook, Linkedin, Waze, Instagran

- Eles sabem o que as pessoas estão pesquisando ou comprando ativamente e as palavras ou frases usadas para encontra-las.
- Eles têm as informações sobre onde estamos, quem somos, onde estaremos e o que faremos.
- Eles sabem muito sobre quanto dinheiro gastamos, o que fazemos para viver, dados demográficos, quem são nossos amigos, o que fazemos fora do trabalho, quem vamos votar e que televisão, musicas e entretenimento que consumimos.
- O Google também sabe como todas essas coisas mudaram ao longo do tempo.
- Em suma, eles têm exatamente as informações que as empresas precisam para maximizar seu marketing. As informações necessárias para trazer o produto ou serviço de que você precisa, exatamente no momento em que você precisar.

44

As informações de mídia social são usadas para atividades de marketing

- Quando os dados pessoais são processados para fins de marketing direto, o titular dos dados terá o direito de se opor a qualquer momento ao processamento de dados pessoais relativos a esse marketing, o que inclui o perfil na medida em que está relacionado a tal marketing direto.
- A notificação dos titulares dos dados sobre a possibilidade de registrar objeções **é obrigatória.**
- Quando o titular dos dados se opuser ao processamento para fins de marketing direto, os dados pessoais deixarão de ser processados para tais finalidades

Fonte: White Paper – Privacidade, Dados Pessoais e o GDPR - § 8.6.3 Cookies

45

4 Lei Geral de Proteção de Dados

- Não cai no exame

51

IT Partners

LGPD - Lei 13.709 de 14 de agosto de 2018

- Em 17 de julho de 2018, o Senado federal aprovou o Projeto de Lei n. 53 que altera a Lei 12.965/2014 (Marco Civil da Internet) e cria a Lei de Proteção de Dados Pessoais.
- Na América Latina, até então, apenas Cuba e Brasil não possuíam legislação de proteção de dados pessoais.
- O projeto foi encaminhado para a sanção presidencial em 14/08.
- Parcialmente sancionado, o texto traz um período de 18 meses para entrar em vigor.

LGPD
Lei Geral de Proteção de Dados

52

Principais pontos da LGPD

- Aplicabilidade: afeta qualquer atividade que envolva utilização de dados pessoais, incluindo tratamento pela internet, de consumidores, empregados, entre outros.
- Autoridade Supervisora: previsão de criação, porém vetada quando da sanção presidencial.
- Notificações obrigatórias: em caso de risco ou dano relevante ao(s) titular(es) em prazo a ser definido pela AS.
- Extraterritorialidade: aplica-se também a empresas que não possuem estabelecimento no Brasil.
- Dados: Pessoais, Sensíveis e de Crianças e de Adolescentes.

53

Principais pontos da LGPD

- Relatório de impacto à proteção de dados pessoais: praticamente é o mesmo critério do GDPR;
- Encarregado da proteção de dados pessoais: é o nosso DPO
- Consentimento x Exceções para Consentimento: é a autorização formal do titular dos dados em relação às demais formas de permitir o tratamento sem a devida autorização, em exceção:

Obrigação legal Controlador	Uso da Administração Pública	Órgãos de Pesquisa (Anonimização)
Execução de contrato	Direitos em processos	Proteção da vida
Tutela da saúde	Legítimo Interesse	Proteção do crédito

54

Principais pontos da LGPD

Escopo de aplicação - Art. 1

Afeta qualquer atividade que envolva tratamento de dados pessoais, incluindo o tratamento pela internet, de consumidores, empregados, entre outros

Autoridade

Criada na MP no. 869/2018 a Autoridade Nacional de Proteção de Dados (ANPD), responsável por garantir cumprimento da Lei.

Autorização para o tratamento de dados - Art. 7

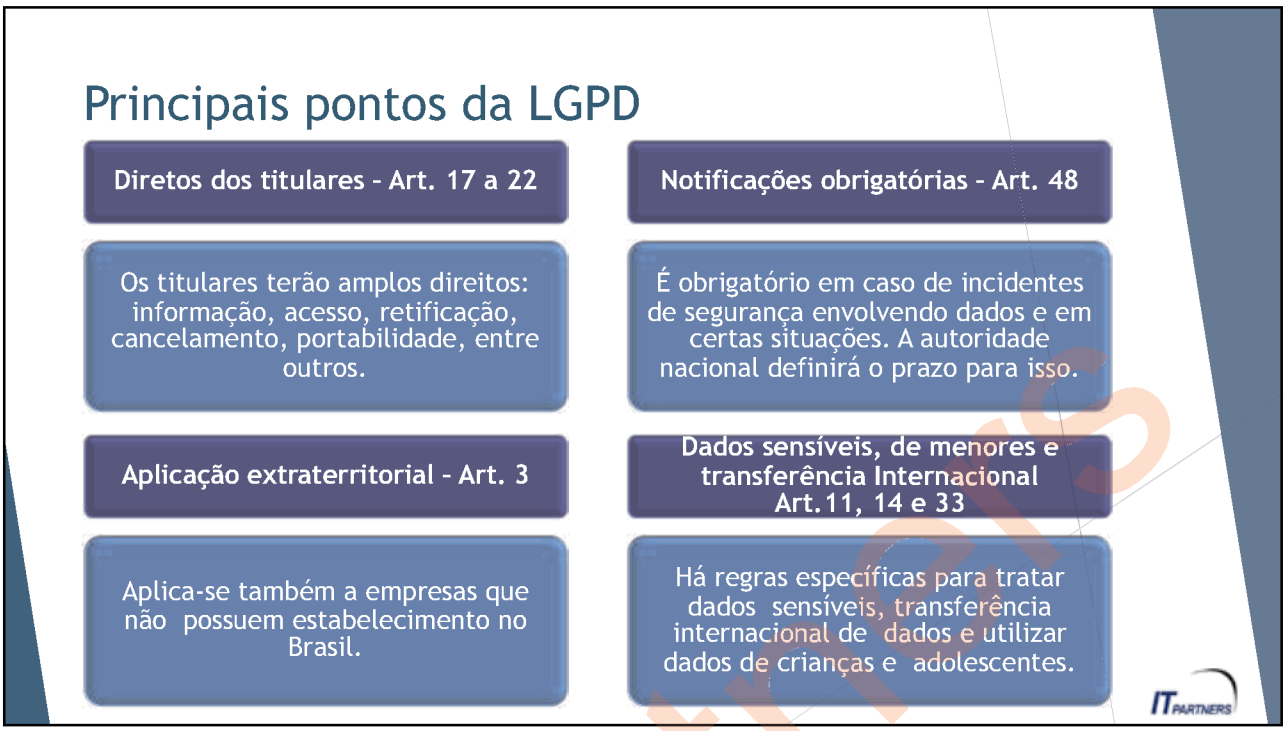
O consentimento será uma das 10 responsabilidades que legitimarão o tratamento de dados.

Princípios de proteção de dados - Art. 6

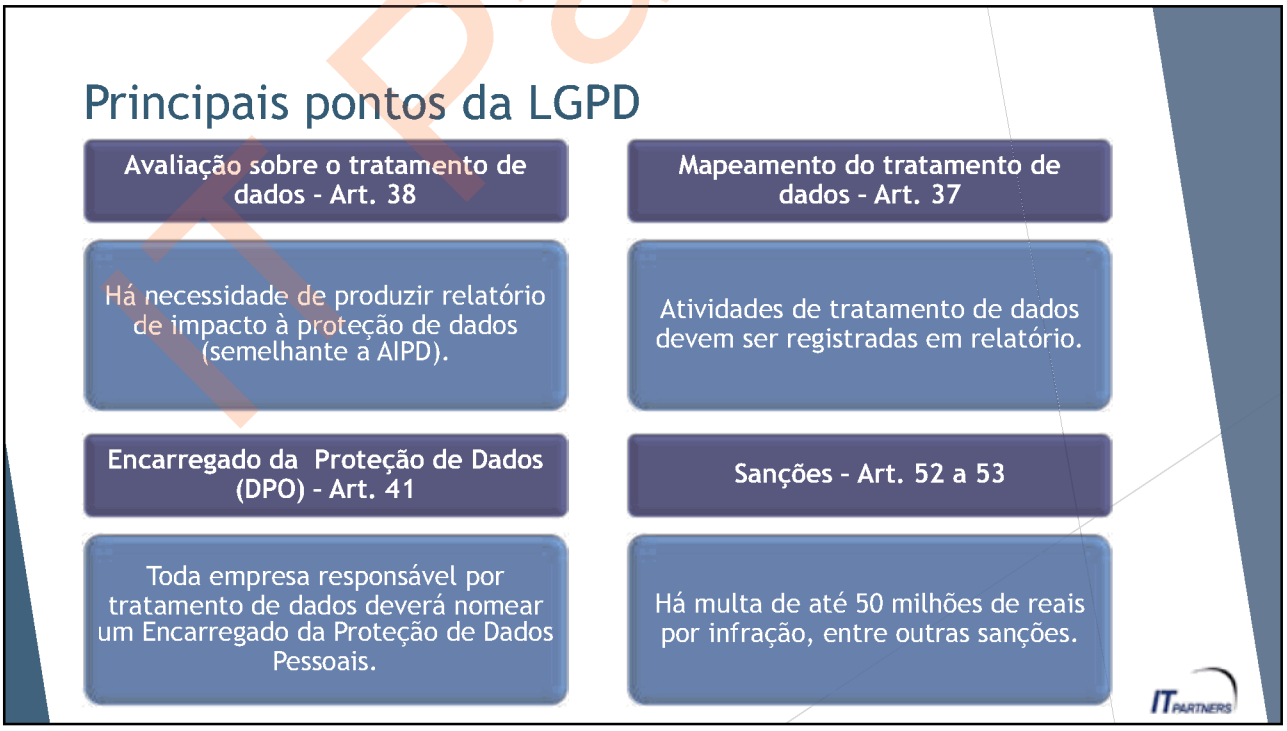
Foram introduzidos 10 princípios da proteção de dados, incluindo-se o de demonstrar medidas adotadas para cumprir a lei (prestação de contas).

55

IT Partners



56



57

IT Partners

10 princípios da LGPD(art.6): Boa Fé



58

Fim do Módulo 3

59

IT Partners

EXIN Privacy & Data Protection

FOUNDATION

Certified by EXIN

Exame simulado

Edição 202003

Copyright © EXIN Holding B.V. 2020. All rights reserved.
EXIN® is a registered trademark.

No part of this publication may be reproduced, stored, utilized or transmitted in any form or by any means, electronic, mechanical, or otherwise, without the prior written permission from EXIN.

Conteúdo

Introdução	4
Exame simulado	5
Gabarito de respostas	16
Avaliação	36

Introdução

Este é o exame simulado EXIN Privacy & Data Protection Foundation (PDPF.PR). As regras e regulamentos do exame do EXIN se aplicam a este exame.

Este exame consiste de 40 questões de múltipla escolha. Cada questão de múltipla escolha possui um certo número de alternativas de resposta, entre as quais apenas uma resposta é a correta.

O número máximo de pontos que pode ser obtido neste exame é 40. Cada resposta correta vale 1 ponto. Você precisa de 26 pontos ou mais para passar no exame.

O tempo permitido para este exame é de 60 minutos.

Boa Sorte!

Exame simulado

1 / 40
Um lojista deseja registrar quantos visitantes entram em sua loja todos os dias. Um sistema detecta o endereço MAC do smartphone de cada visitante. É impossível o lojista identificar o proprietário do telefone a partir deste sinal, mas os provedores de serviços de telefonia podem relacionar o endereço MAC ao proprietário do telefone.

De acordo com o GDPR, é permitido que o lojista utilize este método?

A) Sim, porque o lojista não pode identificar o proprietário do telefone.
B) Sim, porque o visitante consentiu automaticamente quando se conectou ao Wi-Fi.
C) Não, porque o endereço MAC do telefone deve ser considerado como um dado pessoal.
D) Não, porque os provedores de serviços de telefonia são os proprietários dos endereços MAC.

2 / 40
Os dados pessoais, de acordo com a definição no GDPR, podem ser divididos em vários tipos. Um desses tipos é descrito do seguinte modo:

Dados que revelem direta ou indiretamente as origens raciais ou étnicas de uma pessoa, suas visões políticas, filosóficas ou religiosas, afiliação sindical e dados relacionados à saúde, vida sexual ou orientação sexual.

Que categoria de dados pessoais é esta?

A) Dados pessoais diretos
B) Dados pessoais indiretos
C) Dados pseudonimizados
D) Dados pessoais de categoria especial

3 / 40
Uma pessoa física ou jurídica, autoridade pública, agência ou outro organismo que, isoladamente ou em conjunto com outras partes, determina os objetivos e os meios de processamento de dados pessoais.

Que papel na proteção de dados é definido aqui?

A) Controlador
B) Processador
C) Autoridade supervisora
D) Terceiro

4 / 40
Ocorreu uma violação de segurança em um sistema de informação que também contém dados pessoais.

De acordo com o GDPR, qual é a **primeira** coisa que o controlador deve fazer?

A) Verificar se a violação pode ter provocado a perda ou o processamento ilegal de dados pessoais
B) Avaliar o risco de efeitos adversos para os titulares dos dados usando uma Avaliação de Impacto sobre a Proteção de Dados (DPIA)
C) Determinar se dados pessoais de caráter sensível foram ou possam ter sido processados ilegalmente
D) Relatar a violação imediatamente a todos os titulares dos dados e à autoridade supervisora relevante

5 / 40
Uma violação da segurança que provoque a destruição, perda, alteração, divulgação não autorizada ou acesso acidental ou ilegal de dados pessoais transmitidos, armazenados ou processados de outro modo.

Qual é o termo **exato** associado a esta definição no GDPR?

A) Violação da confidencialidade
B) Violação de dados pessoais
C) Violação de segurança
D) Incidente de segurança

6 / 40
Que direito do titular dos dados é definido explicitamente pelo GDPR?

A) Uma cópia dos dados pessoais deve ser fornecida no formato solicitado pelo titular dos dados.
B) O acesso aos dados pessoais deve ser fornecido sem custo para o titular dos dados.
C) Os dados pessoais sempre devem ser alterados mediante solicitação do titular dos dados.
D) Os dados pessoais devem ser apagados sempre que isso for solicitado pelo titular dos dados.

7 / 40
Quando dados pessoais são processados, quem é o responsável final por demonstrar conformidade com o GDPR?

A) O controlador
B) O Data Protection Officer (DPO)
C) O processador
D) A autoridade supervisora

8 / 40
De acordo com o princípio de limitação de finalidade, os dados não devem ser processados além do objetivo legítimo definido. Contudo, o processamento adicional é permitido em alguns casos específicos, desde que sejam adotadas salvaguardas apropriadas aos direitos e liberdades dos titulares dos dados.

Para qual finalidade o processamento adicional **não** é permitido?

A) Para fins de arquivamento por interesse público
B) Para fins comerciais e de marketing direto
C) Para fins estatísticos em geral
D) Para fins de pesquisa histórica ou científica

9 / 40
De acordo com o GDPR, em que situação os titulares dos dados devem ser **sempre** notificados de uma violação de dados pessoais?

A) Quando os dados pessoais forem processados em uma unidade do processador que não esteja localizada dentro das fronteiras da Área Econômica Euopeia (AEE)
B) Quando os dados pessoais forem processados por uma parte que concordou com o contrato de processamento, mas ainda não o assinou
C) Quando o sistema no qual os dados pessoais são processados for atacado, causando uma avaria em seus dispositivos de armazenamento
D) Quando houver uma probabilidade considerável de que a violação provoque um alto risco à privacidade dos titulares dos dados

10 / 40
Alguns processamentos de dados estão fora do escopo material do GDPR.

Que tipo de processamento **não** está sujeito ao GDPR?

A) Coleta de informações de nome e endereço para um clube de ginástica
B) Criação de um backup de dados biométricos para fins de segurança dos dados
C) Edição de fotografias pessoais antes de imprimi-las em casa

11 / 40
O GDPR não define privacidade como um termo, mas emprega o conceito de modo implícito em todo o seu texto.

Qual seria uma definição correta de privacidade, conforme implicitamente utilizado por todo o GDPR?

A) O direito fundamental à proteção de dados pessoais, independentemente do modo como foram obtidos
B) O direito de não ser incomodado por pessoas não convidadas, não ser seguido, vigiado ou monitorado
C) O direito ao respeito pela vida privada e familiar de uma pessoa, seu lar e sua correspondência pessoal
D) O direito à liberdade de opinião e expressão e o direito a buscar, receber e divulgar informações

12 / 40
Qual é a relação entre privacidade e proteção de dados?

A) Proteção de dados e privacidade são sinônimos e têm o mesmo significado.
B) Proteção de dados é a parte da privacidade que protege a integridade física de um indivíduo.
C) Proteção de dados refere-se às medidas necessárias para proteger a privacidade de um indivíduo.

13 / 40
Qual é a situação jurídica do GDPR?

A) O GDPR é uma lei funcional em todos os estados membros da Área Econômica Europeia (AEE). Alguns artigos permitem que a legislação dos estados membros forneça regras mais específicas.
B) O GDPR é uma recomendação da Comissão Europeia para que as autoridades legais dos países da AEE melhorem suas leis sobre proteção de dados pessoais.
C) O GDPR estabelece condições e requisitos mínimos. Os estados membros devem aprovar leis nacionais que atendam a estes requisitos mínimos.

14 / 40
No GDPR, alguns tipos de dados pessoais são considerados como dados pessoais de categoria especial.

Quais dados pessoais são considerados como dados pessoais de categoria especial?

A) Uma lista de pagamentos efetuados usando um cartão de crédito
B) Uma lista de endereços dos membros de um partido político
C) Um registro genealógico dos ancestrais de uma pessoa

15 / 40
Para planejar o tamanho da área de estacionamento necessária, um governo local monitora e salva o número da placa de cada carro que entra e sai do centro da cidade. Foi obtida uma permissão para coletar dados sobre o número de carros presentes no centro da cidade.

Pela comparação dos horários de entrada e saída para as placas, é calculado o número de carros presentes a cada momento de cada dia. A cada mês é gerado um relatório detalhando o número médio de carros presentes no centro da cidade em momentos específicos para cada dia da semana. Em todas as entradas no centro da cidade, um cartaz explica com clareza quais dados são coletados por quem, a finalidade do processamento e o fato de que os números das placas serão armazenados em segurança por até dois anos, porque as medidas serão repetidas no ano seguinte.

Que princípio básico do processamento legítimo de dados pessoais está sendo **violado** neste caso?

A) Os dados pessoais devem ser coletados para finalidades especificadas, explícitas e legítimas e não devem ser processados adicionalmente.
B) Os dados pessoais devem ser mantidos de modo que permita a identificação dos titulares dos dados por um período não maior que o necessário.
C) Os dados pessoais devem ser processados de modo que garanta a segurança apropriada dos dados pessoais.
D) Os dados pessoais devem ser processados de modo transparente em relação ao titular dos dados.

16 / 40
Os dados pessoais devem ser adequados, relevantes e limitados ao que for necessário em relação às finalidades para as quais são processados.

Que princípio do processamento de dados é descrito aqui?

A) Exatidão
B) Minimização de dados
C) Equidade e transparência
D) Limitação de finalidade

17 / 40
Um indivíduo está se mudando da cidade A para a cidade B, em um estado membro da Área Econômica Europeia (AEE). Na cidade A, ele era um paciente do hospital local A. Na cidade B, passa a ser um paciente do hospital B. O paciente optou pela não inclusão no sistema nacional de prontuários eletrônicos de pacientes.

O paciente solicita que o hospital A encaminhe seu prontuário médico diretamente ao hospital B.

De acordo com o GDPR, o que é permitido?

A) O hospital em A pode enviar os dados diretamente ao hospital B, como solicitado pelo paciente.
B) O hospital em A pode enviar o prontuário ao hospital B, antes que seja solicitado pelo paciente.
C) O hospital em A pode enviar o prontuário médico ao titular dos dados, mas não a outro hospital.
D) O hospital em A não pode enviar o prontuário porque não há uma base legítima para o processamento.

18 / 40
Uma empresa tem planos para processar dados pessoais. O Data Protection Officer (DPO) recentemente indicado executa uma Avaliação de Impacto sobre a Proteção de Dados (DPIA). O DPIA constata que todos os computadores têm uma configuração que faz os monitores exibirem um protetor de tela após cinco segundos de inatividade. Contudo, os computadores não são bloqueados automaticamente. Quando os funcionários deixam sua mesa, geralmente também não bloqueiam seus computadores.

Isso é um exemplo de quê?

A) Acesso a dados
B) Violação de dados pessoais
C) Incidente de segurança
D) Vulnerabilidade da segurança

19 / 40
O GDPR refere-se aos princípios de proporcionalidade e subsidiariedade.

Qual é o significado de subsidiariedade neste contexto?

A) Dados pessoais só podem ser processados de acordo com a especificação da finalidade.
B) Dados pessoais não podem ser reutilizados sem um consentimento explícito e informado.
C) Dados pessoais só podem ser processados quando não houver outros meios para obter a finalidade.
D) Dados pessoais devem ser adequados, relevantes e não excessivos em relação às finalidades.

20 / 40
"O controlador deve implementar medidas técnicas e organizacionais apropriadas para garantir que (...) sejam processados somente os dados pessoais que sejam necessários para cada finalidade específica do processamento."

Que termo do GDPR é definido aqui?

A) Conformidade
B) Proteção de dados desde a concepção (by design) e por padrão (by default)
C) Proteção de dados incorporada

21 / 40
Durante a realização de um backup, ocorreu uma falha no disco rígido do servidor de dados. Tanto os dados quanto o backup são perdidos. O disco continha dados pessoais, mas nenhum dado pessoal de categoria especial.

O processador afirma que isto constitui uma violação de dados pessoais.

A afirmação do processador é verdadeira?

A) Sim, porque os dados pessoais no disco foram processados de modo ilegal.
B) Sim, porque não havia dados pessoais de categoria especial armazenados no disco.
C) Não, porque nenhum dado pessoal no disco foi processado, apenas destruído.
D) Não, porque isto é apenas um incidente de segurança, e não uma violação de dados.

22 / 40
As organizações têm a obrigação de manter diversos registros para demonstrar conformidade com o GDPR.

Qual registro **não** é obrigatório de acordo com o GDPR?

A) Um registro de todo o processamento pretendido, juntamente com a(s) finalidade(s) do processamento e as justificativas legais
B) Um registro de violações de dados com todas as características relevantes, incluindo notificações
C) Um registro das notificações enviadas à autoridade supervisora, relativas ao processamento de dados pessoais
D) Um registro de processadores, incluindo os dados pessoais fornecidos e o período pelo qual estes dados podem ser retidos

23 / 40
Houve uma violação de dados pessoais e o controlador está redigindo uma notificação à autoridade supervisora. As seguintes informações já constam da notificação:

- A natureza da violação de dados pessoais e suas possíveis consequências.
- Informações sobre as partes que podem fornecer mais informações sobre a violação dos dados.

Que outras informações o controlador deve fornecer?

A) A informação de que as autoridades locais e nacionais foram notificadas da violação dos dados
B) O nome e os detalhes de contato dos titulares dos dados que possam ter tido seus dados violados
C) As medidas sugeridas para mitigar as consequências adversas da violação de dados
D) As informações necessárias para acessar os dados pessoais que foram violados

24 / 40
De acordo com o Artigo 33 do GDPR, o controlador deve notificar uma violação de dados pessoais à autoridade supervisora sem demora injustificada e, quando possível, no máximo 72 horas após tomar ciência do fato.

Qual é a sanção máxima para o descumprimento desta obrigação de notificar?

A) € 10.000.000 ou 2% do volume global anual de negócios, o que for maior
B) € 20.000.000 ou 4% do volume global anual de negócios, o que for maior
C) Até € 500.000 com um mínimo de € 120.000
D) Até € 820.000 com um mínimo de € 350.000

25 / 40
De acordo com o GDPR, qual é uma tarefa da autoridade supervisora?

A) Implementar medidas técnicas e organizacionais para garantir a conformidade
B) Investigar violações de segurança de informações corporativas
C) Monitorar e impor a aplicação do GDPR

26 / 40
Uma empresa belga tem sua sede na França por motivos fiscais. Ela firma um contrato juridicamente vinculante com um processador nos Países Baixos para o processamento de dados pessoais de titulares dos dados de várias nacionalidades.

Ocorre uma violação de dados pessoais. A autoridade supervisora inicia uma investigação.

Por que a autoridade supervisora francesa é considerada como a autoridade supervisora principal?

A) Porque a França está localizada no meio da Europa
B) Porque a França é o maior dos três países da Área Econômica Europeia (AEE)
C) Porque a sede da empresa está na França

27 / 40
Em 12 de julho de 2016 a Comissão Europeia implementou uma disposição regulamentar relativa à transferência de dados pessoais entre a Área Econômica Europeia (AEE) e os Estados Unidos da América (EUA). A disposição regulamentar é baseada nas medidas para proteção de dados descritas no EU-US Privacy Shield.

Que tipo de disposição é essa?

A) Decisão de adequação
B) Exceção
C) Contrato juridicamente vinculante
D) Tratado que substitui o GDPR

28 / 40
Um controlador deseja terceirizar o processamento de dados pessoais para um processador.

O que deve ser realizado **antes** da terceirização?

A) O controlador deve pedir permissão à autoridade supervisora para terceirizar o processamento dos dados.
B) O controlador deve perguntar à autoridade supervisora se o contrato por escrito combinado está em conformidade com os regulamentos.
C) O controlador e o processador devem preparar uma minuta e assinar um contrato por escrito garantindo a confidencialidade dos dados.
D) O processador deve demonstrar ao controlador que todas as demandas acordadas no acordo de nível de serviço (ANS) são cumpridas.

29 / 40
Qual é o objetivo de uma auditoria de proteção de dados pela autoridade supervisora?

A) Aconselhar o controlador sobre a mitigação de riscos à privacidade para proteger o controlador de pedidos de indenização de responsabilidade civil por não conformidade
B) Atender a obrigação no GDPR de implementar medidas técnicas e organizacionais apropriadas para proteção de dados
C) Monitorar e impor a aplicação do GDPR, determinando se o processamento está sendo realizado em conformidade com o GDPR

30 / 40
Para que um processamento de dados pessoais seja legal, o que **sempre** será exigido?

A) Um código de conduta deve ser estabelecido, descrevendo exatamente o que o processamento envolve.
B) O processamento deve relatado e autorizado pela autoridade supervisora.
C) Deve haver uma base legítima para o processamento de dados pessoais.

31 / 40
Dados pessoais podem ser transferidos para fora da Área Econômica Europeia (AEE).

De acordo com o GDPR, que transferências para fora da AEE são sempre legais?

A) Transferências baseadas nas leis do país não pertencente à AEE envolvido
B) Transferências sujeitas às regras da Organização Mundial do Comércio (OMC)
C) Transferências governadas por regras corporativas vinculantes (BCR) aprovadas
D) Transferências dentro de uma corporação ou organização global

32 / 40
De acordo com o GDPR, qual seria uma descrição de regras corporativas vinculantes (BCR)?

A) Uma decisão sobre a segurança da transferência de dados pessoais para um país fora da Área Econômica Europeia (AEE)
B) Uma medida para compensar a ausência de proteção de dados em um país terceiro
C) Um conjunto de acordos abordando transferências de dados pessoais entre países situados fora da AEE
D) Um conjunto de regras aprovadas sobre a proteção de dados pessoais, usadas por um grupo de empresas

33 / 40
Um contrato por escrito entre um controlador e um processador é chamado de acordo de processamento.

De acordo com o GDPR, o que **não** precisa ser abordado no contrato por escrito?

A) O código de ética comercial e conduta da contratada que será utilizado
B) Os procedimentos para violações de segurança das informações e de dados pessoais
C) As medidas técnicas e organizacionais implementadas
D) Quais dados são cobertos pelo acordo de processamento de dados

34 / 40
Um dos objetivos de uma Avaliação de Impacto sobre a Proteção de Dados (DPIA) é fortalecer a confiança dos clientes ou cidadãos no modo como os dados pessoais são processados e a privacidade é respeitada.

Como um DPIA pode fortalecer a confiança?

A) A organização minimiza o risco de ajustes dispendiosos dos processos ou remodelamento dos sistemas em um estágio mais tardio.
B) A organização previne a não conformidade com o GDPR e minimiza o risco de multas.
C) A organização prova que considera a privacidade com seriedade e visa à conformidade com o GDPR.

35 / 40
Um dos sete princípios da proteção de dados desde a concepção (by design) é a *Funcionalidade – Soma Positiva, Diferente de Zero*.

Qual é a essência deste princípio?

A) As normas de segurança aplicadas devem garantir a confidencialidade, a integridade e a disponibilidade dos dados pessoais durante todo o seu ciclo de vida.
B) Se diferentes tipos de objetivos legítimos forem contraditórios, os objetivos de privacidade devem ter prioridade em relação a outros objetivos de segurança.
C) Ao incorporar a privacidade em uma determinada tecnologia, processo ou sistema, isto deve ser realizado de tal modo que a funcionalidade completa não seja prejudicada.
D) Sempre que possível, avaliações detalhadas de impacto na privacidade e riscos devem ser realizadas e publicadas, documentando com clareza os riscos para a privacidade.

36 / 40
Uma empresa deseja utilizar os dados pessoais de seus clientes. Ela pretende começar a enviar um informativo personalizado a todas as clientes do sexo feminino.

Que direito todos os titulares dos dados terão nesta situação?

A) O direito à compensação
B) O direito de se opor à definição de perfis
C) O direito à retificação

37 / 40
Qual seria uma descrição de proteção de dados desde a concepção (by design) e como padrão (by default)?

A) Uma abordagem que implementa a proteção dos dados desde o início.
B) Uma indicação de prazos se o processamento estiver relacionado ao apagamentos.
C) Os dados só podem ser coletados para finalidades explícitas e legítimas.
D) Não manter mais dados que o estritamente necessário para o processamento.

38 / 40
De acordo com o GDPR, quando uma Avaliação de Impacto sobre a Proteção de Dados (DPIA) é obrigatória?

A) Quando um projeto incluir tecnologias ou processos que utilizem dados pessoais
B) Quando for provável que o processamento cause um alto risco para os direitos dos titulares dos dados
C) Quando operações de processamento semelhantes com riscos comparáveis forem repetidas

39 / 40
O GDPR descreve o princípio de minimização de dados.

Como as organizações podem obedecer a esse princípio?

A) Aplicando o conceito de privilégio mínimo aos dados pessoais coletados, armazenados ou de outro modo processados.
B) Limitando o direito de acesso às pessoas que precisarem dos dados pessoais para as operações de processamento pretendidas.
C) Limitando os tamanhos dos arquivos, salvando todos os dados pessoais processados no menor formato possível.
D) Limitando os dados pessoais àquilo que for adequado, relevante e necessário para os objetivos do processamento.

40 / 40
Qual é a **principal** utilização de um cookie persistente?

A) Garantir que os dados pessoais do usuário sejam armazenados com segurança no servidor
B) Personalizar a experiência do usuário do site durante uma próxima visita
C) Registrar cada tecla pressionada por um usuário computador para descobrir senhas
D) Salvar as páginas que um usuário marcar como favoritas no histórico do navegador do usuário

Gabarito de respostas

1 / 40
Um lojista deseja registrar quantos visitantes entram em sua loja todos os dias. Um sistema detecta o endereço MAC do smartphone de cada visitante. É impossível o lojista identificar o proprietário do telefone a partir deste sinal, mas os provedores de serviços de telefonia podem relacionar o endereço MAC ao proprietário do telefone.

De acordo com o GDPR, é permitido que o lojista utilize este método?

A) Sim, porque o lojista não pode identificar o proprietário do telefone.
B) Sim, porque o visitante consentiu automaticamente quando se conectou ao Wi-Fi.
C) Não, porque o endereço MAC do telefone deve ser considerado como um dado pessoal.
D) Não, porque os provedores de serviços de telefonia são os proprietários dos endereços MAC.

A) Incorreto. O problema não é o lojista conseguir identificar o visitante, mas o fato de que isto seria tecnicamente possível.
B) Incorreto. O consentimento deve consistir em um ato ativo, informado e voluntário de anuência ao processamento. Para ver um endereço MAC, o visitante não precisa estar conectado ao Wi-Fi.
C) Correto. O sinal do telefone é um código específico que pode ser relacionado a seu proprietário. Os dados devem ser considerados como dados pessoais, porque tecnicamente é possível identificar o visitante. (Literatura: A, Capítulo 3; Artigos 26 e 30 do GDPR)
D) Incorreto. O lojista não pode manter nem processar os dados porque eles devem ser considerados como dados pessoais. O provedor de serviços de telefonia não é o proprietário do endereço MAC e não é protegido pelo GDPR.

2 / 40
Os dados pessoais, de acordo com a definição no GDPR, podem ser divididos em vários tipos. Um desses tipos é descrito do seguinte modo:

Dados que revelem direta ou indiretamente as origens raciais ou étnicas de uma pessoa, suas visões políticas, filosóficas ou religiosas, afiliação sindical e dados relacionados à saúde, vida sexual ou orientação sexual.

Que categoria de dados pessoais é esta?

A) Dados pessoais diretos
B) Dados pessoais indiretos
C) Dados pseudonimizados
D) Dados pessoais de categoria especial

A) Incorreto. Tanto dados diretos quanto indiretos são descritos.
B) Incorreto. Tanto dados diretos quanto indiretos são descritos.
C) Incorreto. Dados pseudonimizados não são capazes de revelar informações diretamente.
D) Correto. Esta é a definição de dados pessoais de categoria especial. (Literatura: A, Capítulo 1; Artigo 4 do GDPR)

3 / 40
Uma pessoa física ou jurídica, autoridade pública, agência ou outro organismo que, isoladamente ou em conjunto com outras partes, determina os objetivos e os meios de processamento de dados pessoais.

Que papel na proteção de dados é definido aqui?

A) Controlador
B) Processador
C) Autoridade supervisora
D) Terceiro

A) Correto. O controlador determina o objetivo e os meios de processamento. (Literatura: A, Capítulo 1; Artigo 4(7) do GDPR)
B) Incorreto. O controlador determina os objetivos do processamento, o processador trabalha de acordo com as instruções do controlador.
C) Incorreto. A autoridade supervisora monitora e exige o cumprimento dos requisitos do GDPR.
D) Incorreto. Um terceiro não atua para determinar o objetivo do processamento. Qualquer parte que determine o objetivo se tornaria um novo controlador.

4 / 40
Ocorreu uma violação de segurança em um sistema de informação que também contém dados pessoais.

De acordo com o GDPR, qual é a **primeira** coisa que o controlador deve fazer?

A) Verificar se a violação pode ter provocado a perda ou o processamento ilegal de dados pessoais
B) Avaliar o risco de efeitos adversos para os titulares dos dados usando uma Avaliação de Impacto sobre a Proteção de Dados (DPIA)
C) Determinar se dados pessoais de caráter sensível foram ou possam ter sido processados ilegalmente
D) Relatar a violação imediatamente a todos os titulares dos dados e à autoridade supervisora relevante

A) Correto. A primeira coisa que deve ser feita é verificar se o incidente de segurança realmente constitui uma violação de dados pessoais. (Literatura: A, Capítulo 5)
B) Incorreto. Um DPIA é conduzido durante o delineamento de operações de processamento de dados pessoais. Isso não faz parte do procedimento para uma violação de dados.
C) Incorreto. Esta é a etapa seguinte, se for comprovado que o incidente constitui uma violação de dados pessoais – verificar o tipo de violação de dados.
D) Incorreto. A necessidade de relatar uma violação de dados, e a quem ela deve ser relatada, depende de ter havido ou não uma violação de dados e, se for o caso, do tipo de violação de dados.

5 / 40
Uma violação da segurança que provoque a destruição, perda, alteração, divulgação não autorizada ou acesso acidental ou ilegal de dados pessoais transmitidos, armazenados ou processados de outro modo.

Qual é o termo **exato** associado a esta definição no GDPR?

A) Violação da confidencialidade
B) Violação de dados pessoais
C) Violação de segurança
D) Incidente de segurança

A) Incorreto. O GDPR utiliza o termo violação de dados pessoais. Nem toda violação de dados constitui uma violação de confidencialidade.
B) Correto. Esta é a definição de uma violação de dados pessoais. (Literatura: A, Capítulo 5; Artigo 4(12) do GDPR)
C) Incorreto. O GDPR utiliza o termo violação de dados pessoais. Nem toda violação de segurança constitui uma violação de dados. Nem toda violação de dados constitui uma violação de dados pessoais.
D) Incorreto. O GDPR utiliza o termo violação de dados pessoais. Nem todo incidente de segurança constitui uma violação de dados.

6 / 40
Que direito do titular dos dados é definido explicitamente pelo GDPR?

A) Uma cópia dos dados pessoais deve ser fornecida no formato solicitado pelo titular dos dados.
B) O acesso aos dados pessoais deve ser fornecido sem custo para o titular dos dados.
C) Os dados pessoais sempre devem ser alterados mediante solicitação do titular dos dados.
D) Os dados pessoais devem ser apagados sempre que isso for solicitado pelo titular dos dados.

A) Incorreto. Os dados devem ser fornecidos em um formato estruturado, rotineiramente usado e que permita a leitura em um computador, mas não necessariamente em qualquer formato especificado pelo titular dos dados.
B) Correto. Os titulares dos dados têm direito a uma cópia de seus dados, sem custos. Contudo, apenas a primeira cópia precisa ser gratuita. (Literatura: A, Capítulo 4)
C) Incorreto. Apenas os dados incorretos precisam ser retificados.
D) Incorreto. O direito ao apagamento apresenta várias exceções, por exemplo, quando os dados forem necessários para o estabelecimento, exercício ou defensa de reclamações legais.

7 / 40
Quando dados pessoais são processados, quem é o responsável final por demonstrar conformidade com o GDPR?

A) O controlador
B) O Data Protection Officer (DPO)
C) O processador
D) A autoridade supervisora

A) Correto. O controlador é responsável por medidas de segurança dos dados adequadas e deve ser capaz de demonstrar a conformidade com o GDPR. (Literatura: A, Capítulo 2)
B) Incorreto. O DPO tem um conhecimento especializado e ajuda o controlador ou o processador a monitorar a conformidade interna.
C) Incorreto. O processador é aquele que processa os dados pessoais de acordo com as instruções do controlador. Mesmo assim, o controlador ainda é o responsável final.
D) Incorreto. O controlador deve demonstrar a conformidade com o GDPR, se solicitado pela autoridade supervisora.

8 / 40
De acordo com o princípio de limitação de finalidade, os dados não devem ser processados além do objetivo legítimo definido. Contudo, o processamento adicional é permitido em alguns casos específicos, desde que sejam adotadas salvaguardas apropriadas aos direitos e liberdades dos titulares dos dados.

Para qual finalidade o processamento adicional **não** é permitido?

A) Para fins de arquivamento por interesse público
B) Para fins comerciais e de marketing direto
C) Para fins estatísticos em geral
D) Para fins de pesquisa histórica ou científica

A) Incorreto. Com salvaguardas estabelecidas, o processamento adicional para fins de arquivamento por interesse público é permitido.
B) Correto. Esta não é uma finalidade permitida, se não constituir a finalidade legítima original do processamento. (Literatura: A, Capítulo 2)
C) Incorreto. Com salvaguardas estabelecidas, o processamento adicional para fins estatísticos em geral é permitido.
D) Incorreto. Com salvaguardas estabelecidas, o processamento adicional para fins de pesquisa é permitido.

9 / 40
De acordo com o GDPR, em que situação os titulares dos dados devem ser **sempre** notificados de uma violação de dados pessoais?

A) Quando os dados pessoais forem processados em uma unidade do processador que não esteja localizada dentro das fronteiras da Área Econômica Euopeia (AEE)
B) Quando os dados pessoais forem processados por uma parte que concordou com o contrato de processamento, mas ainda não o assinou
C) Quando o sistema no qual os dados pessoais são processados for atacado, causando uma avaria em seus dispositivos de armazenamento
D) Quando houver uma probabilidade considerável de que a violação provoque um alto risco à privacidade dos titulares dos dados

A) Incorreto. O local onde os dados são processados não tem importância para a obrigação de notificar os titulares dos dados sobre violações de dados pessoais.
B) Incorreto. O processamento de dados pessoais por outra parte diferente do controlador sem um contrato por escrito válido é considerado como uma violação de dados. Nesta situação, porém, consequências negativas para os titulares dos dados são improváveis. A notificação dos titulares dos dados não é obrigatória neste caso.
C) Incorreto. Uma avaria de dispositivos de armazenamento dificulta ou até mesmo impossibilita o acesso aos dados, mas não implica um processamento ilegal.
D) Correto. Se houver uma probabilidade significativa de impacto negativo para os titulares dos dados, o controlador é obrigado a notificá-los sobre a violação. (Literatura: A, Capítulo 5)

10 / 40
Alguns processamentos de dados estão fora do escopo material do GDPR.

Que tipo de processamento **não** está sujeito ao GDPR?

A) Coleta de informações de nome e endereço para um clube de ginástica
B) Criação de um backup de dados biométricos para fins de segurança dos dados
C) Edição de fotografias pessoais antes de imprimi-las em casa

A) Incorreto. A coleta também é considerada como um processamento de dados.
B) Incorreto. O armazenamento também é considerado como um processamento de dados.
C) Correto. O GDPR não é aplicável ao uso domiciliar de suas próprias fotografias. (Literatura: A, Capítulo 1; Artigo 4 do GDPR)

11 / 40
O GDPR não define privacidade como um termo, mas emprega o conceito de modo implícito em todo o seu texto.

Qual seria uma definição correta de privacidade, conforme implicitamente utilizado por todo o GDPR?

A) O direito fundamental à proteção de dados pessoais, independentemente do modo como foram obtidos
B) O direito de não ser incomodado por pessoas não convidadas, não ser seguido, vigiado ou monitorado
C) O direito ao respeito pela vida privada e familiar de uma pessoa, seu lar e sua correspondência pessoal
D) O direito à liberdade de opinião e expressão e o direito a buscar, receber e divulgar informações

A) Incorreto. Esta é uma definição de proteção dos dados.
B) Incorreto. Esta é uma definição de privacidade física. Contudo, o GDPR não diz respeito à privacidade física.
C) Correto. Esta é a definição empregada de modo implícito ao longo do GDPR. (Literatura: A, Capítulo 1)
D) Incorreto. Esta é uma versão resumida do Artigo 19 da Declaração Universal de Direitos Humanos: liberdade de opinião e expressão.

12 / 40
Qual é a relação entre privacidade e proteção de dados?

A) Proteção de dados e privacidade são sinônimos e têm o mesmo significado.
B) Proteção de dados é a parte da privacidade que protege a integridade física de um indivíduo.
C) Proteção de dados refere-se às medidas necessárias para proteger a privacidade de um indivíduo.

A) Incorreto. A proteção dos dados ajuda a proteger a privacidade de um indivíduo, mas os termos não são sinônimos.
B) Incorreto. A proteção de dados não está relacionada à integridade física ou à privacidade física.
C) Correto. A proteção de dados consiste em algumas medidas necessárias para proteger a privacidade de um indivíduo. (Literatura: A, Capítulo 1)

13 / 40
Qual é a situação jurídica do GDPR?

A) O GDPR é uma lei funcional em todos os estados membros da Área Econômica Europeia (AEE). Alguns artigos permitem que a legislação dos estados membros forneça regras mais específicas.
B) O GDPR é uma recomendação da Comissão Europeia para que as autoridades legais dos países da AEE melhorem suas leis sobre proteção de dados pessoais.
C) O GDPR estabelece condições e requisitos mínimos. Os estados membros devem aprovar leis nacionais que atendam a estes requisitos mínimos.

A) Correto. O GDPR é uma lei europeia, mas o Regulamento não exclui uma legislação dos estados membros que estabeleça as circunstâncias para situações de processamento específicas. (Literatura: A, Capítulo 1; Item 10 do Preâmbulo do GDPR)
B) Incorreto. Uma recomendação da UE não é obrigatória. O GDPR é uma lei europeia funcional em todos os estados membros.
C) Incorreto. Esta é a descrição de uma Diretiva da UE.

14 / 40
No GDPR, alguns tipos de dados pessoais são considerados como dados pessoais de categoria especial.

Quais dados pessoais são considerados como dados pessoais de categoria especial?

A) Uma lista de pagamentos efetuados usando um cartão de crédito
B) Uma lista de endereços dos membros de um partido político
C) Um registro genealógico dos ancestrais de uma pessoa

A) Incorreto. Dados de cartão de crédito são dados pessoais, mas não dados de categoria especial.
B) Correto. Dados pessoais que revelem opiniões políticas constituem dados pessoais especiais. (Literatura: A, Capítulo 1; Artigo 9(1) do GDPR)
C) Incorreto. Informações genealógicas de pessoas vivas constituem dados pessoais, mas não de categoria especial. O GDPR não é aplicável aos dados de pessoas falecidas.

15 / 40
Para planejar o tamanho da área de estacionamento necessária, um governo local monitora e salva o número da placa de cada carro que entra e sai do centro da cidade. Foi obtida uma permissão para coletar dados sobre o número de carros presentes no centro da cidade.

Pela comparação dos horários de entrada e saída para as placas, é calculado o número de carros presentes a cada momento de cada dia. A cada mês é gerado um relatório detalhando o número médio de carros presentes no centro da cidade em momentos específicos para cada dia da semana. Em todas as entradas no centro da cidade, um cartaz explica com clareza quais dados são coletados por quem, a finalidade do processamento e o fato de que os números das placas serão armazenados em segurança por até dois anos, porque as medidas serão repetidas no ano seguinte.

Que princípio básico do processamento legítimo de dados pessoais está sendo **violado** neste caso?

A) Os dados pessoais devem ser coletados para finalidades especificadas, explícitas e legítimas e não devem ser processados adicionalmente.
B) Os dados pessoais devem ser mantidos de modo que permita a identificação dos titulares dos dados por um período não maior que o necessário.
C) Os dados pessoais devem ser processados de modo que garanta a segurança apropriada dos dados pessoais.
D) Os dados pessoais devem ser processados de modo transparente em relação ao titular dos dados.

A) Incorreto. O governo local está autorizado a coletar dados sobre o número de carros presentes.
B) Correto. Nessa situação, não há necessidade de reter os dados de um carro específico, identificando o proprietário, após ele ter deixado a área. (Literatura: A, Capítulo 2; Artigo 5 do GDPR)
C) Incorreto. Essa situação não sugere uma segurança inadequada.
D) Incorreto. O processamento está ocorrendo de um modo transparente, pois é comunicado adequadamente aos titulares dos dados.

16 / 40
Os dados pessoais devem ser adequados, relevantes e limitados ao que for necessário em relação às finalidades para as quais são processados.

Que princípio do processamento de dados é descrito aqui?

A) Exatidão
B) Minimização de dados
C) Equidade e transparência
D) Limitação de finalidade

A) Incorreto. Exatidão é o princípio pelo qual os dados pessoais devem ser exatos e atualizados.
B) Correto. Minimização de dados significa que os dados pessoais devem ser adequados, relevantes e limitados ao que for necessário. (Literatura: A, Capítulo 2; Artigo 5(1) do GDPR)
C) Incorreto. Equidade e transparência significam que os dados pessoais devem ser processados de um modo legal, imparcial e transparente em relação ao titular dos dados.
D) Incorreto. Limitação das finalidades significa que os dados pessoais devem ser coletados para finalidades especificadas, explícitas e legítimas e não devem ser processados adicionalmente de um modo incompatível com essas finalidades; o processamento adicional para fins de arquivamento por interesse público, fins de pesquisa científica ou histórica ou fins estatísticos, de acordo com o Artigo 89(1) do GDPR, não deve ser considerado incompatível com as finalidades iniciais.

17 / 40
Um indivíduo está se mudando da cidade A para a cidade B, em um estado membro da Área Econômica Europeia (AEE). Na cidade A, ele era um paciente do hospital local A. Na cidade B, passa a ser um paciente do hospital B. O paciente optou pela não inclusão no sistema nacional de prontuários eletrônicos de pacientes.

O paciente solicita que o hospital A encaminhe seu prontuário médico diretamente ao hospital B.

De acordo com o GDPR, o que é permitido?

A) O hospital em A pode enviar os dados diretamente ao hospital B, como solicitado pelo paciente.
B) O hospital em A pode enviar o prontuário ao hospital B, antes que seja solicitado pelo paciente.
C) O hospital em A pode enviar o prontuário médico ao titular dos dados, mas não a outro hospital.
D) O hospital em A não pode enviar o prontuário porque não há uma base legítima para o processamento.

A) Correto. O direito à portabilidade permite isso. (Literatura: A, Capítulo 3)
B) Incorreto. O hospital em B só pode adquirir o prontuário de A com o consentimento ou se for de interesse vital para o titular dos dados e o consentimento não puder ser obtido.
C) Incorreto. O titular dos dados pode pedir que os dados sejam enviados diretamente.
D) Incorreto. Uma solicitação do titular dos dados, que implica consentimento, constitui uma base legítima suficiente.

18 / 40
Uma empresa tem planos para processar dados pessoais. O Data Protection Officer (DPO) recentemente indicado executa uma Avaliação de Impacto sobre a Proteção de Dados (DPIA). O DPIA constata que todos os computadores têm uma configuração que faz os monitores exibirem um protetor de tela após cinco segundos de inatividade. Contudo, os computadores não são bloqueados automaticamente. Quando os funcionários deixam sua mesa, geralmente também não bloqueiam seus computadores.

Isso é um exemplo de quê?

A) Acesso a dados
B) Violação de dados pessoais
C) Incidente de segurança
D) Vulnerabilidade da segurança

A) Incorreto. Os dados não foram acessados.
B) Incorreto. Nenhum dado pessoal foi processado sem autorização até o momento; portanto, isto não é uma violação.
C) Incorreto. O processamento ainda vai ser iniciado; não há motivos para supor que um incidente tenha ocorrido.
D) Correto. A confidencialidade dos dados não pode ser garantida se os funcionários deixarem suas estações de trabalho sem bloquear o computador. (Literatura: A, Capítulo 2; Artigo 5(1)(f) do GDPR)

19 / 40
O GDPR refere-se aos princípios de proporcionalidade e subsidiariedade.

Qual é o significado de subsidiariedade neste contexto?

A) Dados pessoais só podem ser processados de acordo com a especificação da finalidade.
B) Dados pessoais não podem ser reutilizados sem um consentimento explícito e informado.
C) Dados pessoais só podem ser processados quando não houver outros meios para obter a finalidade.
D) Dados pessoais devem ser adequados, relevantes e não excessivos em relação às finalidades.

A) Incorreto. Essa é uma das limitações legais.
B) Incorreto. Essa é uma das limitações legais.
C) Correto. Essa é a definição de subsidiariedade. (Literatura: A, Capítulo 3; Artigo 35(7) do GDPR)
D) Incorreto. Essa é a definição de proporcionalidade.

20 / 40
"O controlador deve implementar medidas técnicas e organizacionais apropriadas para garantir que (...) sejam processados somente os dados pessoais que sejam necessários para cada finalidade específica do processamento."

Que termo do GDPR é definido aqui?

A) Conformidade
B) Proteção de dados desde a concepção (by design) e por padrão (by default)
C) Proteção de dados incorporada

A) Incorreto. Conformidade significa cumprir regras ou normas.
B) Correto. Como padrão, o mínimo de dados pessoais deve ser processado durante o período mais curto possível, usando as melhores medidas de segurança possíveis para prevenir um acesso não autorizado. A proteção de dados desde a concepção refere-se a um processamento que inclua medidas apropriadas para implementar os princípios de proteção de dados. (Literatura: A, Capítulo 8; Artigo 25 do GDPR)
C) Incorreto. Proteção de dados incorporada é o resultado da proteção desde a concepção.

21 / 40
Durante a realização de um backup, ocorreu uma falha no disco rígido do servidor de dados. Tanto os dados quanto o backup são perdidos. O disco continha dados pessoais, mas nenhum dado pessoal de categoria especial.

O processador afirma que isto constitui uma violação de dados pessoais.

A afirmação do processador é verdadeira?

A) Sim, porque os dados pessoais no disco foram processados de modo ilegal.
B) Sim, porque não havia dados pessoais de categoria especial armazenados no disco.
C) Não, porque nenhum dado pessoal no disco foi processado, apenas destruído.
D) Não, porque isto é apenas um incidente de segurança, e não uma violação de dados.

A) Correto. A perda irrecuperável de dados pessoais é considerada como uma violação de segurança que provoca a destruição ilegal de dados pessoais, o que também faz com que represente uma violação de dados pessoais. (Literatura: A, Capítulo 5; Artigo 4(12) do GDPR)
B) Incorreto. A perda acidental de dados constitui um incidente de segurança (os dados já não estão disponíveis). De acordo com o GDPR, isto também representa um processamento ilegal de dados pessoais e, portanto, uma violação de dados pessoais. Os dados não precisam pertencer à categoria de dados pessoais especiais para que sejam enquadrados na categoria de violação de dados pessoais.
C) Incorreto. Uma falha técnica que faça com que os dados deixem de estar disponíveis constitui um incidente de segurança. O GDPR considera uma perda acidental de dados pessoais como um processamento ilegal (não por instrução do controlador ou do processador) e, portanto, como uma violação de dados pessoais.
D) Incorreto. Dados pessoais perdidos de modo irrecuperável são considerados pelo GDPR como um processamento não autorizado, portanto, uma violação de dados pessoais. O fato de que os dados foram destruídos acidentalmente também faz com que este evento seja um incidente de segurança.

22 / 40
As organizações têm a obrigação de manter diversos registros para demonstrar conformidade com o GDPR.

Qual registro **não** é obrigatório de acordo com o GDPR?

A) Um registro de todo o processamento pretendido, juntamente com a(s) finalidade(s) do processamento e as justificativas legais
B) Um registro de violações de dados com todas as características relevantes, incluindo notificações
C) Um registro das notificações enviadas à autoridade supervisora, relativas ao processamento de dados pessoais
D) Um registro de processadores, incluindo os dados pessoais fornecidos e o período pelo qual estes dados podem ser retidos

A) Incorreto. Deve ser mantido um registro de todo o processamento pretendido, com a(s) finalidade(s) e justificativas legais.
B) Incorreto. Deve ser mantido um registro de violações de dados.
C) Correto. Uma consulta prévia sobre um processamento de alto risco é obrigatória, mas não há necessidade de um registro separado das notificações enviadas. (Literatura: A, Capítulo 6; Artigo 36(1) do GDPR)
D) Incorreto. Deve ser mantido um registro de processadores e dados fornecidos.

23 / 40
Houve uma violação de dados pessoais e o controlador está redigindo uma notificação à autoridade supervisora. As seguintes informações já constam da notificação:

- A natureza da violação de dados pessoais e suas possíveis consequências.
- Informações sobre as partes que podem fornecer mais informações sobre a violação dos dados.

Que outras informações o controlador deve fornecer?

A) A informação de que as autoridades locais e nacionais foram notificadas da violação dos dados
B) O nome e os detalhes de contato dos titulares dos dados que possam ter tido seus dados violados
C) As medidas sugeridas para mitigar as consequências adversas da violação de dados
D) As informações necessárias para acessar os dados pessoais que foram violados

A) Incorreto. A autoridade supervisora deve ser informada de relatos a autoridades supervisoras de outros países da Área Econômica Europeia (AEE). Relatos a autoridades locais, por exemplo, a polícia, não precisam ser notificados.
B) Incorreto. A autoridade supervisora requer uma estimativa do número de titulares de dados envolvidos, não seus dados pessoais.
C) Correto. O controlador deve acrescentar as medidas sugeridas para mitigar as consequências adversas da violação dos dados. (Literatura: A, Capítulo 7; Artigo 33(d) do GDPR)
D) Incorreto. A autoridade supervisora precisa conhecer o tipo de dados pessoais envolvido, mas não precisa ter acesso aos dados em si.

24 / 40
De acordo com o Artigo 33 do GDPR, o controlador deve notificar uma violação de dados pessoais à autoridade supervisora sem demora injustificada e, quando possível, no máximo 72 horas após tomar ciência do fato.

Qual é a sanção máxima para o descumprimento desta obrigação de notificar?

A) € 10.000.000 ou 2% do volume global anual de negócios, o que for maior
B) € 20.000.000 ou 4% do volume global anual de negócios, o que for maior
C) Até € 500.000 com um mínimo de € 120.000
D) Até € 820.000 com um mínimo de € 350.000

A) Correto. Este é o valor máximo, de acordo com o GDPR, para uma infração da obrigação de notificar de violação de dados pessoais. (Literatura: A, Capítulo 7; Artigo 33 do GDPR)
B) Incorreto. Esta é a multa aplicada para descumprimento ou não conformidade com os princípios básicos de processamento, incluindo as condições para o consentimento.
C) Incorreto. Este é um valor desatualizado, baseado no Código penal Holandês. As regras do GDPR especificam multas mais altas.
D) Incorreto. Este é um valor desatualizado, baseado no Código penal Holandês. As regras do GDPR especificam multas mais altas.

25 / 40
De acordo com o GDPR, qual é uma tarefa da autoridade supervisora?

A) Implementar medidas técnicas e organizacionais para garantir a conformidade
B) Investigar violações de segurança de informações corporativas
C) Monitorar e impor a aplicação do GDPR

A) Incorreto. Esta é a tarefa do controlador.
B) Incorreto. Apenas violações de dados pessoais interessam à autoridade supervisora.
C) Correto. Esta é a principal tarefa da autoridade supervisora. (Literatura: A, Capítulo 7)

26 / 40
Uma empresa belga tem sua sede na França por motivos fiscais. Ela firma um contrato juridicamente vinculante com um processador nos Países Baixos para o processamento de dados pessoais de titulares dos dados de várias nacionalidades.

Ocorre uma violação de dados pessoais. A autoridade supervisora inicia uma investigação.

Por que a autoridade supervisora francesa é considerada como a autoridade supervisora principal?

A) Porque a França está localizada no meio da Europa
B) Porque a França é o maior dos três países da Área Econômica Europeia (AEE)
C) Porque a sede da empresa está na França

A) Incorreto. A posição geográfica dos países é irrelevante.
B) Incorreto. O tamanho dos países é irrelevante.
C) Correto. O país do estabelecimento principal determina a autoridade supervisora principal. O estabelecimento principal é o local da administração central da organização ou, em outras palavras, sua sede. (Literatura: A, Capítulo 7)

27 / 40
Em 12 de julho de 2016 a Comissão Europeia implementou uma disposição regulamentar relativa à transferência de dados pessoais entre a Área Econômica Europeia (AEE) e os Estados Unidos da América (EUA). A disposição regulamentar é baseada nas medidas para proteção de dados descritas no EU-US Privacy Shield.

Que tipo de disposição é essa?

A) Decisão de adequação
B) Exceção
C) Contrato juridicamente vinculante
D) Tratado que substitui o GDPR

A) Correto. A disposição regulamentar constitui uma decisão de adequação relativa ao processamento em terceiros países. (Literatura: A, Capítulo 7; Artigo 45 e Itens (104) e (106) do preâmbulo do GDPR)
B) Incorreto. Uma exceção é usada para situações específicas nas quais uma transferência seja necessária, mas não exista uma disposição que permita isso. (Literatura: Artigo 49(1)(d) do GDPR)
C) Incorreto. A disposição regulamentar constitui uma decisão de adequação. Um contrato juridicamente vinculante é estabelecido entre um processador e um controlador.
D) Incorreto. A disposição regulamentar constitui uma decisão de adequação. Ela não substitui o GDPR.

28 / 40
Um controlador deseja terceirizar o processamento de dados pessoais para um processador.

O que deve ser realizado **antes** da terceirização?

A) O controlador deve pedir permissão à autoridade supervisora para terceirizar o processamento dos dados.
B) O controlador deve perguntar à autoridade supervisora se o contrato por escrito combinado está em conformidade com os regulamentos.
C) O controlador e o processador devem preparar uma minuta e assinar um contrato por escrito garantindo a confidencialidade dos dados.
D) O processador deve demonstrar ao controlador que todas as demandas acordadas no acordo de nível de serviço (ANS) são cumpridas.

A) Incorreto. O controlador não precisa pedir a permissão da autoridade supervisora para cada caso de terceirização.
B) Incorreto. A autoridade supervisora não é um advogado ou departamento jurídico e não verifica a conformidade de contratos.
C) Correto. Deve haver um contrato por escrito garantindo a confidencialidade dos dados, listando os objetivos e os métodos de processamento do modo definido pelo controlador e especificando que o processador conduzirá o processamento unicamente conforme as instruções do controlador. As duas partes devem assinar este contrato. (Literatura: A, Capítulo 8; Artigo 28(3) do GDPR)
D) Incorreto. Um ANS não é suficiente porque ele focará nas operações, não necessariamente nos objetivos.

29 / 40
Qual é o objetivo de uma auditoria de proteção de dados pela autoridade supervisora?

A) Aconselhar o controlador sobre a mitigação de riscos à privacidade para proteger o controlador de pedidos de indenização de responsabilidade civil por não conformidade
B) Atender a obrigação no GDPR de implementar medidas técnicas e organizacionais apropriadas para proteção de dados
C) Monitorar e impor a aplicação do GDPR, determinando se o processamento está sendo realizado em conformidade com o GDPR

A) Incorreto. A autoridade supervisora tem a tarefa de monitorar a conformidade e aconselhar sobre aprimoramentos, mas seu objetivo não é proteger o controlador.
B) Incorreto. A auditoria não constitui a implementação das medidas, e sim uma avaliação de sua eficácia.
C) Correto. De acordo com o GDPR, esta é uma tarefa importante da autoridade supervisora. (Literatura: A, Capítulo 7; Artigo 57(1)(a) do GDPR)

30 / 40
Para que um processamento de dados pessoais seja legal, o que **sempre** será exigido?

A) Um código de conduta deve ser estabelecido, descrevendo exatamente o que o processamento envolve.
B) O processamento deve relatado e autorizado pela autoridade supervisora.
C) Deve haver uma base legítima para o processamento de dados pessoais.

A) Incorreto. Códigos de conduta podem representar um modo de harmonizar contratos entre o controlador e o processador.
B) Incorreto. Uma consulta prévia é obrigatória somente quando um DPIA indicar um alto risco. (Artigo 36 do GDPR)
C) Correto. O processamento só é legal quando existir uma finalidade legítima. (Literatura: A, Capítulo 3; Artigo 6 do GDPR)

31 / 40
Dados pessoais podem ser transferidos para fora da Área Econômica Europeia (AEE).

De acordo com o GDPR, que transferências para fora da AEE são sempre legais?

A) Transferências baseadas nas leis do país não pertencente à AEE envolvido
B) Transferências sujeitas às regras da Organização Mundial do Comércio (OMC)
C) Transferências governadas por regras corporativas vinculantes (BCR) aprovadas
D) Transferências dentro de uma corporação ou organização global

A) Incorreto. Isto também exigiria um parecer de adequação, confiando que essas leis são suficientes.
B) Incorreto. A OMC abrange apenas o livre comércio de bens e serviços.
C) Correto. BCR aprovadas pela autoridade supervisora envolvida tornam a transferência legal. (Literatura: A, Capítulo 7; Artigo 47 do GDPR)
D) Incorreto. Isso também exigiria a adoção de BCR oficiais.

32 / 40
De acordo com o GDPR, qual seria uma descrição de regras corporativas vinculantes (BCR)?

A) Uma decisão sobre a segurança da transferência de dados pessoais para um país fora da Área Econômica Europeia (AEE)
B) Uma medida para compensar a ausência de proteção de dados em um país terceiro
C) Um conjunto de acordos abordando transferências de dados pessoais entre países situados fora da AEE
D) Um conjunto de regras aprovadas sobre a proteção de dados pessoais, usadas por um grupo de empresas

A) Incorreto. Isso se refere às decisões de adequação.
B) Incorreto. Isso se refere às salvaguardas apropriadas.
C) Incorreto. O GDPR não abrange acordos entre países não pertencentes à AEE.
D) Correto. BCR constituem um conjunto de regras aprovadas pelas autoridades supervisoras. (Literatura: A, Capítulo 3; Artigo 47 do GDPR)

33 / 40
Um contrato por escrito entre um controlador e um processador é chamado de acordo de processamento.

De acordo com o GDPR, o que **não** precisa ser abordado no contrato por escrito?

A) O código de ética comercial e conduta da contratada que será utilizado
B) Os procedimentos para violações de segurança das informações e de dados pessoais
C) As medidas técnicas e organizacionais implementadas
D) Quais dados são cobertos pelo acordo de processamento de dados

A) Correto. Embora o GDPR endosse o uso de códigos de conduta e certificação, não é obrigatório incluir esta cláusula para demonstrar a conformidade com o GDPR. (Literatura: A, Capítulo 8; Artigo 28(3) do GDPR)
B) Incorreto. Isso é obrigatório porque descreve as obrigações do processador em relação à notificação de uma violação de dados pessoais (pelo controlador) à autoridade supervisora.
C) Incorreto. Isso é obrigatório porque descreve as medidas técnicas e organizacionais que devem ser adotadas pelo processador.
D) Incorreto. Isso é obrigatório porque descreve os dados pessoais, incluindo dados pessoais de categoria especial, cobertos pelo contrato.

34 / 40
Um dos objetivos de uma Avaliação de Impacto sobre a Proteção de Dados (DPIA) é fortalecer a confiança dos clientes ou cidadãos no modo como os dados pessoais são processados e a privacidade é respeitada.

Como um DPIA pode fortalecer a confiança?

A) A organização minimiza o risco de ajustes dispendiosos dos processos ou remodelamento dos sistemas em um estágio mais tardio.
B) A organização previne a não conformidade com o GDPR e minimiza o risco de multas.
C) A organização prova que considera a privacidade com seriedade e visa à conformidade com o GDPR.

A) Incorreto. Este aspecto pode fortalecer a confiança da gerência, mas não de clientes ou cidadãos.
B) Incorreto. A prevenção de multas pode fortalecer a confiança da gerência, mas não de clientes ou cidadãos.
C) Correto. A realização de um DPIA mostra aos clientes ou cidadãos que a empresa leva a proteção de dados a sério. (Literatura: A, Capítulo 8)

35 / 40
Um dos sete princípios da proteção de dados desde a concepção (by design) é a *Funcionalidade – Soma Positiva, Diferente de Zero*.

Qual é a essência deste princípio?

A) As normas de segurança aplicadas devem garantir a confidencialidade, a integridade e a disponibilidade dos dados pessoais durante todo o seu ciclo de vida.
B) Se diferentes tipos de objetivos legítimos forem contraditórios, os objetivos de privacidade devem ter prioridade em relação a outros objetivos de segurança.
C) Ao incorporar a privacidade em uma determinada tecnologia, processo ou sistema, isto deve ser realizado de tal modo que a funcionalidade completa não seja prejudicada.
D) Sempre que possível, avaliações detalhadas de impacto na privacidade e riscos devem ser realizadas e publicadas, documentando com clareza os riscos para a privacidade.

A) Incorreto. Este é um aspecto da Segurança de Ponta-a-Ponta – Proteção do Ciclo de Vida, um dos outros seis princípios básicos.
B) Incorreto. A proteção de dados desde a concepção rejeita a ideia de que a privacidade compete com outros interesses, objetivos do projeto e capacidades técnicas.
C) Correto. Esta é a essência. (Literatura: A, Capítulo 8; Artigo 25 do GDPR)
D) Incorreto. Este é um aspecto da Privacidade Incorporada ao Design, um dos outros seis princípios básicos.

36 / 40
Uma empresa deseja utilizar os dados pessoais de seus clientes. Ela pretende começar a enviar um informativo personalizado a todas as clientes do sexo feminino.

Que direito todos os titulares dos dados terão nesta situação?

A) O direito à compensação
B) O direito de se opor à definição de perfis
C) O direito à retificação

A) Incorreto. É improvável que todos os titulares dos dados sofram um prejuízo que deva ser compensado nessa situação.
B) Correto. Todos os titulares dos dados têm direito de se opor ao processamento de dados pessoais para marketing direto, incluindo a definição de perfis. Isto claramente constitui uma definição de perfis. (Literatura: A, Capítulo 4)
C) Incorreto. É improvável que a empresa tenha dados incorretos sobre todos os titulares de dados. Portanto, o direito à retificação não é aplicável.

37 / 40
Qual seria uma descrição de proteção de dados desde a concepção (by design) e como padrão (by default)?

A) Uma abordagem que implementa a proteção dos dados desde o início.
B) Uma indicação de prazos se o processamento estiver relacionado ao apagamentos.
C) Os dados só podem ser coletados para finalidades explícitas e legítimas.
D) Não manter mais dados que o estritamente necessário para o processamento.

A) Correto. Esta é a descrição correta. (Literatura: A, Capítulo 8; Artigo 25(1) do GDPR)
B) Incorreto. Esta é a descrição de uma Avaliação de Impacto sobre a Proteção de Dados (DPIA).
C) Incorreto. Esta é uma descrição de medidas adotadas para conformidade com o princípio de limitação de finalidade.
D) Incorreto. Esta é uma descrição dos procedimentos usados para conformidade com o princípio de minimização de dados.

38 / 40
De acordo com o GDPR, quando uma Avaliação de Impacto sobre a Proteção de Dados (DPIA) é obrigatória?

A) Quando um projeto incluir tecnologias ou processos que utilizem dados pessoais
B) Quando for provável que o processamento cause um alto risco para os direitos dos titulares dos dados
C) Quando operações de processamento semelhantes com riscos comparáveis forem repetidas

A) Incorreto. O DPIA é obrigatório apenas para tecnologias e processos que tenham a probabilidade de gerar um alto risco para os direitos dos titulares dos dados.
B) Correto. Para operações de processamento que tenham a probabilidade de gerar um alto risco, um DPIA é obrigatório para avaliar esses riscos e projetar medidas de mitigação. (Literatura: A, Capítulo 6; Artigo 35 do GDPR)
C) Incorreto. Esse é um caso em que o DPIA não precisa ser repetido.

39 / 40
O GDPR descreve o princípio de minimização de dados.

Como as organizações podem obedecer a esse princípio?

A) Aplicando o conceito de privilégio mínimo aos dados pessoais coletados, armazenados ou de outro modo processados.
B) Limitando o direito de acesso às pessoas que precisarem dos dados pessoais para as operações de processamento pretendidas.
C) Limitando os tamanhos dos arquivos, salvando todos os dados pessoais processados no menor formato possível.
D) Limitando os dados pessoais àquilo que for adequado, relevante e necessário para os objetivos do processamento.

A) Incorreto. A minimização dos dados não aborda o privilégio mínimo.
B) Incorreto. Isso descreve o conceito de limite de autorização, por exemplo, para obedecer ao princípio de integridade e confidencialidade.
C) Incorreto. De acordo com o GDPR, a minimização dos dados não envolve o tamanho do armazenamento, e sim a redução do uso de dados pessoais a um mínimo.
D) Correto. Essa é a essência da descrição no GDPR. (Literatura: A, Capítulo 2; Artigo 5(1)(c) do GDPR)

40 / 40
Qual é a **principal** utilização de um cookie persistente?

A) Garantir que os dados pessoais do usuário sejam armazenados com segurança no servidor
B) Personalizar a experiência do usuário do site durante uma próxima visita
C) Registrar cada tecla pressionada por um usuário computador para descobrir senhas
D) Salvar as páginas que um usuário marcar como favoritas no histórico do navegador do usuário

A) Incorreto. Cookies não são usados para armazenar dados no servidor.
B) Correto. Essa é a principal finalidade de um cookie persistente. (Literatura: A, Capítulo 8)
C) Incorreto. Os cookies não são maliciosos por natureza, porém o mecanismo pode ser explorado de um modo malicioso.
D) Incorreto. Os favoritos e o histórico do navegador são salvos, mas não em um cookie.

Avaliação

A tabela a seguir mostra as respostas corretas às questões apresentadas neste exame simulado.

Questão	Resposta	Questão	Resposta
1	C	**21**	A
2	D	**22**	C
3	A	**23**	C
4	A	**24**	A
5	B	**25**	C
6	B	**26**	C
7	A	**27**	A
8	B	**28**	C
9	D	**29**	C
10	C	**30**	C
11	C	**31**	C
12	C	**32**	D
13	A	**33**	A
14	B	**34**	C
15	B	**35**	C
16	B	**36**	B
17	A	**37**	A
18	D	**38**	B
19	C	**39**	D
20	B	**40**	B



Contato EXIN

www.exin.com